

FUNDAMENTALS OF CYBER SECURITY

- **UNIT-I**

1. Introduction to Cybercrime
2. Cyber offenses: How Criminals Plan Them
3. Mobile and Wireless Devices

- **UNIT-II**

1. Tools and methods used in Cybercrime
2. Phishing and Identity Theft

- **UNIT – III**

1. Understanding Computer Forensics

Unit-I

1. Introduction to Cybercrime

- Cybercrime - Definition and Origins of the Word
- Cybercrime and Information Security
- Who are Cybercriminals?
- Classifications of Cyber Crimes.

Unit-I

2. Cyber offenses: How Criminals Plan Them

- Introduction
- How Criminals Plan the Attacks
- Social Engineering
- Cyberstalking
- Cybercafe and Cybercrimes
- Botnets: The Fuel for Cybercrime

Unit-I

3. Cybercrime: Mobile and Wireless Devices

- Introduction
- Proliferation of Mobile and Wireless Devices
- Credit Card Frauds in Mobile and Wireless Computing Era
- Authentication Service Security
- Attacks on Mobile/Cell Phones
- Organizational Measures for Handling Mobile

TEXTBOOK

Sunit Belapure and Nina Godbole, “**Cyber Security: Understanding Cyber Crimes, Computer Forensics And Legal Perspectives**”, Wiley India Pvt Ltd, ISBN: 978-81- 265-21791, Publish Date 2013.

REFERENCE BOOKS:

1. Thomas J. Mowbray, “Cybersecurity: Managing Systems, Conducting Testing, and Investigating Intrusions”, Copyright © 2014 by John Wiley & Sons, Inc, ISBN: 978-1-118 -84965 -1.
2. James Graham, Ryan Olson, Rick Howard, “Cyber Security Essentials”, CRC Press, 15-Dec 2010.
3. Anti- Hacker Tool Kit (Indian Edition) by Mike Shema, Publication Mc Graw-Hill

Introduction to Cybercrime

Dr. Ravi B , Dept of ISE

Introduction to Cybercrime

Topics :

1. Cybercrime - Definition and Origins of the Word
2. Cybercrime and Information Security
3. Who are Cybercriminals?
4. Classifications of Cyber Crimes.

1) Introduction to Cybercrime

- Cybercrime is a new way of exploitation (involves the use of computers, the Internet, cyberspace and the world wide web).
- The first recorded cybercrime took place in the year 1820.
- While the worldwide scenario on cybercrime looks bleak, the situation in India is not any better.
- Indian corporate and government sites have been attacked or defaced more than 780 times between February 2000 and December 2002.
- According to a story posted on 3 December 2009, a total of 3,286 Indian websites were hacked in 5 months – between January and June 2009 (Old data)

1) Introduction to Cybercrime

Definition :

- *Cybercrime is any illegal behaviour, directed by means of electronic operations, that targets the security of computer systems and the data processed by them.*
- Cyberspace is a term **coined by William Gibson**, a science fiction writer, in his Sci-fi novel **Neuromancer** published in 1984
(He suggested it as a consensual hallucination)
- **The term “cybercrime” relates to a number of other terms:**
Computer-related crime, Computer crime, Internet crime, E-crime, High-tech crime

1) Introduction to Cybercrime

- **Cybercrime** specifically can be defined in a number of ways;
 1. *A crime committed using a computer and the Internet to steal a person's identity (identity theft) or sell contraband(illegal items) or stalk victims or disrupt operations with malevolent(causing harm) programs.*
 2. *Crimes completed either on or with a computer.*
 3. *Any illegal activity done through the Internet or on the computer.*
 4. *All criminal activities done using the medium of computers, the Internet, cyberspace and the WWW.*

1) Introduction to Cybercrime

- Two types of cyber attacks are prevalent: Techno-crime and Techno-vandalism

1. Techno-crime:

- A premeditated act against a system or systems, with the intent to copy, steal, prevent access, corrupt or otherwise deface or damage parts of or the complete computer system.
- The 24 × 7 connection to the Internet makes this type of cybercrime a real possibility to engineer from anywhere in the world, leaving few, if any, “finger prints.”

1) Introduction to Cybercrime

2. Techno-vandalism:

- These acts of “brainless” defacement of websites and/or other activities, such as copying files and publicizing their contents publicly, are usually opportunistic in nature.
- Tight internal security, allied to strong technical safeguards, should prevent the vast majority of such incidents.

1) Introduction to Cybercrime

What is cyber?

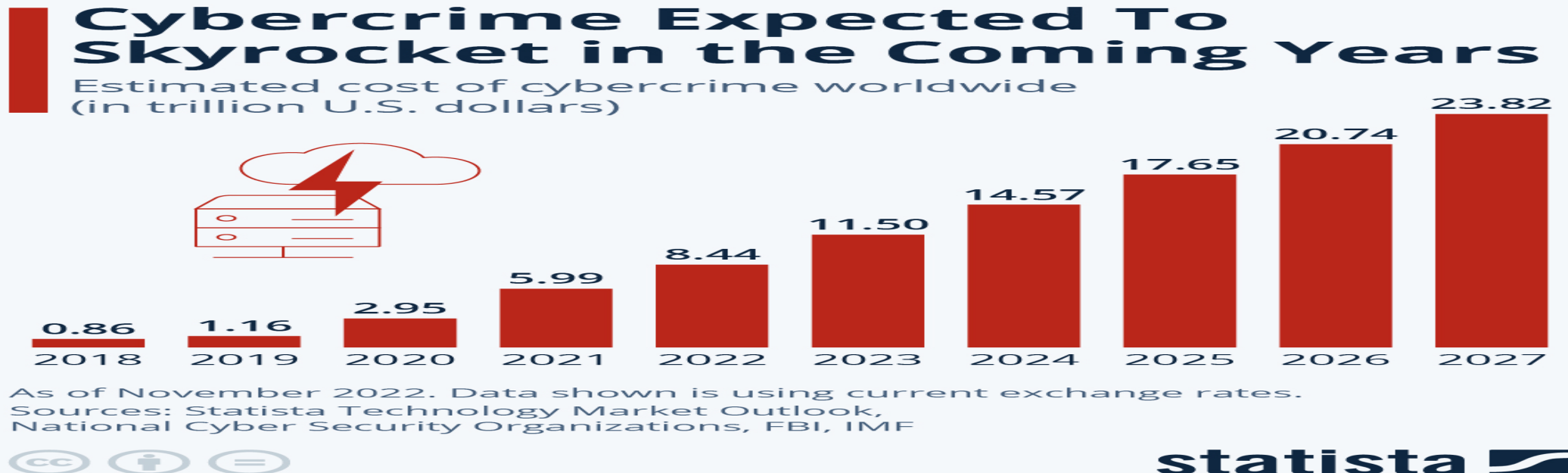
- Cyber means combining forms relating to **Information Technology, the Internet and Virtual Reality.**
- This term owes its origin to the word “cybernetics” which deals with information and its use; *Cybernetics is the science that overlaps the fields of neurophysiology, information theory, computing machinery and automation.*
- According to Wikipedia cybernetics is the interdisciplinary study of the structure of regulatory systems. It is closely related to control theory and systems theory.

1) Introduction to Cybercrime

- **Cyberterrorists** usually use computer as a tool, target or both for their unlawful act to gain information which can result in heavy loss/damage to the owner of that intangible sensitive information.
- Internet is one of the means by which the offenders can gain priced sensitive information of companies, firms, individuals, banks and can lead to intellectual property (IP) crimes (such as stealing new product plans, its description, market program plans, list of customers, etc.), selling illegal articles, pornography/child pornography, etc.
- This is done using methods such as **Phishing, Spoofing, Pharming, Internet Phishing, wire transfer, etc**

1) Introduction to Cybercrime

- “Phishing” refers to an attack using mail programs to deceive or coax Internet users into disclosing confidential information that can be then exploited for illegal purposes. Figure 1.2 shows the increase in **Phishing** hosts.



2) Cybercrime and Information Security

What is *Cybersecurity*?

- Lack of information security gives rise to **cybercrimes**
- ***“Cybersecurity” means protecting information, equipment, devices, computer, computer resource, communication device and information stored therein from unauthorized access, use, disclosure, disruption, modification or destruction. (Indian Information Technology Act (ITA-2008))***
- The term incorporates both the physical security of devices as well as the information stored therein.
- It covers protection from unauthorized access, use, disclosure, disruption, modification and destruction.

2) Cybercrime and Information Security

- To avoid negative publicity, most organizations abstain from revealing facts and figures about “security incidents” including cybercrime (outsider or insider crime). Reporting of financial losses due cybercrime also often remains approximate.
- Typical network misuses are for Internet radio/streaming audio, streaming video, file sharing, instant messaging and online gaming (such as online poker, online casinos, online betting, etc.;)
- Online gambling is illegal in some countries – for example, in India. However, India has yet to pass laws that specifically deal with the issue, leaving a sort of legal loophole in the meantime.

2) Cybercrime and Information Security

- Figure 1.4 shows several categories of incidences – viruses, insider abuse, laptop theft and unauthorized access to systems.

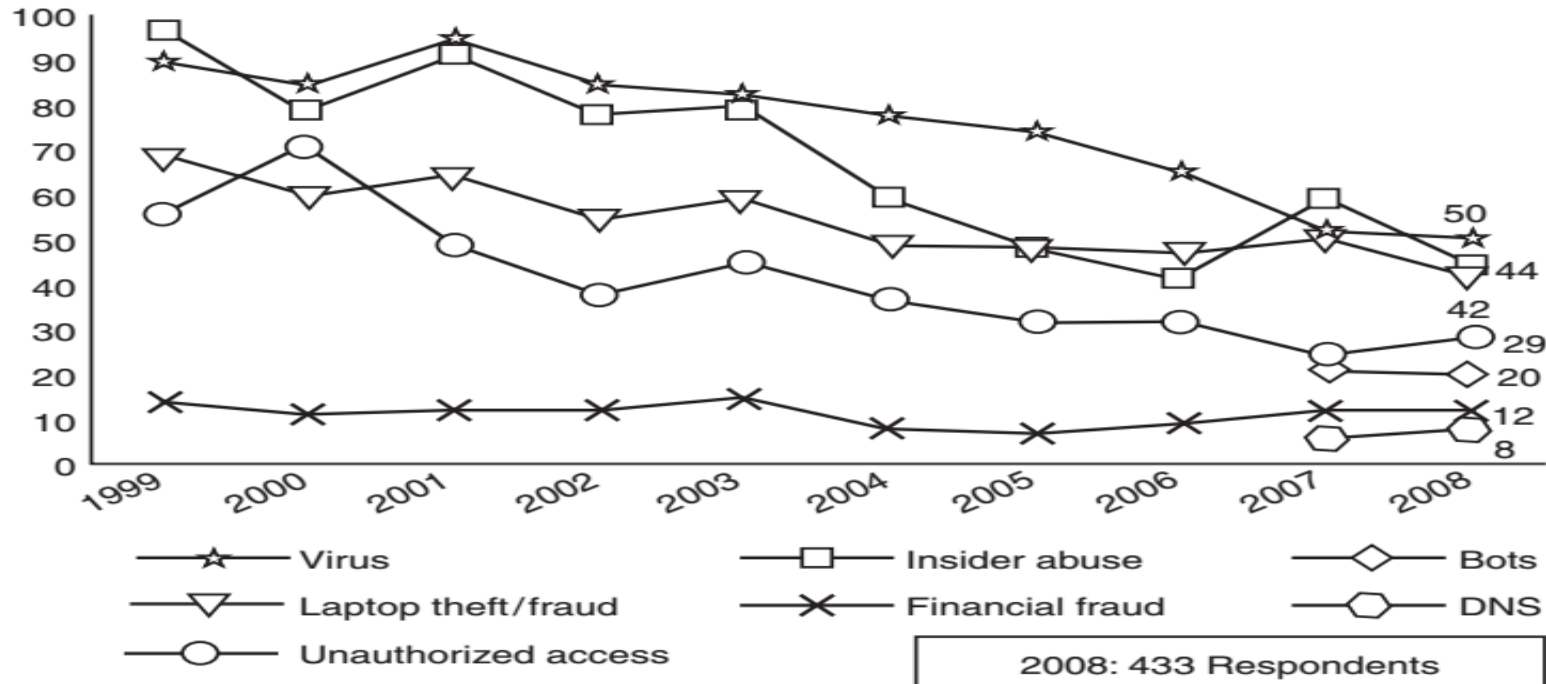
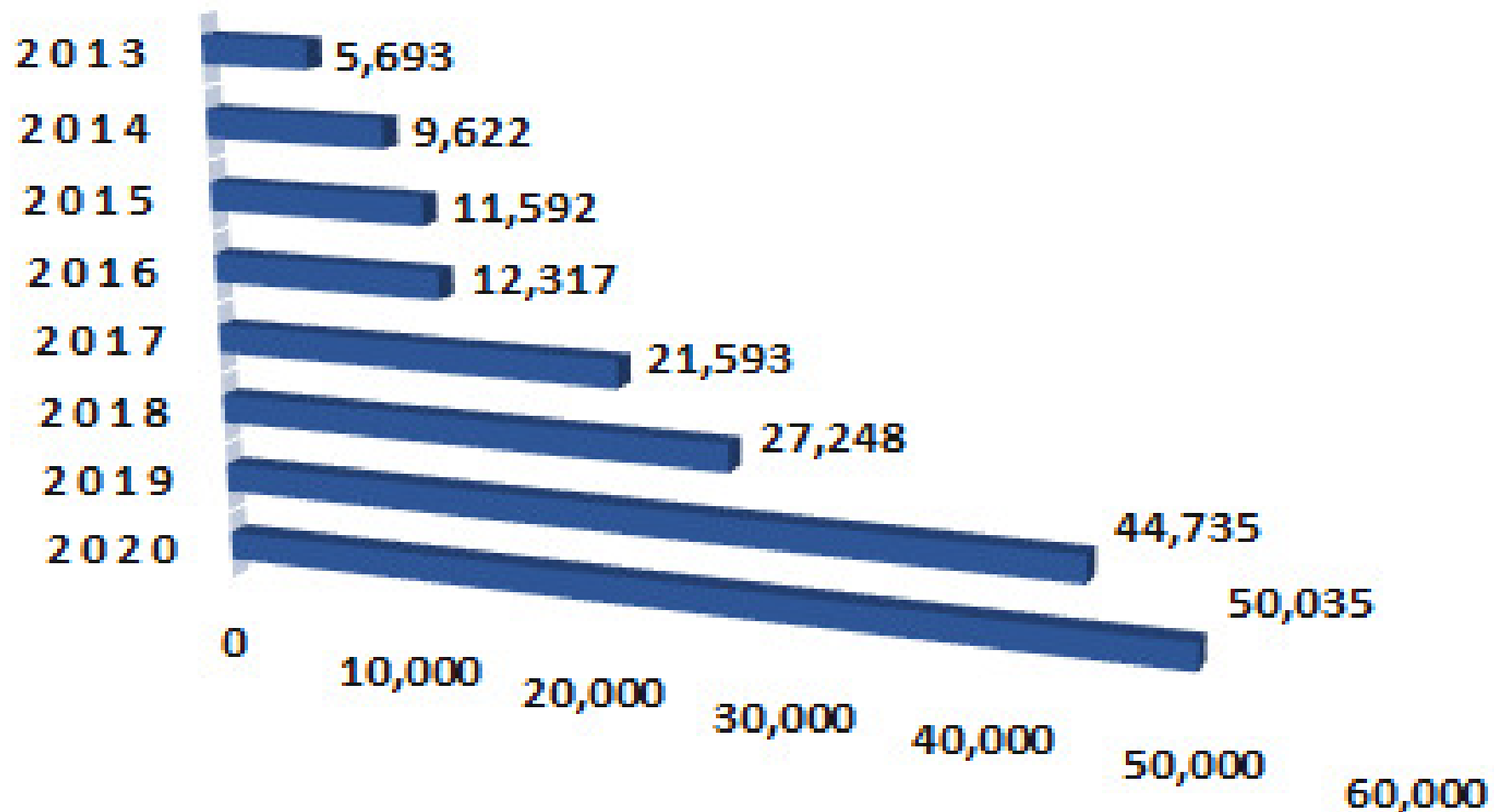
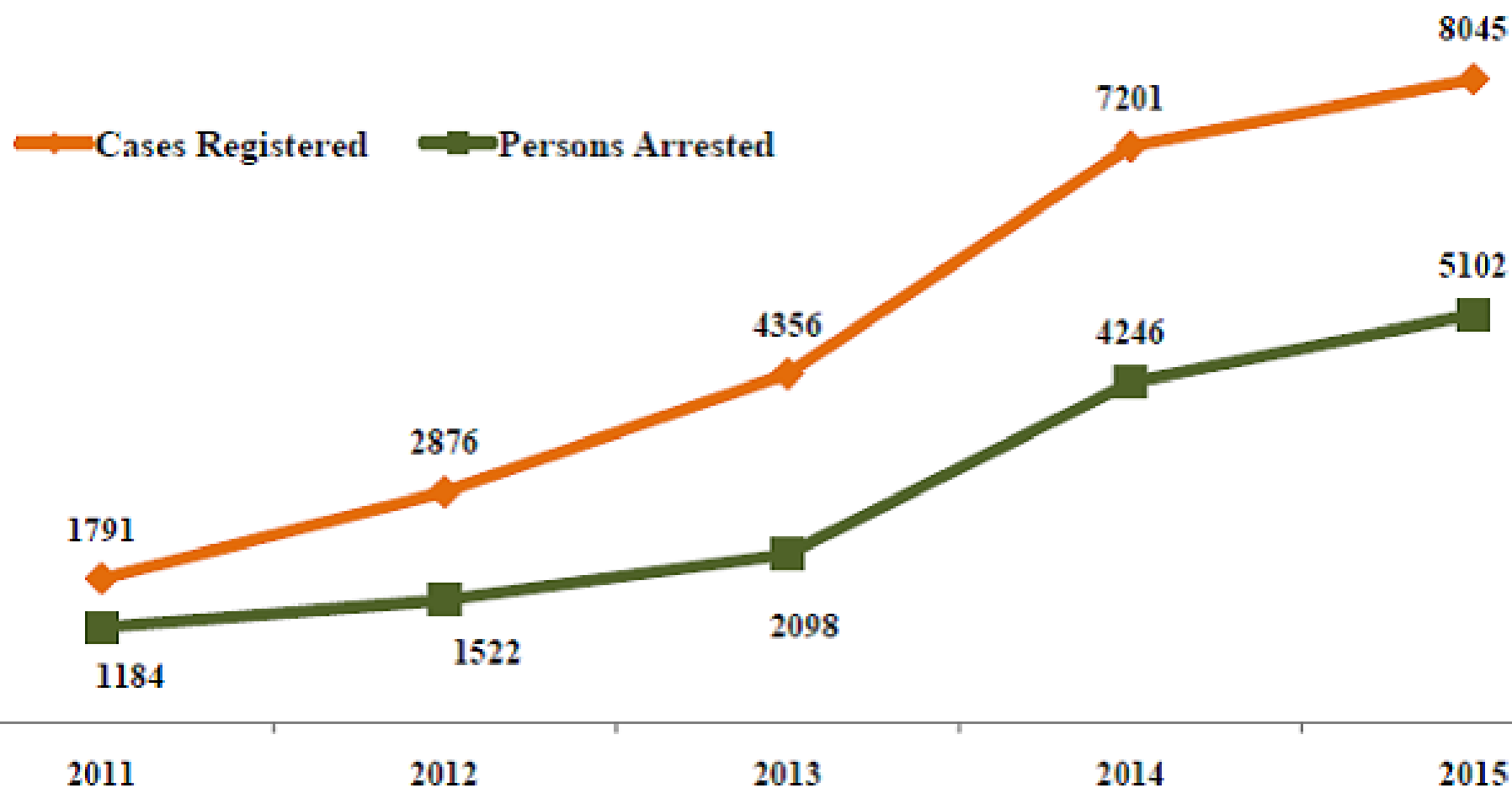


Figure 1.4 Major types of incidents by percentage.
Source: 2008 CSI Computer Crime and Security Survey available at the link <http://i.cmpnet.com/v2.gocsi.com/pdf/CSIsurvey2008.pdf> (15 March 2009).

CYBER CRIME REPORTED IN INDIA



Cyber Crimes in India - Cases Registered Under IT Act (2011-15)



2) Cybercrime and Information Security

The Botnet menace

- The term Botnet is used to refer to a group of compromised computers(zombie computers, i.e., **personal computers secretly under the control of hackers**) running malwares under a common command and control infrastructure.
- A Botnet maker can control the group remotely for illegal purposes, the most common being DoS attack, Adware, Spyware, E-mail spam, click fraud, theft of application serial numbers, login IDs and financial information such as credit card numbers, etc.
- The computer may continue to operate normally without the owner's knowledge that his computer has been compromised.

2) Cybercrime and Information Security

The Botnet menace (Cont...)

- Small and medium businesses in the country are at greater risk, as they are highly vulnerable to Bots, Phishing, Spam and Malicious Code attacks.
- **Mumbai with 33% incidences** tops the Bot-infected city list, followed by New Delhi at 25%, Chennai at 17% and Bangalore at 13%.
- If the computers, computer systems, computer resources, etc. are unsecured and vulnerable to security threats, it can be detrimental to the critical infrastructure of the country

The Botnet menace - How it works? (Cont...)



2) Cybercrime and Information Security

The Cybercrime trend over the years

Table 1.5 | Cybercrime trend over the years (1999–2008)

<i>Types of Cybercrime</i>	<i>2004 (%)</i>	<i>2005 (%)</i>	<i>2006 (%)</i>	<i>2007 (%)</i>	<i>2008 (%)</i>
Denial of service (DoS)	39	32	25	25	21
Laptop theft	49	48	47	50	42
Telecom fraud	10	10	8	5	5
Unauthorized access	37	32	32	25	29
Viruses (addressed in Chapter 4)	78	74	65	52	50
Financial fraud	8	7	9	12	12
Insider abuse	59	48	42	59	44
System penetration	17	14	15	13	13
Sabotage	5	2	3	4	2
Theft/loss of proprietary information	10	9	9	8	9
• from mobile devices					4
• from all other sources					5
Website defacement (see Figs. 1.6–1.10)	7	5	6	10	6
Abuse of wireless network	15	16	14	17	14
Misuse of web application	10	5	6	9	11
Bots (see Box 1.2; more in Chapter 2)				21	20
DoS attacks				6	8
Instant messaging abuse				25	21
Password sniffing (explained in Chapter 2)				10	9
Theft/loss of customer data				17	17
• from mobile devices					8
• from all other sources					8

Source: 2008 CSI Computer Crime and Security Survey available at the link <http://i.cmpnet.com/v2.gocsi.com/pdf/CSIsurvey2008.pdf> (15 March 2009).

3) Who are Cybercriminals?

- Cybercrime involves such activities as
 - Child pornography;
 - Credit card fraud;
 - Cyberstalking;
 - Defaming another online;
 - Gaining unauthorized access to computer systems;
 - Ignoring copyright, software licensing and trademark protection;
 - Overriding encryption to make illegal copies;
 - Software piracy and stealing another's identity (known as identity theft) to perform criminal acts
- **Cybercriminals are those who conduct such acts.**

3) Who are Cybercriminals?

- They can be categorized into three groups that reflect their motivation
1. Type I: **Cybercriminals** – hungry for recognition
 - Hobby hackers;
 - IT professionals (social engineering is one of the biggest threat);
 - Politically motivated hackers;
 - terrorist organizations.
 2. Type II: Cybercriminals – not interested in recognition
 - Psychological perverts;
 - Financially motivated hackers (corporate espionage);
 - state-sponsored hacking (national espionage, sabotage);
 - organized criminals.

3) Who are Cybercriminals?

- Type III: Cybercriminals – the insiders
 - Disgruntled or former employees seeking revenge;
 - competing companies using employees to gain economic advantage through damage and/or theft.
- *The typical “motives” behind cybercrime seem to be greed, desire to gain power and/or publicity, desire for revenge, a sense of adventure, looking for thrill to access forbidden information, destructive mindset and desire to sell network security services.*

3) Who are Cybercriminals?

Motives for cybercrimes

- Revenge/settling scores
- Greed/money
- Extortion
- Cause disrepute
- Prank/satisfaction of gaining control
- Fraud/illegal gain
- Eve teasing/harassment
- others

4) Classifications of Cybercrimes

- The typical motives behind cybercrime seem to be greed, desire to gain power and/or publicity, desire for revenge, a sense of adventure, looking for thrill to access forbidden information, destructive mindset and desire to sell network security services.
- Crime is defined as ***“an act or the commission of an act that is forbidden, or the omission of a duty that is commanded by a public law and that makes the offender liable to punishment by that law.”***
- Cyber crimes are classified as:
 1. Cybercrime against individual
 2. Cybercrime against property
 3. Cybercrime against organization
 4. Cybercrime against Society
 5. Crimes emanating from Usenet newsgroup

4) Classifications of Cybercrimes

1. Cybercrime against individual

- E-Mail spoofing and other online frauds
- Phishing, spear phishing and its various other forms such as Vishing and Smishing.
- Spamming
- Cyberdefamation
- Cyberstalking and harassment
- Computer sabotage
- Pornographic offenses
- Password sniffing

4) Classifications of Cybercrimes

2. Cybercrime against property

- Credit card frauds
- Intellectual property crimes
- Internet time theft

3. Cybercrime against organization

- Unauthorized accessing of computer
- Password sniffing
- Denial-of-service attacks
- Virus attack/dissemination of viruses
- E-Mail bombing/mail bombs
- Salami attack/Salami technique
- Logic bomb
- Trojan Horse
- Data diddling
- Crimes emanating from Usenet newsgroup
- Industrial spying/industrial espionage
- Computer network intrusions
- Software piracy

4) Classifications of Cybercrimes

4. Cybercrime against Society

- Forgery
- Cyberterrorism
- Web jacking

5. Crimes emanating from Usenet newsgroup: Usenet groups may carry very offensive, harmful, inaccurate or otherwise inappropriate material, or in some cases, postings that have been mislabelled or are deceptive in another way.

4) Classifications of Cybercrimes

- **Email Spoofing**- A spoofed E-Mail is one that appears to originate from one source but actually has been sent from another source.
- **Example**

Let us say, Roopa has an E-Mail address **roopa@asianlaws.org**. Let us say her boyfriend Suresh and she happen to have a showdown. Then Suresh, having become her enemy, spoofs her E-Mail and sends obscene/vulgar messages to all her acquaintances. Since the E-Mails appear to have originated from Roopa, her friends could take offense and relationships could be spoiled for life.

4) Classifications of Cybercrimes

- **Spamming-**

- People who create electronic spam are called **spammers**.
- ***Spam is the abuse of electronic messaging systems(including most broadcast media, digital delivery systems) to send unsolicited bulk messages indiscriminately.***
- Although the most widely recognized form of Spam is E-Mail Spam, the term is applied to similar abuses in other media: instant messaging spam, Usenet newsgroup spam, web search engine spam, spam in blogs, wiki spam, online classified ads spam, mobile phone messaging spam, Internet forum spam, junk fax transmissions, social networking spam, file sharing network spam, video sharing sites, etc.

4) Classifications of Cybercrimes

- **Spamming-** (Cont...)

- Spamming is difficult to control because it has economic viability – advertisers have no operating costs beyond the management of their mailing lists, and it is difficult to hold senders accountable for their mass mailings.
- In the context of **search engine spamming**, spamming is alteration or creation of a document with the intent to deceive an electronic catalog or a filing system.
- Some web authors use “**subversive techniques**” to ensure that their site appears more frequently or higher number in returned search results – this is strongly discouraged by search engines and there are fines/ penalties associated with the use of such subversive techniques.

4) Classifications of Cybercrimes

The following web publishing techniques should be avoided

- Repeating keywords
- Use of keywords that do not relate to the content on the site
- Use of fast meta refresh
- Redirection
- IP cloaking
- Use of colored text on the same colour background
- Tiny text usage
- Duplication of pages with different URLs
- Hidden links
- Use of different pages that bridge to the same URL(gateway pages)

(webpage designed to rank highly for particular [search queries](#) that does not offer useful information to the searcher)

4) Classifications of Cybercrimes

Cyberdefamation

- **Cyberdefamation is a cognizable offense.**
- *Cyberdefamation occurs when defamation takes place with the help of computers and/or the Internet, for eg., someone publishes defamatory matter about someone on a website or sends an E-Mail containing defamatory information to all friends of that person.*

According to the IPC section 499:

1. It may amount to defamation to impute anything to a deceased person, if the imputation would harm the reputation of that person if living, and is intended to be hurtful to the feelings of his family or other near relatives.
2. It may amount to defamation to make an imputation concerning a company or an association or collection of persons as such.

4) Classifications of Cybercrimes

Cyberdefamation (Cont...)

(According to the IPC section 499):

3. An imputation in the form of an alternative or expressed ironically, may amount to defamation.
4. No imputation is said to harm a person's reputation unless that imputation directly or indirectly, in the estimation of others, lowers the moral or intellectual character of that person, or lowers the character of that person in respect of his caste or of his calling, or lowers the credit of that person, or causes it to be believed that the body of that person is in a loathsome state or in a state generally considered as disgraceful.

4) Classifications of Cybercrimes

Cyberdefamation (Cont...)

- **Libel** is written defamation and **slander** is oral defamation.
- The only issue to consider for defamation is whether a person would believe that the words would indeed injure the person's reputation. Even if there is no damage to a person's reputation, the person who made the allegations may still be held responsible for defamation
- The law on defamation attempts to create a workable balance between two equally important human rights: ***The right to an unimpaired reputation and the right to freedom of expression.***

4) Classifications of Cybercrimes

Internet Time Theft

- Such a theft occurs when an unauthorized person uses the Internet hours paid for by another person.
- Basically, Internet time theft comes under hacking because the person who gets access to someone else's ISP user ID and password, either by hacking or by gaining access to it by illegal means, uses it to access the Internet without the other person's knowledge.
- However, one can identify time theft if the Internet time has to be recharged often, even when one's own use of the Internet is not frequent. (related to the crimes conducted through "identity theft.")

4) Classifications of Cybercrimes

Salami Attack/Salami Technique

- These attacks are used for committing financial crimes. The idea here is to make the alteration so insignificant that in a single case it would go completely unnoticed

Example :

A bank employee inserts a program, into the bank's servers, that deducts a small amount of money (say ` 2/- or a few cents in a month) from the account of every customer. No account holder will probably notice this unauthorized debit, but the bank employee will make a sizable amount every month.

4) Classifications of Cybercrimes

Data diddling attack

- Involves altering raw data just before it is processed by a computer and then changing it back after the processing is completed.
- Electricity boards in India have been victims to data diddling programs inserted when private parties computerize their systems.

Forgery

- Counterfeit currency notes, postage and revenue stamps, marksheets, etc. can be forged using sophisticated computers, printers and scanners.
- Outside many colleges there are miscreants soliciting the sale of fake marksheets or even degree certificates. These are made using computers and high-quality scanners and printers.

4) Classifications of Cybercrimes

Web Jacking

- Web jacking occurs when someone forcefully takes control of a website (by cracking the password and later changing it).
- Thus, the first stage of this crime involves “password sniffing.”
- The actual owner of the website does not have any more control over what appears on that website.

Newsgroup Spam/Crimes Emanating from Usenet Newsgroup

- The advent of Google Groups, and its large Usenet archive, has made Usenet more attractive to spammers than ever.
- The first widely recognized Usenet Spam titled Global Alert for All: ***Jesus is Coming Soon was posted on 18 January 1994 by Clarence L. Thomas IV***, a sys admin at Andrews University.

4) Classifications of Cybercrimes

- **Industrial Spying/Industrial Espionage**
- Spies can get information about product finances, research and development and marketing strategies , an activity known as “industrial spying”.
- Highly skilled hackers are contracted by high-profile companies or certain governments to carry out spying
- With the growing public availability of **Trojans and Spyware** material even a low-skilled one can generate high volume profit out of industrial spying. This is referred to as “Targeted Attacks”

3) Classifications of Cybercrimes

- Industrial Spying/Industrial Espionage (Cont...)

Real Example:

One interesting case is the famous Israeli Trojan story, where a software engineer in London created a Trojan Horse program specifically designed to extract critical data gathered from machines infected by his program. He had made a business out of selling his Trojan Horse program to companies in Israel, which would use it for industrial spying by planting it into competitors' networks.

4) Classifications of Cybercrimes

- Industrial Spying/Industrial Espionage
- There are also the E-Mail worms automating similar “**data exfiltration features**”.
- **E-Mail worms** can *scan the hard drive of infected machines for all files with the following extensions: .. Such files are uploaded on an FTP server owned by the cybercrooks, with the pdf, .doc, .dwg, .sch, .pcb, .dwt, .dxf, .max, .mdbaim of stealing as much IP as possible wherever it can be and then selling it to people who are ready to pay for it.*
- *Organizations subject to online extortion tend to keep quiet about it to avoid negative publicity about them.*

4) Classifications of Cybercrimes

Hacking

Purposes

- Greed
 - Power
 - Publicity
 - Revenge
 - Adventure
 - Desire to access forbidden information
 - Destructive mindset
- Every act committed toward breaking into a computer and/or network is hacking and it is an offense. Those who break into computer systems are called crackers and those targeting phones are phreaks.

4) Classifications of Cybercrimes

Hacking (Cont...)

- Hackers **write or use ready-made computer programs** to attack the target computer.
- They possess the **desire to destruct**, and they get enjoyment out of such destruction.
- Some hackers hack for **personal monetary gains**, such as **stealing credit card** information, **transferring money from various bank accounts** to their own account followed by **withdrawal of money**.
- They **extort money** from some corporate giant threatening him to publish the stolen information that is critical in nature.
- Government websites are hot on hackers' target lists and attacks on Government websites receive **wide press coverage**. (For example, according to the story posted on December 2009, the NASA site was hacked via SQL Injection)

4) Classifications of Cybercrimes

Hacking (Cont...)

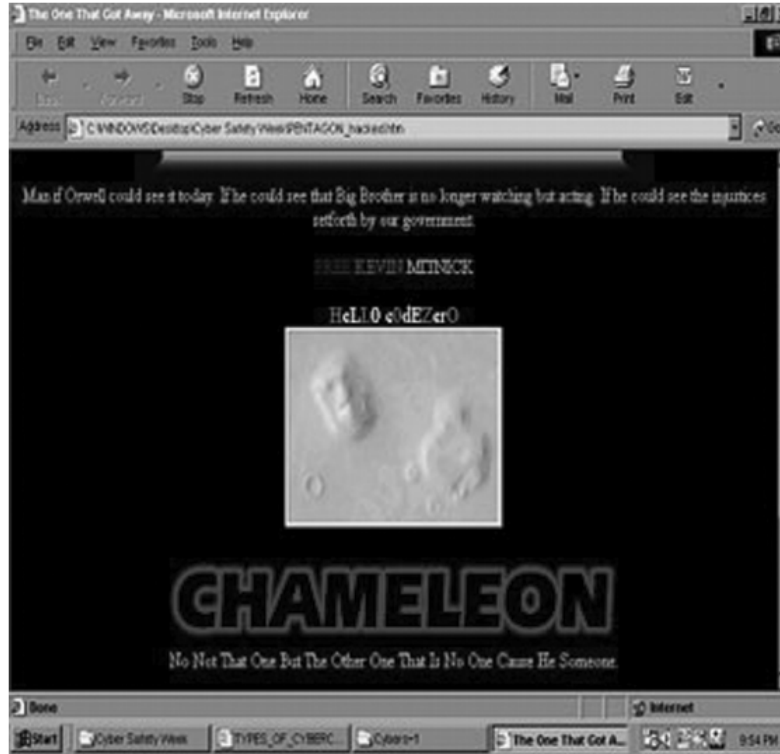
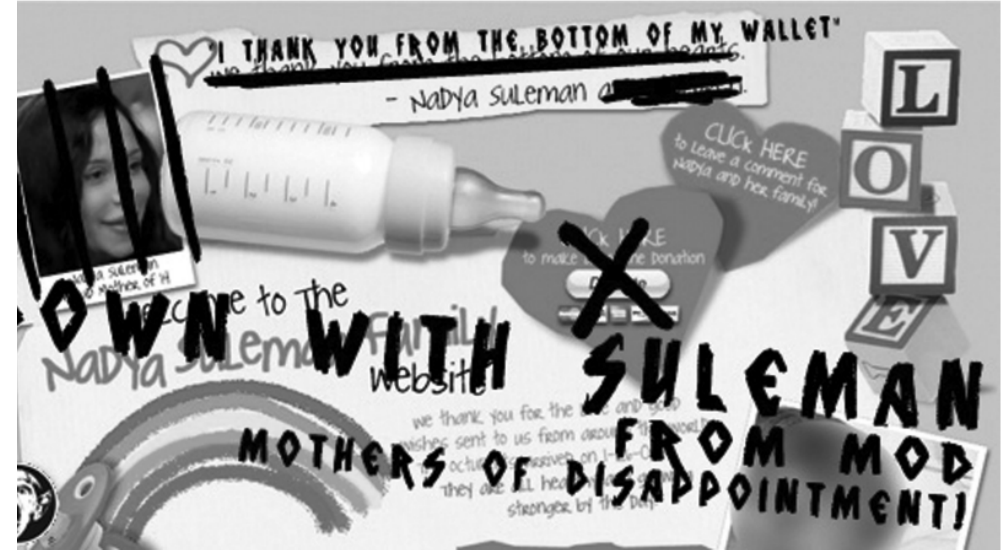


Figure 1.7 | Pentagon, the US site defaced.
Source: <http://www.keylogger.org/news-world/hackers-attack-pentagon-1086.html>



1.8 | Octomom's defaced website.
Source: <http://weeklyworldnews.com/headlines/6233/nadva-sulemans-website-hacked/>

4) Classifications of Cybercrimes

Hacking (Cont...)

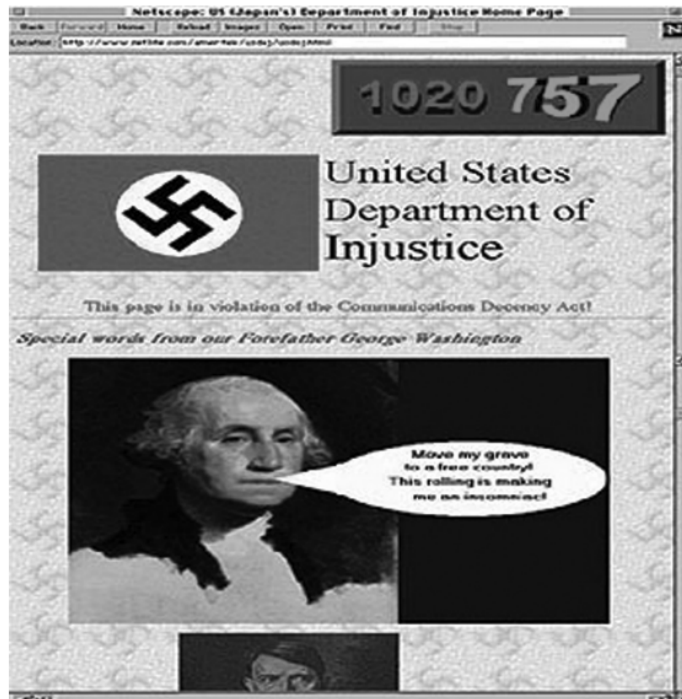


Figure 1.9 | Department of justice site defaced.
Source: <http://www.technize.com/see-all-the-hacked-and-defaced-websites/>

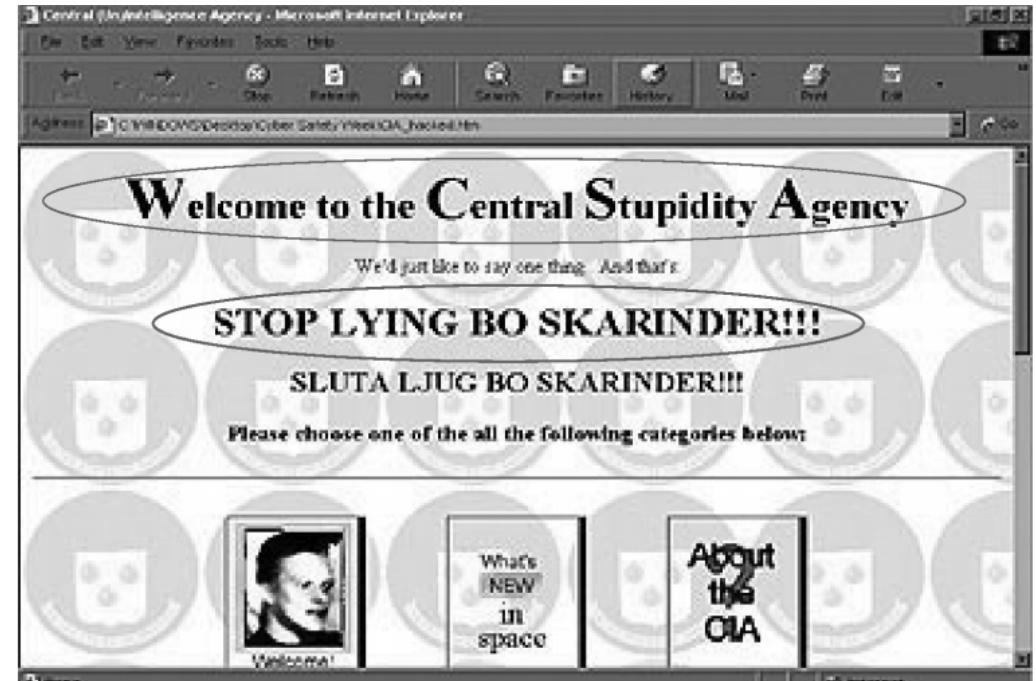


Figure 1.10 | CIA (Central Intelligence Agency), the US, website defaced.
Source: <http://www.technize.com/see-all-the-hacked-and-defaced-websites/>

4) Classifications of Cybercrimes

Online frauds

- There are a few major types of crimes under the category of hacking: Spoofing website and E-Mail security alerts, hoax mails about virus threats, lottery frauds and Spoofing
- In Spoofing websites and E-Mail security threats, fraudsters create authentic looking websites that are actually nothing but a spoof
- The purpose of these websites is to make the user enter personal information which is then used to access business and bank accounts.
- Fraudsters are increasingly turning to E-Mail to generate traffic to these websites. This kind of online fraud is common in banking and financial sector.

4) Classifications of Cybercrimes

Online frauds (Cont...)

- In **virus hoax E-Mails**, the warnings may be genuine, so there is always a dilemma whether to take them lightly or seriously.
- A wise action is to first confirm by visiting an antivirus site such as McAfee, Sophos or Symantec before taking any action, such as forwarding them to friends and colleagues.
- **Lottery frauds** are typically letters or E-Mails that inform the recipient that he/she has won a prize in a lottery. To get the money, the recipient has to reply, after which another mail is received asking for bank details so that the money can be directly transferred.
- The E-Mail also asks for a processing fee/handling fee. Of course, the money is never transferred in this case; the processing fee is swindled, and the banking details are used for other frauds and scams.

4) Classifications of Cybercrimes

Online frauds (Cont...)

- “Spoofing” means illegal intrusion, posing as a genuine user. A hacker logs-in to a computer illegally, using a different identity than his own.
- He is able to do this by having previously obtained the actual password.
- He creates a new identity by fooling the computer into thinking that the hacker is the genuine system operator and then hacker then takes control of the system.
- He can commit innumerable number of frauds using this false identity.

4) Classifications of Cybercrimes

Pornographic Offenses

- **“Child pornography”** means any visual depiction, including **but not limited** to the following:
 1. Any photograph that can be considered obscene and/or unsuitable for the age of child viewer;
 2. film, video, picture;
 3. computer-generated image or picture of sexually explicit conduct where the production of such visual depiction involves the use of **a minor engaging in sexually explicit conduct.**

4) Classifications of Cybercrimes

Pornographic Offenses (Cont...)

- **“Child pornography”** is considered an offense.
- The Internet is being highly used by its abusers to reach and abuse children sexually, worldwide. Its explosion has made the children a viable victim to the cybercrime.
- As the broad-band connections get into the reach of more and more homes, larger child population will be using the Internet and therefore greater would be the chances of falling victim to the aggression of **pedophiles**.
- **“Pedophiles”** are people who physically or psychologically **coerce minors** to engage in sexual activities, which the minors would not consciously consent to.

4) Classifications of Cybercrimes

Pornographic Offenses (Cont...)

Here is how pedophiles operate:

Step 1: Pedophiles use a **false identity** to trap the children/teenagers (using “false identity”)

Step 2: They seek children/teens in the kids’ areas on the services, such as the Teens BB, Games BB or chat areas where the children gather.

Step 3: They befriend children/teens.

Step 4: They extract personal information from the child/teen by winning his/her confidence.

Step 5: Pedophiles get E-Mail address of the child/teen and start making contacts on the victim’s E-Mail address as well. Sometimes, these E-Mails contain sexually explicit language.

4) Classifications of Cybercrimes

Pornographic Offenses (Cont...)

Step 6: They start sending pornographic images/text to the victim including child pornographic images in order to help child/teen shed his/her inhibitions so that a feeling is created in the mind of the victim that what is being fed to him is normal and that everybody does it.

Step 7: At the end of it, the pedophiles set up a meeting with the child/teen out of the house and then drag him/her into the net to further sexually assault him/her or to use him/her as a sex object.

4) Classifications of Cybercrimes

Pornographic Offenses (Cont...)

- Parents can follow simple rules to avoid this and accordingly they advice their children to keep away from dangerous things and ways.
- However, it is possible, even in the modern times most parents may not know the basics of the Internet and the associated (hidden) dangers from the services offered over the Internet.
- Hence most children may remain unprotected in the cyberworld.

4) Classifications of Cybercrimes

Software piracy

- It is defined as theft of software through the illegal copying of genuine programs, or the counterfeiting and distribution of products intended to pass for the original.
- There are many examples of software piracy:
 - ***end-user copying*** – friends loaning disks to each other, or organizations under-reporting the number of software installations they have made, or organizations not tracking their software licenses;
 - ***hard disk loading with illicit means*** – hard disk vendors load pirated software;
 - ***counterfeiting*** – large-scale duplication and distribution of illegally copied software;
 - ***illegal downloads from the Internet*** – by intrusion, by cracking serial numbers, etc.

4) Classifications of Cybercrimes

Software piracy (Cont...)

- Beware that those who buy pirated software have a lot to lose:
 - (a) getting untested software that may have been copied thousands of times over,
 - (b) the software, if pirated, may potentially contain hard-drive-infecting viruses,
 - (c) there is no technical support in the case of software failure, that is, lack of technical product support available to properly licensed users,
 - (d) there is no warranty protection
 - (e) there is no legal right to use the product, etc.

4) Classifications of Cybercrimes

Software piracy (Cont...)

- **Economic impact** : According to some Study in Asia Pacific 55% of the software installed in 2006 on personal computers (PCs) was obtained illegally, while software losses due to software piracy amounted to US\$ 11.6 billion.
- The Study covered software that runs on personal computers, including desktops, laptops and ultra-portables.
- The study includes operating systems, systems software such as databases and security packages, business applications and consumer applications such as PC games, personal finance and reference software.

4) Classifications of Cybercrimes

Software piracy (Cont...)

Dollars lost (year 2008) due to (software) piracy

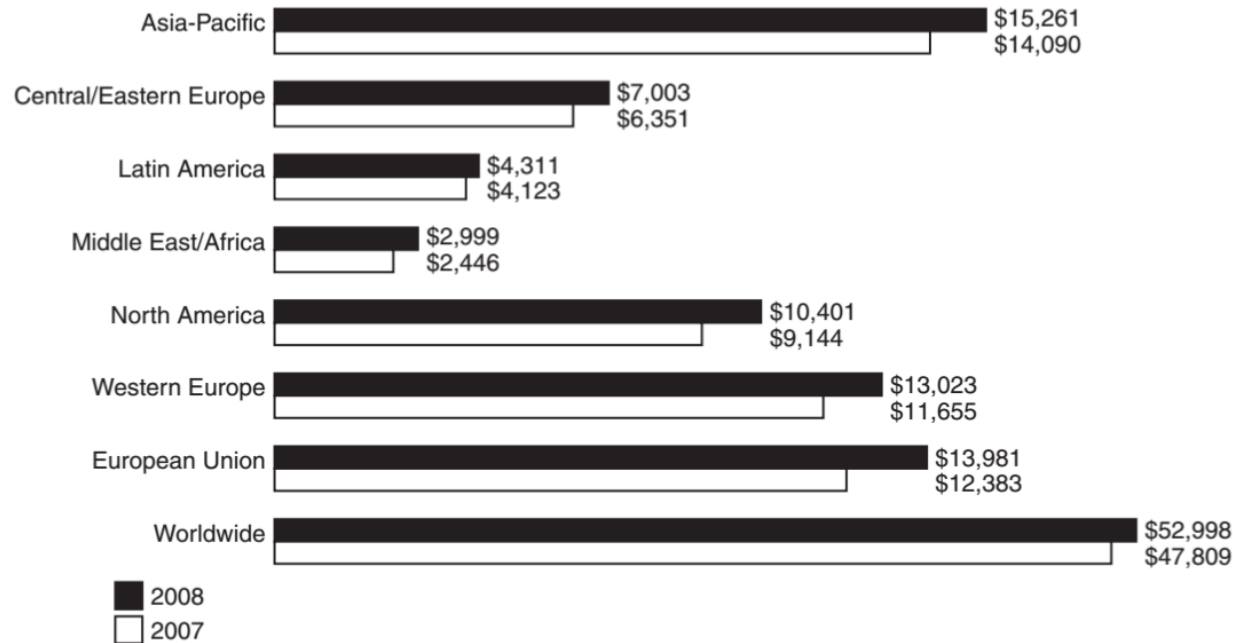


Figure 1.11 | Dollars lost (year 2008) due to (software) piracy – regional scenario.
Source: BSA-IDC Global 2008 Piracy Study released on May 2009 at the following link:
<http://global.bsa.org/globalpiracy2008/studies/globalpiracy2008.pdf> (29 January 2010).

4) Classifications of Cybercrimes

Software piracy (Cont...)

Regional scenario on piracy rate.

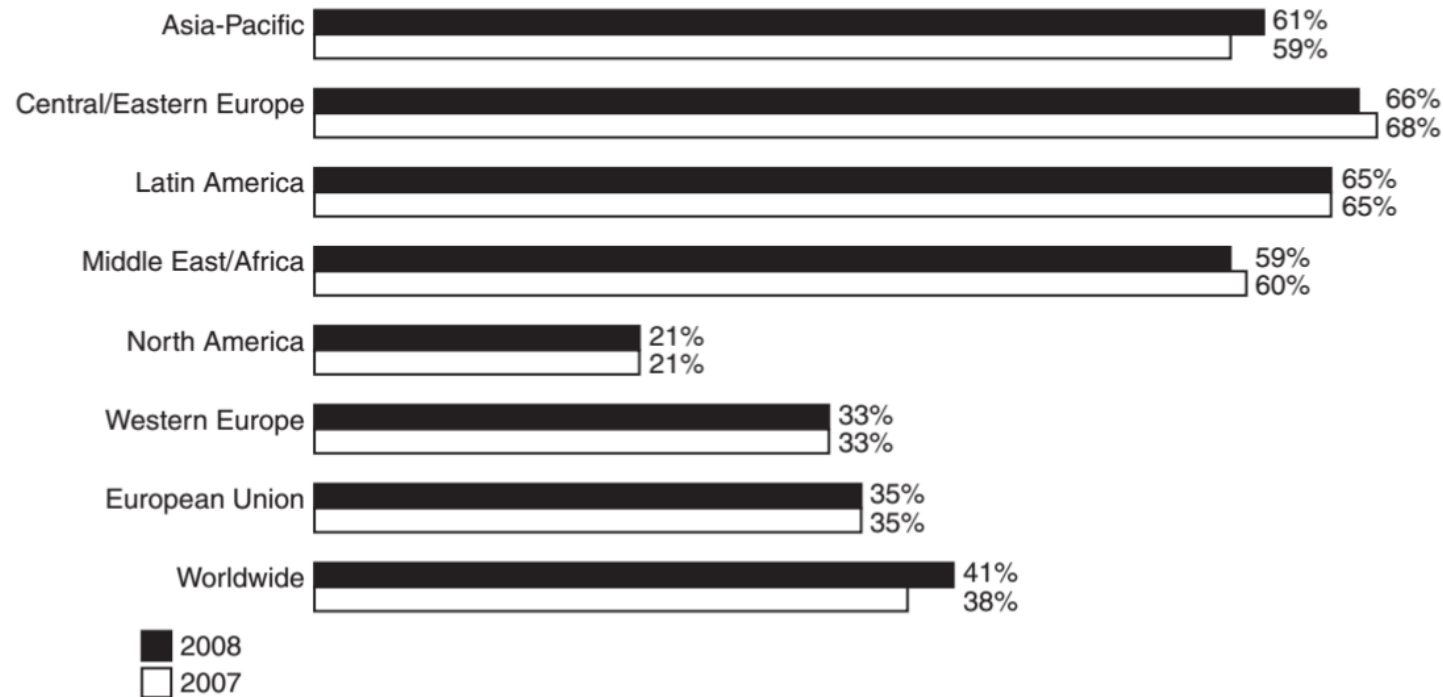


Figure 1.12 | Regional picture on piracy rate.

Source: BSA-IDC Global 2008 Piracy Study released on May 2009 at the following link:

4) Classifications of Cybercrimes

Computer sabotage

- The use of the Internet to hinder the normal functioning of a computer system through the introduction of worms, viruses or logical bombs. It can be used to gain economic advantage over a competitor, to promote the illegal activities of terrorists or to steal data or programs for extortion purposes.
- **Logic bombs** are event-dependent programs created to do something only when a certain event occurs.
- Some viruses may be termed as logic bombs because they lie dormant all through the year and become active only on a particular date(eg., Chernobyl virus and Y2K viruses).

4) Classifications of Cybercrimes

E-Mail Bombing/Mail Bombs

- E-Mail bombing refers to sending **a large number of E-Mails** to the victim to crash victim's E-Mail account (in the case of an individual) or to make victim's mail servers crash (in the case of a company or an E-Mail service provider).
- Computer program can be written to instruct a computer to do such tasks on a repeated basis.
- In recent times, terrorism has hit the Internet in the form of mail bombings. By instructing a computer to repeatedly send E-Mail to a specified person's E-Mail address, the cybercriminal can overwhelm the recipient's personal account and potentially shut down entire systems.
- This may or may not be illegal, but it is certainly disruptive.

4) Classifications of Cybercrimes

Usenet Newsgroup as the source of cybercrimes

- Usenet is a mechanism that allows sharing information in a many-to-many manner.
- In reality, however, there is no technical method available for controlling the contents of any newsgroup. It is merely subject to self-regulation and net etiquette. It is possible to put Usenet to following criminal use:
 1. Distribution/sale of pornographic material
 2. Distribution/sale of pirated software packages
 3. Distribution of hacking software
 4. Sale of stolen credit card numbers
 5. Sale of stolen data/stolen property

4) Classifications of Cybercrimes

Computer network intrusions

- **Crackers** who are often misnamed **Hackers** can break into computer systems from anywhere in the world and steal data, plant viruses, create backdoors, insert Trojan horses or change user names and passwords.
- **Network intrusions are illegal**, but detection and enforcement are difficult. Current laws are limited and many intrusions go undetected.
- The cracker can bypass existing password protection by creating a program to capture logon IDs and passwords.
- The practice of “strong password” is therefore important

4) Classifications of Cybercrimes

Password sniffing

- These are programs that monitor and record the name and password of network users as they login
- Whoever installs the Sniffer can then impersonate an authorized user and login to access restricted documents.
- Laws are not yet set up to adequately prosecute a person for impersonating another person online.
- Laws designed to prevent unauthorized access to information may be effective in apprehending crackers using Sniffer programs.

4) Classifications of Cybercrimes

Credit card frauds

- Bulletin boards and other online services are frequent targets for hackers who want to access large databases of credit card information.
- Such attacks usually result in the implementation of stronger security systems.
- credit card Security measures are improving, and traditional methods of law enforcement seem to be sufficient for prosecuting the thieves of such information.

4) Classifications of Cybercrimes

Identity theft

- This fraud involves another person's identity for an illicit purpose.
- Phishing and identity theft are related offenses.
- Examples include fraudulently obtaining credit, stealing money from the victim's bank accounts, using the victim's credit card number, establishing accounts with utility companies, renting an apartment or even filing bankruptcy using the victim's name.
- The **cyberimpersonator** can steal unlimited funds in the victim's name without the victim even knowing about it for months,

FUNDAMENTALS OF CYBER SECURITY

Cybercrime: Mobile and Wireless Devices

Dr. Ravi B , Dept of ISE

Cybercrime: Mobile and Wireless Devices

Topics

1. Introduction
2. Proliferation of Mobile and Wireless Devices
3. Credit Card Frauds in Mobile and Wireless Computing Era,
4. Authentication Service Security
5. Attacks on Mobile/Cell Phones
6. Organizational Measures for Handling Mobile

1) Introduction

- The rising importance of electronic gadgets bring many challenges to secure these devices from being a victim of cybercrime.
- In the recent years, the use of laptops, personal digital assistants (PDAs), and mobile phones has grown from limited user communities to widespread desktop replacement and broad deployment.
- The complexity of managing these devices outside the walls of the office is something that the information technology (IT) departments in the organizations need to address.
- Remote connection has extended from fixed location dial-in to wireless-on-the-move, and smart hand-held devices have become networked, converging with mobile phones.

2) Proliferation of Mobile and Wireless Devices

- Now A simple hand-held mobile device provides enough computing power to run small applications, play games and music, and make voice calls.
- A key driver for the growth of mobile technology is the rapid growth of business solutions into hand-held devices. Figure 3.1 shows some typical hand-held devices.



Figure 3.1 | Typical hand-held devices.
Source: Nina Godbole (2009), *Information Systems Security: Security Management, Metrics, Frameworks and Best Practices*, Wiley India.

2) Proliferation of Mobile and Wireless Devices

- We first provide a clear distinction among the key terms: **mobile computing, wireless computing and hand-held devices.**

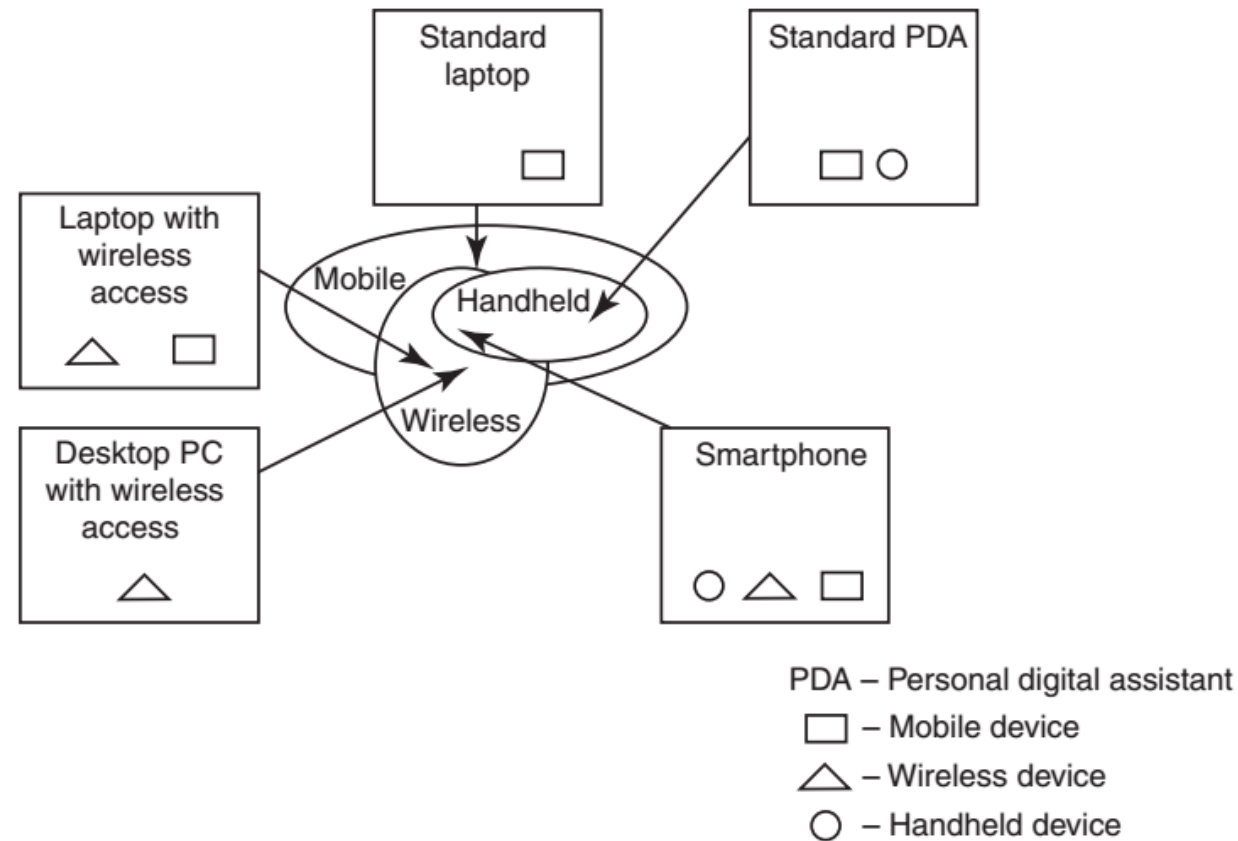


Figure 3.2 | Mobile, wireless and hand-held devices.

Source: Nina Godbole (2009), *Information Systems Security: Security Management, Metrics, Frameworks and Best Practices*, Wiley India.

2) Proliferation of Mobile and Wireless Devices

- ***Mobile computing:*** is taking a computer and all necessary files and software out into the field.
- ***Wireless:*** method of transferring information between a computing device(such as PDA) and data source(database server) without physical connection.
- ***Smart hand-held devices:*** hand held or pocket sized devices that connect to a wireless or a cellular network and can have a software installed on them.

2) Proliferation of Mobile and Wireless Devices

Many types of mobile computers have been introduced since 1990s.

- **Portable Computer:** general purpose computer that can be easily moved from one place to another, but cannot be used during transit because it may need some setting up or AC power supply.
- **Tablet PC:** It is shaped like a slate or paper notebook, lacks keyboard and has features of touch screen with stylus and handwriting recognition software.



2) Proliferation of Mobile and Wireless Devices

- **Internet tablet:** Internet appliance in tablet form. No much computing power and applications suite is limited. Eg: MP3 and video player, web browser, chat application, picture viewer.
- **Personal Digital Assistant(PDA):** Small, pocket sized computer with limited functionality. It is intended to supplement and synchronise with desktop computer giving access to contacts, address book, notes, email and other features



2) Proliferation of Mobile and Wireless Devices

- **Ultramobile PC:** Full featured PDA sized computer running a general purpose OS.



- **Smartphone:** PDA with an integral cell phone functionality, wide range of features and installable applications.

2) Proliferation of Mobile and Wireless Devices

- **Carputer** :Computing device installed in an automobile. It operates as a wireless computer, sound system, global positioning system, DVD player. Also has word processing software and is Bluetooth compatible.



2) Proliferation of Mobile and Wireless Devices

- **Fly Fusion Pentop computer:** computing device with size and shape of a pen. It functions as writing pen, MP3 player, language translator, digital storage device and calculator.



3) Credit Card Frauds in Mobile and Wireless Computing Era

- Credit card frauds are now becoming commonplace given the ever-increasing power and the ever-reducing prices of the mobile handheld devices, factors that result in easy availability of these gadgets to almost anyone.
- Mobile credit card transactions are now very common; new technologies combine low-cost mobile phone technologies with the capabilities of a point-of-sale (POS) terminal.

3) Credit Card Frauds in Mobile and Wireless Computing Era

- Anywhere anytime computing and the developments in wireless technology have fuelled this new mode of working for white collar workers.
- Wireless credit card processing is a relatively new service that will allow a person to process credit cards electronically, virtually anywhere. Wireless credit **card processing is a very desirable system**, because it allows businesses to process transactions from mobile locations quickly, efficiently and professionally.

3) Credit Card Frauds in Mobile and Wireless Computing Era

- Figure 3.4 shows the basic flow of transactions involved in purchases done using credit cards.

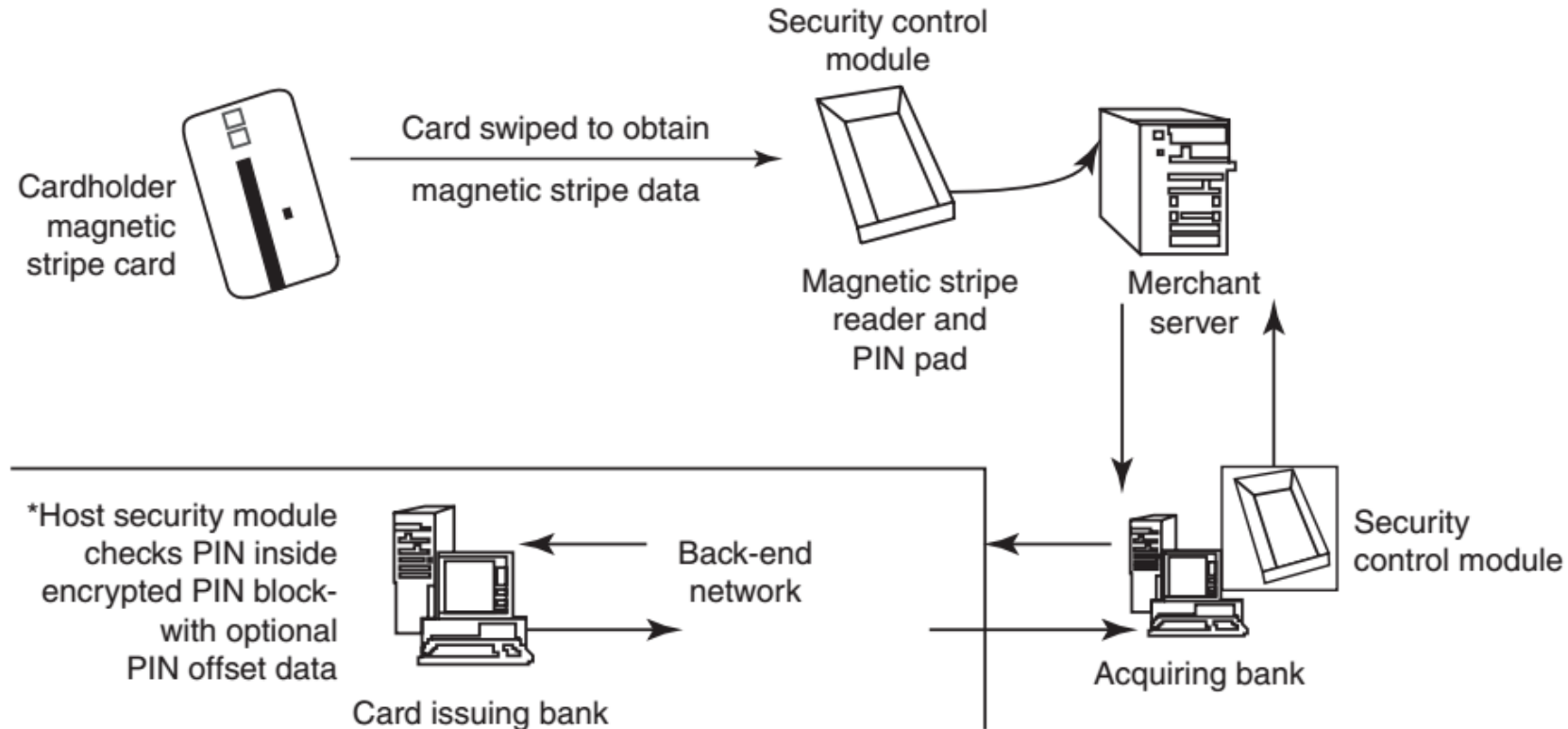


Figure 3.4 | Online environment for credit card transactions.

Source: Nina Godbole (2009), *Information Systems Security: Security Management, Metrics, Frameworks and Best Practices*, Wiley India.

3) Credit Card Frauds in Mobile and Wireless Computing Era

Tips to prevent credit card frauds

Do's

- Put your signature on the card immediately upon its receipt.
- Make photocopy of both the sides of your card and preserve it at a safe place to remember the card number, expiration date in case of loss of card.
- Change the default pin received from bank before doing any transaction
- Always carry the details about contact numbers of your bank in case of loss of your card.
- Carry your cards in a separate pouch or card holder than your wallet.
- Keep an eye on your card during the transaction and ensure to get it back immediately
- Preserve all the receipts to compare with the credit card invoice.

3) Credit Card Frauds in Mobile and Wireless Computing Era

Tips to prevent credit card frauds (Cont...)

Do's

- Reconcile your monthly invoice/statement with your receipts
- Report immediately if any discrepancy observed in monthly invoice/statement
- Discard all the receipts after reconciling it with the monthly invoice statements
- Inform your bank in advance, about any changes in your contact details such as home address, cell phone number, email.
- Ensure Legitimacy of the website before providing any of your card details.
- Report the loss of card immediately in your bank and at the police station ,if necessary

3) Credit Card Frauds in Mobile and Wireless Computing Era

Tips to prevent credit card frauds (Cont...)

Dont's

- Store your card number and pin in your cell
- Lend your cards to anyone
- Leave cards or transaction receipt lying around
- Sign a blank receipt
- Write your card number/PIN on a postcard or outside of any envelope
- Give out immediately your account number over the phone
- Destroy credit card receipts by simply dropping into garbage/dustbin

3) Credit Card Frauds in Mobile and Wireless Computing Era

Closed Loop Environment for Wireless(CLEW)

- There is a system available from an Australian company “Alacrity” called **closed-loop environment for wireless (CLEW)**. Figure 3.5 shows the flow of events with CLEW

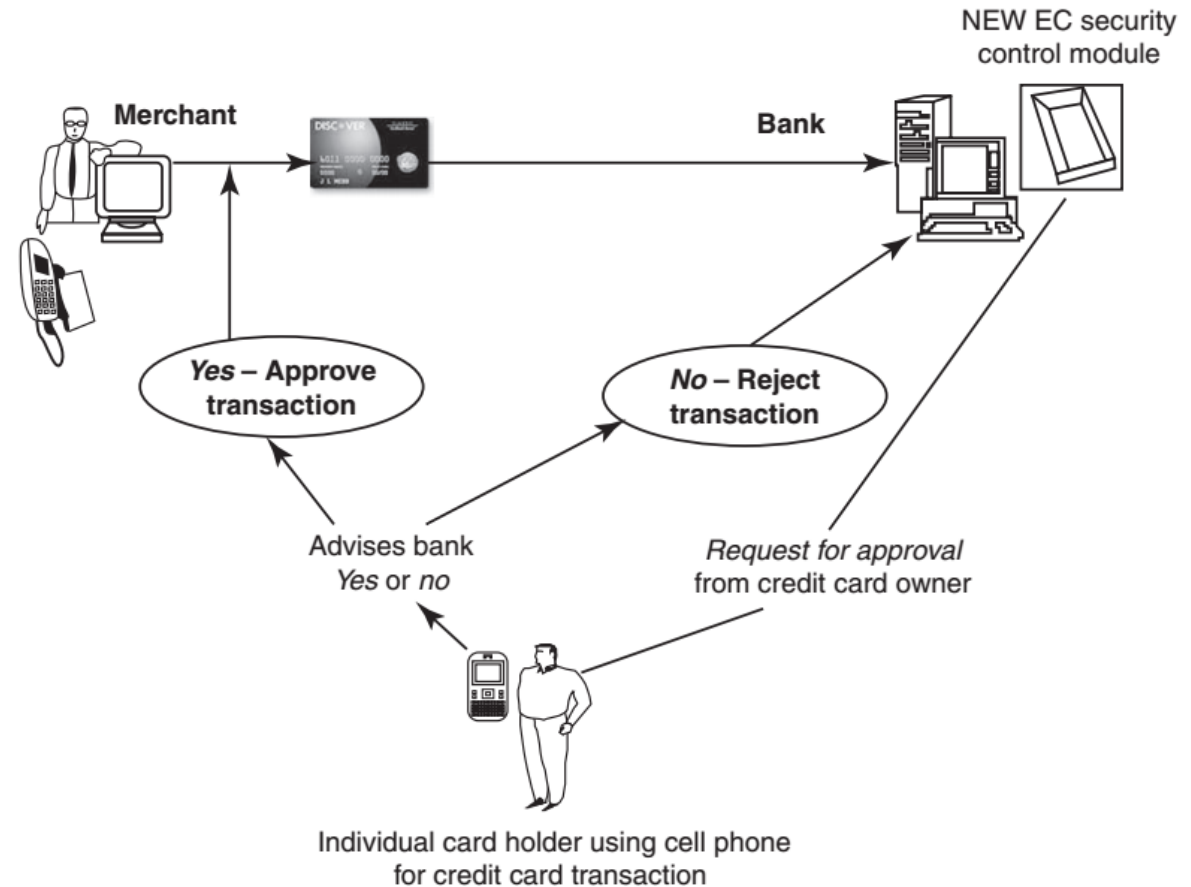


Figure 3.5 Closed-loop environment for wireless (CLEW).
Source: Nina Godbole (2009), *Information Systems Security: Security Management, Metrics, Frameworks and Best Practices*, Wiley India.

3) Credit Card Frauds in Mobile and Wireless Computing Era

Closed Loop Environment for Wireless(CLEW) (Cont...)

As shown in Figure 3.5, the basic flow is as follows:

1. Merchant sends a transaction to bank;
2. The bank transmits the request to the authorized cardholder [not short message service (SMS)];
3. The cardholder approves or rejects (password protected);
4. The bank/merchant is notified;
5. The credit card transaction is completed.

3) Credit Card Frauds in Mobile and Wireless Computing Era

Types and techniques of Credit Card Frauds

1. Traditional techniques

- The traditional and the first type of credit card fraud is paper-based fraud- ***application fraud***, wherein a criminal uses stolen or fake documents such as utility bills and bank statements that can build up useful personally Identifiable Information to open an account in someone else's name.

Application fraud can be divided into

1. **ID theft:** Where an individual pretends to be someone else.
 2. **Financial fraud:** Where an individual gives false information about his or her financial status to acquire credit.
- Illegal use of lost and stolen cards is another form of traditional technique. Stealing a credit card is either by pickpocket or from postal service before it reaches its final destination.

3) Credit Card Frauds in Mobile and Wireless Computing Era

Types and techniques of Credit Card Frauds

2. Modern Techniques

- Sophisticated techniques enable criminals to produce fake and doctored cards. Then there are also those who use skimming to commit fraud.
- Skimming is where the information held on either the magnetic strip on the back of the credit card or the data stored on the smart chip are copied from one card to another. Site cloning and false merchant sites on the Internet are becoming a popular method of fraud and to direct the users to such bogus/fake sites is called Phishing.

3) Credit Card Frauds in Mobile and Wireless Computing Era

Types and techniques of Credit Card Frauds

2. Modern Techniques (Cont...)

1. Triangulation:

- The criminal offers the goods with heavy discounted rates through a website designed and hosted by him, which appears to be legitimate merchandise website.
- The customer registers on this website with his/her name, address, shipping address and valid credit card details.
- The criminal orders the goods from a legitimate website with the help of stolen credit card details and supply shipping address that have been provided by the customer while registering on the criminal's website.
- The goods are shipped to the customer and the transaction gets completed.
- The criminal keeps on purchasing other goods using fraudulent credit card details of different customers till the criminal closes existing website and starts a new one.

3) Credit Card Frauds in Mobile and Wireless Computing Era

Types and techniques of Credit Card Frauds

2. Modern Techniques (Cont...)

1. Triangulation:

- The entire investigation process for tracking and reaching these criminals is time-consuming, and the criminals may close such fake website in between the process that may cause further difficulty to trace the criminal.
- The criminals aim to create a great deal of confusion for the authorities so that they can operate long enough to accumulate a vast amount of goods purchased through such fraudulent transactions.

3) Credit Card Frauds in Mobile and Wireless Computing Era

Types and techniques of Credit Card Frauds

2. Modern Techniques (Cont...)

2. Credit card generators:

2. It is another modern technique- computer emulation software – that creates valid credit card numbers and expiry dates.
3. The criminals highly rely on these generators to create valid credit cards. These are available for free download on the Internet.

5) Attacks on Mobile /Cell phones

1. Mobile Phone Theft
2. Mobile viruses
3. Mishing
4. Vishing
5. Smishing
6. Hacking Bluetooth

5) Attacks on Mobile /Cell phones

Mobile Phone Theft

- Increase in the purchasing power and availability of numerous low cost handsets have also lead to an increase in mobile phone users.
- Theft of mobile phones have risen dramatically over the years. Theft occurs mainly at **bus stops, buses, railway stations, trains, traffic signals** etc
- Many Insurance companies have stopped offering Mobile Theft insurance due to false claims.
- “**Contact List**” and “**Personally Identifiable Information (PII)**” that really matter, when phones are lost.

5) Attacks on Mobile /Cell phones

Mobile Phone Theft (Cont...)

- After PC, the criminals' new playground has been cell phones, reason being the increasing usage of cell phones and availability of Internet.
- Another reason is increasing demand for Wi-Fi zones in the metropolitans and extensive usage of cell phones in the youths with lack of awareness about the vulnerabilities of the technology.
- The following factors contribute for outbreaks on mobile devices:
 1. **Enough target terminals:** The first **Palm OS virus** was seen after the number of Palm OS devices reached 15 million. The first instance of a mobile virus was observed during **June 2004 when** it was discovered that an organization "Ojam" had engineered an **antipiracy Trojan virus** in older versions of their mobile phone game known as **Mosquito**. This virus sent SMS text messages to the organization without the users' knowledge.

5) Attacks on Mobile /Cell phones

Mobile Phone Theft (Cont...)

- The following factors contribute for outbreaks on mobile devices:
 - 2. Enough functionality:** Mobile devices are increasingly being equipped with office functionality and already carry critical data and applications, which are often protected insufficiently or not at all. The expanded functionality also increases the probability of malware.
 - 3. Enough connectivity:** Smartphones offer multiple communication options, such as SMS, MMS, synchronization, Bluetooth, infrared (IR) and WLAN connections. Therefore, unfortunately, the increased amount of freedom also offers more choices for virus writers.

5) Attacks on Mobile /Cell phones

Mobile Phone Theft (Cont...)

Tips to secure your cell/mobile phone from being stolen/lost

- Ensure to note the following details about your cell phone and preserve it in a safe place:
 1. Your phone number;
 2. The make and model;
 3. Color and appearance details;
 4. PIN and/or security lock code;
 5. IMEI number.
- The International Mobile Equipment Identity (IMEI) :
 - It is a number unique cell phone. It is a 15-digit number and can be obtained by entering ***#06#** from the keypad.
 - The IMEI number is used by the GSM network to identify valid devices and therefore can be used to stop a stolen phone from accessing the network in that country.

5) Attacks on Mobile /Cell phones

Mobile Phone Theft (Cont...)

Tips to secure your cell/mobile phone from being stolen/lost

- For example, if a mobile phone is stolen, the owner can call his or her service provider and instruct **them to “lock” the phone using its IMEI number.**
- This will help to stop the usage of phone in that country, even if a SIM is changed.
- Visit the weblink <http://www.numberingplans.com/?page=analysis&sub=imeinr> to check all information about your cell phone such as manufacturer, model type and country of approval of a handset.

5) Attacks on Mobile /Cell phones

Mobile Phone Theft (Cont...)

Tips to secure your cell/mobile phone from being stolen/lost

- Remember the following

1. **Add a security mark on your cell phone.** Use permanent marker and print your alternate contact number and short address on your cell phone instrument as well as on battery. In case someone finds your handset, it is easier to contact you if the finder of your cell phone would like to return it you.
2. **Set a password** and ensure the password is strong enough so that a finder of your cell phone cannot easily guess it.
3. In case of loss of your cell phone, **register a complaint with cell phone service provider** immediately, **using your IMEI number**, to enable your service provider to block your cell phone and your account details. Preserve all the details of launched complaints, that is, obtain confirmation in writing from your service provider that your phone has been disabled.

5) Attacks on Mobile /Cell phones

Mobile Phone Theft (Cont...)

Tips to secure your cell/mobile phone from being stolen/lost

4. In case of loss of your cell phone, **register a complaint at the police station** and obtain FIR. Preserve all the details for launched complaints, that is, FIR report.
5. **Keep an eye on your phone** while traveling. During the security check at the airport security, ensure to retrieve your cell phone immediately once it enters the x-ray machine – criminals often steal phones during these vulnerable seconds.
6. **Keep Wi-Fi and Bluetooth OFF** when it is not required to be in use. Airports, coffee shops, hotels and all other public places wherever free Wi-Fi zone is available, criminals always have an eye to seek the vulnerability to steal information.
7. **Periodic backup is important and especially if you are traveling**, backup before traveling is necessary. It takes only few minutes to take backup but it is always helpful in case you lose your cell phone during traveling.

5) Attacks on Mobile /Cell phones

Mobile Phone Theft (Cont...)

Tips to secure your cell/mobile phone from being stolen/lost

8. **Do not forget to apply all the updates** for cell phone software/firmware, received from manufacturers, which are routinely provided to update vulnerabilities fixes.
9. **Only download applications from reputable sources** – specific care should be taken while downloading plug-in applications on the cell phone. It is always advised to use the recommendations provided by cell phone manufacturers' to download directly from the Web.

5) Attacks on Mobile /Cell phones

Mobile Phone Theft (Cont...)

Tips to secure your cell/mobile phone from being stolen/lost

Install antitheft software on your cell phone

- Antitheft software does not allow the criminal to use another SIM card in the stolen cell phone. When a SIM card is changed, the system asks for a verification code.
- Even if the criminal manages to break this code, the phone sends out a message regarding the change of SIM to two selected contacts from the cell phone contact directory with the new SIM number.
- So, it becomes easy to trace the address of the new cell phone number from the service provider and thus to trace the cell.
- Only the owners of the cell phone will know about the installed antitheft software, as it does not show any icons on the menu

Antitheft software on your cell phone: GadgetTrak, Back2u, Wavesecure, F-Secure

5) Attacks on Mobile /Cell phones

Mobile Viruses

- Similar to computer virus that targets mobile phone data or applications installed in it.
- In total, 40 mobile virus families and more than 300(+) mobile viruses have been identified.
- Mobile virus spreads through Bluetooth and MMS.
- Bluetooth virus can easily spread within a distance of 10-30m.
- MMS virus can send a copy of itself to the contact list of victim's phone.
- Mobile phone virus hoaxes have been circulating since 1999. Hoax messages either will be sent through E-Mail or through SMS to the mobile users.

5) Attacks on Mobile /Cell phones

Mobile Viruses (Cont...)

- **The example of such hoax is given.**
- *“All mobile users pay attention!!!!!!! If you receive a phone call and your mobile phone displays (XALAN) on the screen don’t answer the call, END THE CALL IMMEDIATELY, if you answer the call, your phone will be infected by a virus. Th is virus WILL ERASE all IMEI and IMSI information from both your phone and your SIM card, which will make your phone unable to connect with the telephone network. You will have to buy a new phone. This information has been confirmed by both Motorola and Nokia. There are over 3 Million mobile phones being infected by this virus in all around the world now. You can also check this news in the CNN website.*

PLEASE FORWARD THIS PIECE OF INFORMATION TO ALL YOUR FRIENDS HAVING A MOBILE PHONE.”

5) Attacks on Mobile /Cell phones

Mobile Viruses (Cont...)

- **How to protect from Mobile Malware Attacks?**

1. Download or accept programs and content(including ring tones, games, video clips and photos) only from a trusted source.
2. If a mobile is equipped with Bluetooth, turn it OFF or set it to non-discoverable mode when it is not in use and/or not required to use.
3. If a mobile is equipped with beam(i.e., IR), allow it to receive incoming beams, only from the trusted source.
4. Download and install antivirus software for mobile devices.

5) Attacks on Mobile /Cell phones

Mobile Viruses (Cont...)

Cabir.A

- First reported: June 2004
- Attacks: Symbian Series 60 phones
- Spreads via: Bluetooth
- Harm: none

Skulls.A

First reported: November 2004

Attacks: various Symbian phones

Spreads via: Internet download

Harm: disables all phone functions except sending/receiving calls

5) Attacks on Mobile /Cell phones

Mobile Viruses (Cont...)

- **Commwarrior.A**
 - First reported: January 2005
 - Attacks: Symbian Series 60 phones
 - Spreads via: Bluetooth and MMS
 - Harm: sends out expensive MMS messages to everyone in phonebook (in course of MMS replication)
- **Locknut.B**
 - First reported: March 2005
 - Attacks: Symbian Series 60 phones
 - Spreads via: Internet download (disguised as patch for Symbian Series 60 phones)
 - Harm: crashes system ROM; disables all phone functions; inserts other (inactive) malware into phone

5) Attacks on Mobile /Cell phones

Mishing

- **Mishing** Is a combination of mobile phone and phishing.
- If you use your mobile phone for purchasing goods/services and for banking, you could be more vulnerable to a mishing scam.
- A typical mishing attacker uses call termed as **vishing** or message known as **smishing**.
- Attacker will pretend to be an employee from your bank or another organization and will claim a need for your personal details.
- Attackers are very creative and they would try to convince you with different reasons why they need this information from you.

5) Attacks on Mobile /Cell phones

Vishing

- It is the criminal practice of using **social engineering over the telephone system**, most often using features facilitated by VoIP, to gain access to personal and financial information from the public for the purpose of **financial reward**. The term is a combination of **V- voice and Phishing**.
- The most profitable uses of the information gained through a Vishing attack include:
 - **ID theft;**
 - **Purchasing luxury goods and services;**
 - **Transferring money/funds**
 - **Monitoring the victim's bank accounts;**
 - **Making applications for loans and credit cards.**

5) Attacks on Mobile /Cell phones

How Vishing works (Cont...)

- The criminal can initiate a Vishing attack using a variety of methods, each of which depends upon information gathered by a criminal and criminal's will to reach a particular audience.
 - 1.**Internet E-Mail:** It is also called Phishing mail.
 - 2.**Mobile text** messaging
 - 3.**Voicemail:** Here, victim is forced to call on the provided phone number, once he/she listens to voicemail.

5) Attacks on Mobile /Cell phones

Vishing - How Vishing works (Cont...)

4.Direct phone call: Following are the steps detailing on how direct phone call works:

- The criminal gathers cell/mobile phone numbers located in a particular region and/or steals cell/mobile phone numbers after accessing legitimate voice messaging company.
- The criminal often uses a **war dialer to call phone numbers** of people from a specific region, and that to from the gathered list of phone numbers.
- When the victim answers the call, an automated recorded message is played to alert the victim that his/her credit card has had fraudulent activity and/or his/her bank account has had unusual activity. The message instructs the victim to call one phone number immediately. The same phone number is often displayed in the **spoofed caller ID**, under the name of the financial company the criminal is pretending to represent.

5) Attacks on Mobile /Cell phones

Vishing - How Vishing works (Cont...)

4.Direct phone call:

- When the victim calls on the provided number, he/she is given automated instructions to enter his/her credit card number or bank account details with the help of phone keypad.
- Once the victim enters these details, the criminal(i.e., visher) has the necessary information to make fraudulent use of the card or to access the account.
- Such calls are often used to harvest additional details such as date of birth, credit card expiration date, etc.

5) Attacks on Mobile /Cell phones

Vishing – Examples (Cont...)

When victim calls on the provided number after receiving phished E-Mail and/or after listening voicemail, are as follows:

1. **Automated message:** Thank you for calling (name of local bank). Your business is important to us. To help you reach the correct representative and answer your query fully, please press the appropriate number on your handset after listening to options.
 - Press 1 if you need to check your banking details and live balance.
 - Press 2 if you wish to transfer funds.
 - Press 3 to unlock your online profile.
 - Press 0 for any other query.

5) Attacks on Mobile /Cell phones

Vishing – Examples (Cont...)

2. Regardless of what the victim enters (i.e., presses the key), the automated system prompts him to authenticate himself: “The security of each customer is important to us. To proceed further, we require that you authenticate your ID before proceeding. Please type your bank account number, followed by the pound key.”

3. The victim enters his/her bank account number and hears the next prompt: “Thank you. Now please type your date of birth, followed by the pound key. For example 01 January 1950 press 01011950.”

4. The caller enters his/her date of birth and again receives a prompt from the automated system: “Thank you. Now please type your PIN, followed by the pound key.”

5) Attacks on Mobile /Cell phones

Vishing – Examples (Cont...)

5. The caller enters his PIN and hears one last prompt from the system:
“Thank you. We will now transfer you to the appropriate representative.”

At this stage, the phone call gets disconnected, and the victim thinks there was something wrong with the telephone line; or visher may redirect the victim to the real customer service line, and the victim will not be able to know at all that his authentication was appropriated by the visher.

5) Attacks on Mobile /Cell phones

Vishing - How to protect? (Cont...)

Following are some tips to protect oneself from Vishing attacks:

- **Be suspicious** about all unknown callers.
- **Do not trust caller ID.** It does not guarantee whether the call is really coming from that number, that is, from the individual and/or **company-caller ID spoofing is easy.**
- **Be aware and ask questions,** in case someone is asking for your personal or financial information.
- **Call them back.** If someone is asking you for your personal or financial information, tell them that you will call them back immediately to verify if the company is legitimate or not. In case someone is calling from a bank and/or credit card company, call them back using a number displayed on invoice and/or displayed on website.

5) Attacks on Mobile /Cell phones

Vishing - How to protect? (Cont...)

- **Following are some tips to protect oneself from Vishing attacks (cont...)**
 - **Report incidents:** Report Vishing calls to the nearest cyberpolice cell with the number and name that appeared on the caller ID as well as the time of day and the information talked about or heard in a recorded message.

5) Attacks on Mobile /Cell phones

Smishing

- **It is a criminal offense conducted by using social engineering techniques similar to Phishing.** The name is derived from “SMS PhISHING”.
- Smishing uses cell phone text messages to deliver a lure message to get the victim to reveal his/her PI.
- The popular technique to hook the victim is either provide a **phone number to force the victim to call** or **provide a website URL to force the victim to access the URL**, wherein, the victim gets connected with bogus website and submits his/her PI.
- Smishing works in the similar pattern as Vishing.

5) Attacks on Mobile /Cell phones

Smishing (Cont...)

- A few examples of Smishing are provided herewith to demonstrate how the victim is forced to disclose PI.
- “We are happy to send our confirmation toward your enrolment for our club membership. You will be charged Rs.50 per day, unless you reconfirm your acceptance of your membership on our membership contact number.
- “Name of popular online bank is confirming that you have purchased LCD TV set, worth Rs.90000 only from name of popular computer company. Visit **www.abcdef.com** if you did not make this online purchase.

5) Attacks on Mobile /Cell phones

Smishing -How to protect ? (Cont...)

Following are some tips to protect oneself from Smishing Attacks:

- Do not answer a text message that you have received asking for your PI. Even if the message seems to be received from your best friend, do not respond, because he/she may not be the one who has actually sent it.
- Avoid calling any phone numbers, as mentioned in the received message, to cancel a membership and/or confirming a transaction which you have not initiated but mentioned in the message. Always call on the numbers displayed on the invoice and/or appearing in the bank statements/passbook.

5) Attacks on Mobile /Cell phones

Smishing -How to protect ? (Cont...)

- Never click on a hot link received through message on your Smartphone or PDA. Hot links are links that you can click, which will take you directly to the Internet sites.
- Smishing messages may have hot links, wherein you click on the link and download Spyware to your phone without knowing. Once this software has been downloaded, criminals can easily steal any information that is available on your cell phone and have access to everything that you do on your cell phone.

5) Attacks on Mobile /Cell phones

Hacking Bluetooth

- When Bluetooth is enabled on a device, it essentially broadcasts that its available to any other Bluetooth-based device within a range. This makes easier for attackers to identify the target.
- The attacker installs special software on a laptop and then installs a Bluetooth antenna.

5) Attacks on Mobile /Cell phones

Hacking Bluetooth (Cont...)

- Whenever an attacker moves around public places, the software installed on laptop constantly scans the nearby surroundings of the hacker for active Bluetooth connections.
- Once the software tool used by the attacker finds and connects to a vulnerable Bluetooth enabled cell phone, it can do things like download address book information, photos, calendars, SIM card details, make long distance phone calls using the hacked device.

5) Attacks on Mobile /Cell phones

Hacking Bluetooth (Cont...)

Hacking Bluetooth Tools (Cont...)

1. **BlueScanner**-This tool enables to search for Bluetooth enable device and will try to extract as much information as possible for each newly discovered device after connecting with the target.
2. **BlueSniff**- This is a GUI-based utility **for finding discoverable and hidden Bluetooth enabled devices.**
3. **BlueBugger**-The buggers exploit the vulnerability of the device and access the images, phonebook, messages and other personal information.

5) Attacks on Mobile /Cell phones

Hacking Bluetooth (Cont...)

Hacking Bluetooth Tools (Cont...)

4. **Bluesnarfer**- If a Bluetooth of a device is switched ON, then Bluesnarfing makes it possible to connect to the phone without alerting the owner and to gain access to restricted portions of the stored data.
5. **BlueDiving**- BlueDiving is testing Bluetooth penetration. It implements attacks like Bluebug and BlueSnarf.

5) Attacks on Mobile /Cell phones

Hacking Bluetooth (Cont...)

Common attacks that have emerged as Bluetooth-specific security issues:

1. Bluejacking-

- Bluetooth+Jacking where jacking is a short name for hijack - act of taking over something. If the user does not recognize/realize what the message is, he/she might allow the contact to be added to her/his address book, and the contact can send him messages that might be automatically opened because they are coming from a known contact.
- Bluejacking is harmless, as bluejacked users generally do not understand what has happened and hence they may think that their phone is malfunctioning.

5) Attacks on Mobile /Cell phones

Hacking Bluetooth (Cont...)

Common attacks that have emerged as Bluetooth-specific security issues:

1. Bluejacking- Example:



5) Attacks on Mobile /Cell phones

Hacking Bluetooth (Cont...)

Common attacks that have emerged as Bluetooth-specific security issues:

2. Bluesnarfing-

- It is the unauthorized access from a wireless device through a Bluetooth connection between cell phones, PDAs and computers.
- This enables the attacker to access a calendar, contact list, SMS and E-Mails as well as enable attackers to copy pictures and private videos.

5) Attacks on Mobile /Cell phones

Hacking Bluetooth (Cont...)

Common attacks that have emerged as Bluetooth-specific security issues:

3. Bluebugging-

- It allows attackers to remotely access a user's phone and use its features without user's attention.
- During initial days, the attacker could simply listen to any conversation his/her victim is having;
- However, further developments in Bluebugging tools have enabled the attacker with the ability to take control of the victim's phone and to conduct many more activities such as initiate phone calls; send and read SMS; read and write phonebook contacts; eavesdrop on phone conversations and connect to the Internet.

5) Attacks on Mobile /Cell phones

Hacking Bluetooth (Cont...)

Common attacks that have emerged as Bluetooth-specific security issues:

4. Car Whisperer-

- It is a piece of software that allows attackers to send audio to and receive audio from a Bluetooth-enabled car stereo.
- Further research is underway to know whether Bluetooth attackers could do anything more serious such as disabling airbags or brakes through this kind of attack.
- The researchers are also investigating about possibility of an attacker accessing a telephone address book once the connection gets established with the Bluetooth system through this kind of attack. Among the four above-mentioned attacks, Bluesnarfing is claimed to be much more serious than Bluejacking.

6) Organizational Measures for Handling Mobile Devices-Related Security Issues

- In this section, we discuss what organizations can do toward safeguarding their information systems in the mobile computing paradigm.
 - **Encrypting organizational databases.**
 - **Including mobile devices in security strategy**

6) Organizational Measures for Handling Mobile Devices-Related Security Issues

Encrypting organizational databases (Cont..)

- To protect the organizations' data loss, such databases need encryption
- We mention here two algorithms that are typically used to implement strong encryption of database files:
 1. **Rijndael (pronounced rain-dahl or Rhine-doll)**, a block encryption algorithm, chosen as the new Advanced Encryption Standard (AES) for block ciphers by the National Institute of Standards and Technology (NIST).
 2. The other algorithm used to implement strong encryption of database files is the **Multi-Dimensional Space Rotation (MDSR)** algorithm developed by Casio.

6) Organizational Measures for Handling Mobile Devices-Related Security Issues

- Database file encryption technology, using either the AES or the MDSR algorithms, makes the database file inoperable without the key.

6) Organizational Measures for Handling Mobile Devices-Related Security Issues

Encrypting organizational databases. (Cont...)

- When using strong encryption, it is important not to store the key on the mobile device.
- The key is required whenever you want to start the database or you want to use a utility on your database.
- For greater security there is an option available that instructs the database server to display a dialog box where the user can enter the encryption key.
- This option is necessary because the encryption key should not be entered on the machine in clear text.

6) Organizational Measures for Handling Mobile Devices-Related Security Issues

Encrypting organizational databases (Cont...).

- To protect the scenario of information attack/stealing through the mobile devices connecting to corporate databases, additional security measures are possible through enforcing a self-destruct policy that is controlled from the server.
- When a device that is identified as lost or stolen connects to the organization server, IT department can have the server send a package to destroy privileged data on the device.

6) Organizational Measures for Handling Mobile Devices-Related Security Issues

Mobile device security strategy in companies

- Encryption of corporate databases is not the end of everything.
- However, enterprises that do not want to include mobile devices in their environments often use security as an excuse, saying they fear the loss of sensitive data that could result from a **PDA being stolen or an unsecured wireless connection being used**.
- There are technologies available to properly secure mobile devices. These should be good enough for most organizations.
- Corporate IT departments just need to do their homework.

6) Organizational Measures for Handling Mobile Devices-Related Security Issues

Mobile device security strategy in companies (Cont...)

- **For example**, there are ways to make devices lock or destroy the lost data by sending the machine a special message.
- Also, some mobile devices have high-powered processors that will support 128-bit encryption.
- Although mobile devices do pose unique challenges from a cybersecurity perspective, there are some general steps that the users can take to address them, such as integrating security programs for mobile and wireless systems into the overall security blueprint.

6) Organizational Measures for Handling Mobile Devices-Related Security Issues

Mobile device security strategy in companies (Cont...)

A few things that enterprises can use are:

1. Implement strong asset management, virus checking, loss prevention and other controls for mobile systems that will prohibit unauthorized access and the entry of corrupted data.
2. Investigate alternatives that allow a secure access to the company information through a firewall such as mobile VPN.
3. Develop a system of more frequent and thorough security audits for mobile devices

6) Organizational Measures for Handling Mobile Devices-Related Security Issues

Mobile device security strategy in companies (Cont...)

A few things that enterprises can use are (cont..)

4. Incorporate security awareness into your mobile training and support programs so that everyone understands just how an issue security is within a company's overall IT strategy
5. Notify then appropriate law-enforcement agency and change passwords. User accounts are closely monitored for any unusual activity for a period of time.

Fundamentals of Cybersecurity

2. Cyberoffenses: How criminals Plan them

Dr. Ravi B , Dept of ISE

Cyberoffenses: How criminals Plan them

Topics

1. Introduction
2. How Criminals Plan the Attacks
3. Social Engineering
4. Cyberstalking
5. Cybercafe and Cybercrimes
6. Botnets: The Fuel for Cybercrime

1) Introduction

- Technology is a “**double-edged sword**”
- Computers and tools available in IT are also no exceptions; can be used as either target of offense or means for committing an offense.
- A criminal activity can be carried out across national borders with “false sense of anonymity”;
- Without realizing, we seem to pass on tremendous amount of information about ourselves
- The criminals take advantage of the widespread **lack of awareness about cybercrimes and cyberlaws among the people** who are constantly using the IT infrastructure for official and personal purposes.

1) Introduction

- Figure 2.1 gives us an idea about all those agencies that collect information about the individuals (i.e., Personally Identifiable Information such as date of birth, personal E-Mail address, bank account details and/or credit card details)

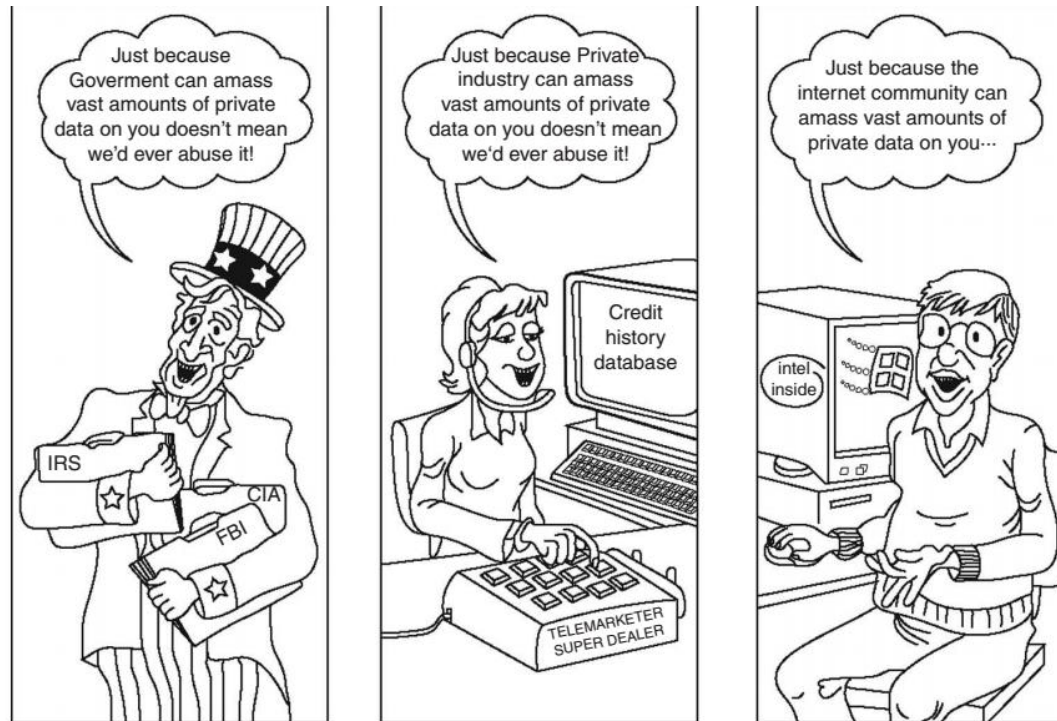


Figure 2.1 | We all vouch for keeping your personal information secret!
Source: Nina Godbole (2009), *Information Systems Security: Security Management, Metrics, Frameworks and Best Practices* (Fig. 29.14), Wiley India.

1) Introduction

Basic terminologies :

- **Hacker:** A hacker is a person with a strong interest in computers who enjoys learning and experimenting with them. Hackers are usually very talented, smart people who understand computers better than others.
- **Brute force hacking:** It is a technique used to find passwords or encryption keys. It involves trying every possible combination of letters, numbers, etc., until the code is broken.
- **Cracker:** A person who breaks into computers. The term “cracker” is usually connected to computer criminals. Some of their crimes include vandalism, theft and snooping in unauthorized areas. The term “cracker” is usually connected to computer criminals.

1) Introduction

Basic terminologies (Cont...)

- **Cracker tools:** These are programs used to break into computers. **It** includes password crackers, Trojans, viruses, war dialers and worms.
- **Phreaking:** This is the notorious art of breaking into phone or other communication systems.
- **War dialer:** It is program that automatically dials phone numbers looking for computers on the other end. It catalogs numbers so that the hackers can call back and try to break in.

1) Introduction

The categories of vulnerabilities that hackers typically search for are the following:

1. Inadequate border protection;
2. Remote access servers(RASs) with weak access controls;
3. Application servers with well-known exploits;
4. Misconfigured systems and systems with default configurations.

1) Introduction

Six Types of Hackers (6 Hats)



1) Introduction

Six Types of Hackers (6 Hats) (Cont...)

- **A black hat** is also called a “**cracker**” or “**dark side hacker**.” Such a person is a malicious or criminal hacker with intention making money
- They usually have the expertise and knowledge to break into computer networks without the owners’ permission, exploit security vulnerabilities, and bypass security protocols. Typically, the term “cracker” is used within the security industry.

1) Introduction

Six Types of Hackers (6 Hats) (Cont...)

- **A white hat hacker** is a person who is ethically opposed to the abuse of computer systems. one. A “white hat” generally focuses on securing IT systems, whereas a “black hat” (the opposite) would like to break into them.
- A black hat will wish to secure his/her own machine whereas a white hat might need to break into a black hat’s machine in course of an investigation.

1) Introduction

Six Types of Hackers (6 Hats) (Cont...)

- **Grey Hat** hackers fall somewhere between white hat and black hat hackers. Grey hat hackers' intentions are often good, but they don't always take the ethical route with their hacking technics.
For example, they may penetrate your website, application, or IT systems to look for vulnerabilities without your consent. But they typically don't try to cause any harm.
- **A grey hat** releases information about any exploits or security holes he/she finds openly to the public. He/she does so without concern for how the information is used in the end(whether for patching or exploiting).

1) Introduction

Six Types of Hackers (6 Hats) (Cont...)

- Much like white hat hackers, **red hat** hackers also want to save the world from evil hackers. But they choose extreme and sometimes illegal routes to achieve their goals.
- When they find a black hat hacker, they deploy dangerous cyber attacks against them.
- In short, red hats are the types of hackers who often choose to take aggressive steps to stop black hat hackers. They're known to launch full-scale attacks to bring down the bad guys' servers and destroy their resources.

1) Introduction

Six Types of Hackers (6 Hats) (Cont...)

- **Blue Hat** hackers don't necessarily care about money or fame. They hack to **take personal revenge** for a real — or perceived — sleight from a person, employer, institution, or government.
- **Blue hat hackers** use malware and deploy various cyber attacks on their enemies' servers/networks to cause harm to their data, websites, or devices.
- Companies often invite them to test the new software and find security vulnerabilities before releasing it. Sometimes, companies organize periodic conferences for **blue hat hackers** to find the bugs in their crucial online systems.

1) Introduction

Six Types of Hackers (6 Hats) (Cont...)

- **Green Hat hackers** are the “newbies” in the world of hacking. Green hat hackers are not aware of the security mechanism and the inner workings of the web, but they are keen learners and determined (and even desperate) to elevate their position in the hacker community.
- Although their intention is not necessarily to cause harm, they may do so while “playing” with various malware and attack techniques.

2) How Criminals Plan the Attacks

Cybercrime can be categorized based on

1. The target of the crime
2. Whether the crime occurs as a single event or a series of events.

1.Crimes targeted at individuals: The goal is to exploit human weakness such as greed and naivety. These crimes include financial frauds, sale of non-existent or stolen items, child pornography, copyright violation, harassment, etc.

2.Crimes targeted at property: This includes **stealing mobile devices** such as cell phone, laptops, PDAs, and removable medias; **transmitting harmful programs** that can disrupt functions of the systems and/or can wipe out data from hard disk, and can create the malfunctioning of the attached devices in the system such as modem, CD drive, etc.

2) How Criminals Plan the Attacks

3.Crimes targeted at organizations: attackers use computer tools and the Internet to usually terrorize the citizens of a particular country by stealing the private information, and also to damage the programs and files or plant programs to get control of the network and/or system.

4.Single event of cybercrime: For eg., unknowingly open an attachment that may contain virus that will infect the system.

5.Series of events: This involves attacker interacting with the victims repetitively. For eg., attacker interacts with the victim on the phone and/or via chat rooms to establish relationship first and then they exploit that relationship to commit the sexual assault.

2) How Criminals Plan the Attacks

Active attacks, passive attacks, inside attack and outside attack

- **Active attacks** are usually used to **alter the system** whereas **passive attacks** attempt to **gain information** about the target.
- Active attacks may affect the **availability, integrity and authenticity of data** whereas passive attacks lead to **breaches of confidentiality**.
- An attack originating and/or attempted within the security parameter of an organization is **an inside attack**; it is usually attempted by an insider who gains access to more resources than expected.
- An **outside attack** is attempted by a source outside of the security parameter, maybe attempted by an outsider, who is indirectly associated with the organization, it is attempted through the Internet or a remote access connection.

2) How Criminals Plan the Attacks

The following phases are involved in planning cybercrime:

1. Reconnaissance(information gathering) is the first phase and is treated as **passive attacks**.
2. Scanning and scrutinizing the gathered information for the validity of the information as well as to identify the existing vulnerabilities.
3. Launching an attack(gaining and maintaining system access).

2) How Criminals Plan the Attacks

1. Reconnaissance:

- The literal meaning of “**Reconnaissance**” is an act of reconnoitering – explore, often with the goal of finding something or somebody (especially to gain information about an enemy or potential enemy).
- In the world of “hacking,” reconnaissance phase begins with “**Footprinting**” – this is the preparation toward preattack phase, and involves accumulating data about the target’s environment and computer architecture to find ways to intrude into that environment.
- **Footprinting** gives an overview about system vulnerabilities and provides a judgment about possible exploitation of those vulnerabilities.
- The objective of this preparatory phase is to understand the system, its networking ports and services, and any other aspects of its security that are needful for launching the attack.
- Thus, an attacker attempts to gather information in two phases: **passive and active attacks**.

2) How Criminals Plan the Attacks

1. Reconnaissance - passive attack :

- A passive attack involves gathering information about a target without his/her (individual's or company's) knowledge.
- it is usually done using Internet searches or by Googling an individual or company to gain information.
 1. **Google or Yahoo search:** People search to locate information about employees
 2. **Surfing online community groups like Orkut/Facebook** will prove useful to gain the information about an individual.
 3. **Organization's website** may provide a personnel directory or information about key employees, for example, contact details, E-Mail address, etc. These can be used in a social engineering attack to reach the target (see Section 2.3).
 4. **Blogs, newsgroups, press releases**, etc. are generally used as the mediums to gain information about the company or employees.
 5. **Going through the job postings in particular job profiles** for technical persons can provide information about type of technology, that is, servers or infrastructure devices a company maybe using on its network.

2) How Criminals Plan the Attacks

1. Reconnaissance - Active Attacks

- An active attack involves probing the network to discover individual hosts to confirm the information (IP addresses, operating system type and version, and services on the network) gathered in the passive attack phase. Also called “**Active reconnaissance.**”
- **Active reconnaissance** can provide confirmation to an attacker about security measures in place, but the **process can also increase the chance of being caught or raise a suspicion.**

2) How Criminals Plan the Attacks

2. Scanning and Scrutinizing Gathered Information

- Scanning is a key step to **examine intelligently** while gathering information about the target.
- The objectives of scanning are as follows:
 1. **Port scanning:** Identify open/close ports and services.
 2. **Network scanning:** Understand IP Addresses and related information about the computer network systems.
 3. **Vulnerability scanning:** Understand the existing weaknesses in the system.

2) How Criminals Plan the Attacks

2. Scanning and Scrutinizing Gathered Information (Cont...)

- The **scrutinizing phase** is always called “**enumeration**” in the hacking world.
- The objective behind this step is to identify:
 1. The **valid user accounts or groups**;
 2. **Network resources** and/or shared resources;
 3. OS and different applications that are running on the OS.

2) How Criminals Plan the Attacks

2. Scanning and Scrutinizing Gathered Information (Cont...)

Ports and Ports Scanning

- A port is an interface on a computer to which one can connect a device.
- A “port” is a place where information goes into and out of a computer and so, with **port scanning**, one can identify open doors to a computer.
- There are some **well-known IP ports** (0–999), which public servers use. They are important for communication over the Internet. **they open the door to potential security breaches by threat agents.**
- Tools such as **Nmap** offer an automated mechanism for an attacker to not only scan the system to find out what **ports are “open”** (meaning being used), but also help to identify what operating system (OS) is being used by the system.

2) How Criminals Plan the Attacks

2. Scanning and Scrutinizing Gathered Information (Cont...)

- The result of a scan on a port is usually generalized into one of the following three categories:
 1. **Open or accepted:** The host sent a reply indicating that a service is listening on the port.
 2. **Closed or not listening:** The host sent a reply indicating that connections will be denied to the port.
 3. **Filtered or blocked:** There was no reply from the host.

2) How Criminals Plan the Attacks

2. Scanning and Scrutinizing Gathered Information (Cont...)

- **Open ports present two vulnerabilities** of which administrators must be wary:
 1. **Vulnerabilities associated with the program** that is delivering the service.
 2. **Vulnerabilities associated with the OS** that is running on the host.
- **Closed ports** present only the latter of the two vulnerabilities that open ports do.
- **Blocked ports** do not present any reasonable vulnerabilities in either the software (program) or the OS at the given time.

2) How Criminals Plan the Attacks

3. Attack (Gaining and Maintaining the System Access)

- After the scanning and enumeration, the attack is launched using the following steps:
 1. Crack the password
 2. Exploit the privileges;
 3. Execute the malicious commands/applications;
 4. Hide the files (if required);
 5. cover the tracks – delete the access logs, so that there is no trail illicit activity.

3) Social Engineering

- **Social engineering** involves **gaining sensitive information or unauthorized access privileges** by building inappropriate trust relationships with insiders.
- A **social engineer** usually uses telecommunication (i.e., telephone and/or cell phone) or Internet to get them to do something that is against the security practices and/or policies of the organization.
- It is an **art of exploiting the trust of people**, which is not doubted while speaking in a normal manner.
- The goal of a social engineer is to **fool someone** into providing valuable information or access to that information.

3) Social Engineering

- The sign of truly successful social engineers is that they receive information without any suspicion.
- **A simple example is calling a user and pretending to be someone from the service desk** working on a network issue; the attacker then proceeds to ask questions about what the user is working on, what file shares he/she uses, what his/her password is, and so on.

3) Social Engineering

Box 2.6 Social Engineering Example

Mr. Joshi: Hello?

The Caller: Hello, Mr. Joshi. This is Geeta Thomas from Tech Support. Due to some disk space constraints on the file server, we will be moving few user's home directories to another disk. This activity will be performed tonight at 8:00 p.m. Your account will be a part of this move and will be unavailable temporarily.

Mr. Joshi: Ohh ... okay. I will be at my home by then, anyway.

Caller: Great!!! Please ensure to log off before you leave office. We just need to check a couple of things. What is your username?

Mr. Joshi: Username is "pjoshi." None of my files will be lost in the move, right?

Caller: No sir. But we will have to check your account to ensure the same. What is the password of that account?

Mr. Joshi: My password is "ABCD1965," all characters in upper case.

Caller: Ok, Mr. Joshi. Thank you for your cooperation. We will ensure that all the files are there.

Mr. Joshi: Thank you. Bye.

Caller: Bye and have a nice day.

3) Social Engineering : Classification

Two types : Human-Based and computer Based

- **Human-Based Social Engineering**-refers to person-to-person interaction to get the required/desired information. An example is calling the help desk and trying to find out a password.
 1. **Impersonating an employee or valid user:** Social engineers take advantage of the fact that most people are basically helpful, so it seems harmless to tell someone who appears to be lost where the computer room is located, or to let someone into the building who forgot his/her badge, etc., or pretending to be an employee or valid user on the system.
 2. **Posing as an important user:** For eg., a CEO or high-level manager who needs immediate assistance to gain access to a system. The attacker uses intimidation so that a lower-level employee such as a help-desk worker to help him/her in gaining access to the system.

3) Social Engineering : Classification

Human-Based Social Engineering (Cont...)

3. **Using a third person:** An attacker pretends to have permission from an authorized source to use a system. This trick is useful when the supposed authorized personnel is on vacation or cannot be contacted for verification.
4. **Calling technical support: Help-desk and technical support personnel** are trained to help users, which makes them good prey for **social engineering attacks**.
5. **Shoulder surfing:** It is a technique of gathering information such as usernames and passwords by watching over a person's shoulder while he/she logs into the system, thereby helping an attacker to gain access to the system.

3) Social Engineering : Classification

Human-Based Social Engineering (Cont...)

5. Shoulder surfing (Cont...)

Shoulder surfing refers to "using direct observation techniques, such as looking over someone's shoulder, to get information." Look around your desk, when you enter your passwords. The attacker may be right next to you.

Social Engineering may start right at work!!!



Figure 2.3 | Social engineering – shoulder surfing.

3) Social Engineering : Classification

Human-Based Social Engineering (Cont...)

6. Dumpster diving:

- It involves looking in the trash for information written on pieces of paper or computer printouts.
- it is used to describe the practice of searching through commercial or residential trash to find useful free items that have been discarded.
- It is also called **dumpstering, binning, trashing, garbing or garbage gleaning**. “Scavenging” is another term to describe these habits.

Consider, for example, going through someone’s trash to recover documentation of his/her critical data [e.g., social security number (SSN) in the US, PAN number in India, credit card identity (ID) numbers, etc.].

3) Social Engineering : Classification

- **Computer-Based Social Engineering-** refers to an attempt made to get the required/desired information by using computer software/Internet.
 1. **Fake E-Mails:** The attacker sends fake E-Mails to numerous users in such that the user finds it as a legitimate mail. It is an attempt to entice the Internet users to reveal their sensitive personal information, such as usernames, passwords and credit card details by impersonating as a trustworthy and legitimate organization and/or an individual. **Banks, financial institutes and payment gateways are the common targets.** (Example: Phishing)
 2. **E-Mail attachments:** are used to send malicious code to a victim's system, which will automatically get executed.
 3. **Pop-Up windows:** are also used, in a similar manner to E-Mail attachments.

3) Social Engineering : Classification

- **Computer-Based Social Engineering (Cont...)**
 - Thus, Phishing is also an example of social engineering techniques used to fool netizens.
 - **Phishing** is typically carried out through E-Mails or instant messaging and often directs users to enter details at a website, usually designed by the attacker with abiding the look and feel of the original website.

3) Social Engineering : Classification

Points to note:

- Information gathered by **social engineer include, critical information** such as patient records in the medical and healthcare domain, corporate financial data, electronic fund transfers, access to financial assets in the financial services domain, and PI about clients or employees.
- Social engineering succeeds by exploiting the **trust of the victim**. Hence, continuous **training/awareness** sessions about such attacks are one of the effective countermeasures.
- **Strict policies** about service desk staff never asking for personally identifying information, such as username and passwords, over the phone or in person can also educate potential victims and recognize a social engineering attempt.

4) Cyberstalking

- **It is the use of information and communications technology**, particularly the Internet, by an individual or group of individuals **to harass another individual, group of individuals or organization.**
- The behaviour includes **false accusations, monitoring, transmission of threats, ID theft, damage to data or equipment, solicitation of minors for sexual purposes**, and **gathering information** for harassment purposes.
- It involves **harassing or threatening behaviour** that an individual will conduct repeatedly, for e.g., following a person, visiting a person's home and/or at business place, making phone calls, leaving written messages, or vandalizing against the person's property.

4) Cyberstalking

Types of Stalkers

- **Online stalkers:** They aim to start the interaction with the victim directly with the help of the Internet. The stalker makes sure that the victim recognizes the attack attempted on him/her. The stalker can make use of a third party to harass the victim.
- **Offline stalkers:** The stalker may begin the attack using **traditional methods** such as following the victim, watching the daily routine of the victim, etc. Searching on **message boards/ newsgroups, personal websites, and people finding services or websites** are most common ways to gather information about the victim using the Internet.

4) Cyberstalking

How Stalking Works?

1. **Personal information gathering about the victim:** Name; family background; contact details such as cell phone and telephone numbers(of residence as well as office); address of residence as well as of the office; E-Mail address; date of birth, etc.
2. **Establish a contact with victim through telephone/cell phone.** Once the contact is established, the stalker may make calls to the victim to threaten/harass.
3. **Stalkers will almost always establish a contact with the victims through E-Mail.** The letters may have the tone of loving, threatening or can be sexually explicit. The stalker may use multiple names while contacting the victim.
4. **Some stalkers keep on sending repeated E-Mails** asking for various kinds of favours or threaten the victim.

4) Cyberstalking

How Stalking Works? (Cont...)

5. **The stalker may post the victim's personal information** on any website related to illicit services such as sex-workers' services or dating services, posing as if the victim has posted the information and invite the people to call the victim on the given contact details to have **sexual services**.
6. Whosoever comes across the information, **start calling the victim on the given contact details**, asking for sexual services or relationships.
7. Some **stalkers subscribe/register the E-Mail account of the victim to innumerable pornographic and sex sites**, because of which victim will start receiving such kind of unsolicited E-Mails

4) Cyberstalking

What is Cyberbullying ?

- The National Crime Prevention Council (NCPC) defines **Cyberbullying** as *“when the Internet, cell phones or other devices are used to send or post text or images intended to hurt or embarrass another person.”*
- www.StopCyberbullying.org, an expert organization dedicated to Internet safety, security, and privacy defines cyberbullying as **“a situation when a child, tween, or teen is repeatedly ‘tormented, threatened, harassed, humiliated, embarrassed, or otherwise targeted’ by another child, tween, or teen using text messaging, E-Mail, instant messaging, or any other type of digital technology.”**
- The practice of cyberbullying is not limited to children and, while the behavior is identified by the same definition in adults, the distinction in age groups is referred to as **cyberstalking or cyberharassment** when perpetrated by adults toward adults

5) Cybercafe and Cybercrimes

- In India, where **cybercafes** are known to be used for either **real or false terrorist communication**. Cybercrimes such as **stealing of bank passwords** and subsequent **fraudulent withdrawal of money** have also happened through cybercafes. Cybercafes have also been used regularly for sending **obscene mails to harass people**.
- Public computers, available in cybercafes, **hold two types of risks**.
 1. **First, we do not know what programs are installed on the computer** – that is, risk of malicious programs such as **keyloggers or Spyware**, which maybe running at the background that can capture the keystrokes to know the passwords and other confidential information and/or monitor the browsing behavior.
 2. Second, **over-the-shoulder peeping can enable others** to find out your passwords. Therefore, one has to be extremely careful about protecting his/her privacy on such systems, as one does not know who will use the computer after him/her

5) Cybercafe and Cybercrimes

- **Cybercriminals prefer cybercafes** to carry out their activities. The criminals tend to identify one particular personal computer (PC) to prepare it for their use.
- Cybercriminals can either install malicious programs such as **keyloggers and/or Spyware** or launch an attack on the target

5) Cybercafe and Cybercrimes

Few tips for safety and security while using the computer in a cybercafe

- **Always logout:** Simply closing the browser window without logout or signout before leaving the system is not enough, because if somebody uses the same service after you then one can get an easy access to your account.
- **Stay with the computer:** While surfing/browsing, one should not leave the system unattended for any period of time.
- **Clear history and temporary files:** Internet Explorer saves pages that you have visited in the history folder and in temporary Internet files. Your passwords may also be stored in the browser if that option has been enabled on the computer that you have used. In tools→Internet options→deselect checkboxes for passwords, delete cookies and clear history. Wait for the process to finish before leaving the computer.
- **Be alert:** One should have to stay alert and aware of the surroundings while using a public computer.

5) Cybercafe and Cybercrimes

Few tips for safety and security while using the computer in a cybercafe (Cont...)

- **Avoid online financial transactions:** Ideally one should avoid online banking, shopping or other transactions that require one to provide personal, confidential and sensitive information such as credit card or bank account details.
- **Change passwords:** Do not use the same pass.
- **Virtual keyboard:** Nowadays almost every bank has provided the virtual keyboard on their website.
- **Security warnings:** One should take utmost care while accessing the websites of any banks/financial institution.

5) Cybercafe and Cybercrimes

ICICI Bank Home [About Us](#) [Contact Us](#)
[Careers](#) [Site Map](#)

Deposites Loans Cards Investments & Insurance Demat NRI Services

Secure Banking

- ▶ Security Measures
- ▶ Browser Requirements
- ▶ Our Unique Features
- ▶ Secure Your PC
- ▶ Do's & Don'ts

Secure Yourself While...

- ▶ Using Mobile Banking
- ▶ Using your ATM/Debit Card
- ▶ Using your Credit Card
- ▶ Using Internet Banking
- ▶ Shopping Online

Learn More

- ▶ Types of Fraud
- ▶ Identify Fraud
- ▶ Cyber Cafe Security
- ▶ Password-Related Tips
- ▶ Privacy Policy
- ▶ FAQs
- ▶ Glossary

Contact US

- ▶ Do-not-Call
- ▶ Contact Points

128-bit Secure Socket Layer Encryption Technology
Entrust Digital Certificate
Secured Bill Pay & Funds Transfer
Tips for Customers

Cyber Cafe Security

If you are accessing any website (including ICICIBANK.com) from cyber cafe, any shared computer or from a computer other than that of your own, please change your passwords after such use from your own PC at workplace or at home.

It is very important to do so especially when you have entered your transaction password from such shared computer or cybercafe computer. Change these Passwords from your own PC at workplace or at house.

Search this Website

Login

- ▶ Personal
- ▶ Corporate
- ▶ Money2India
- ▶ Young Stars

Forgot Password

- ▶ New user ?
- ▶ Forgot user ID & Password

New User - Register Now

Internet Banking Demo

Online Security

a Savings account that turns into an fd and biab returns

Figure 2.5 | Cybercafe security.
Source: <http://www.icicibank.com/pfsuser/temp/cybersec.htm> (27 June 2009).

5) Cybercafe and Cybercrimes



Virtual keyboard (for entering password only)

Virtual keyboard layout showing keys for letters, numbers, and special characters.

ICICI Bank

Virtual Keyboard for Internet Banking

At ICICI Bank, We are committed to make your banking with us a safe and wonderful experience. We provide you with Virtual Keyboard to Protect your password. Virtual Keyboard is an online application to enter password with the help of a mouse.

Advantage of a Virtual Keyboard

The Virtual Keyboard is designed to protect your password from malicious "Spyware" and "Trojan Programs". Use of Virtual keyboard will reduce the risk of password theft.

Process To Use Virtual Keyboard

Steps to use Virtual keyboard are as follows:

- Enter Login ID using Physical Keyboard.
- Select the check box 'Use Virtual Keyboard'.
- Use the Virtual Keyboard to the login password.
- Once you have entered your password, click "Log-in".

•

Functions of different keys on the Virtual Keyboard

Caps Lock: This key can be used to enter upper case if the password consist of capital letters.

Back Space: This key wil clear the last character entered in the password field.

Clear: This key wil clear all characters entered in the password field by Virtual keyboard.

Tab: This key is visible only for change or forced change password. field by Virtual keyboard. This key can be used to ente values in the next field.

Figure 2.6 | Virtual keyboard.

Source: <http://www.icicibank.com/pfsuser/webnews/virtualkeyboad.htm> (27 June 2009).

5) Cybercafe and Cybercrimes

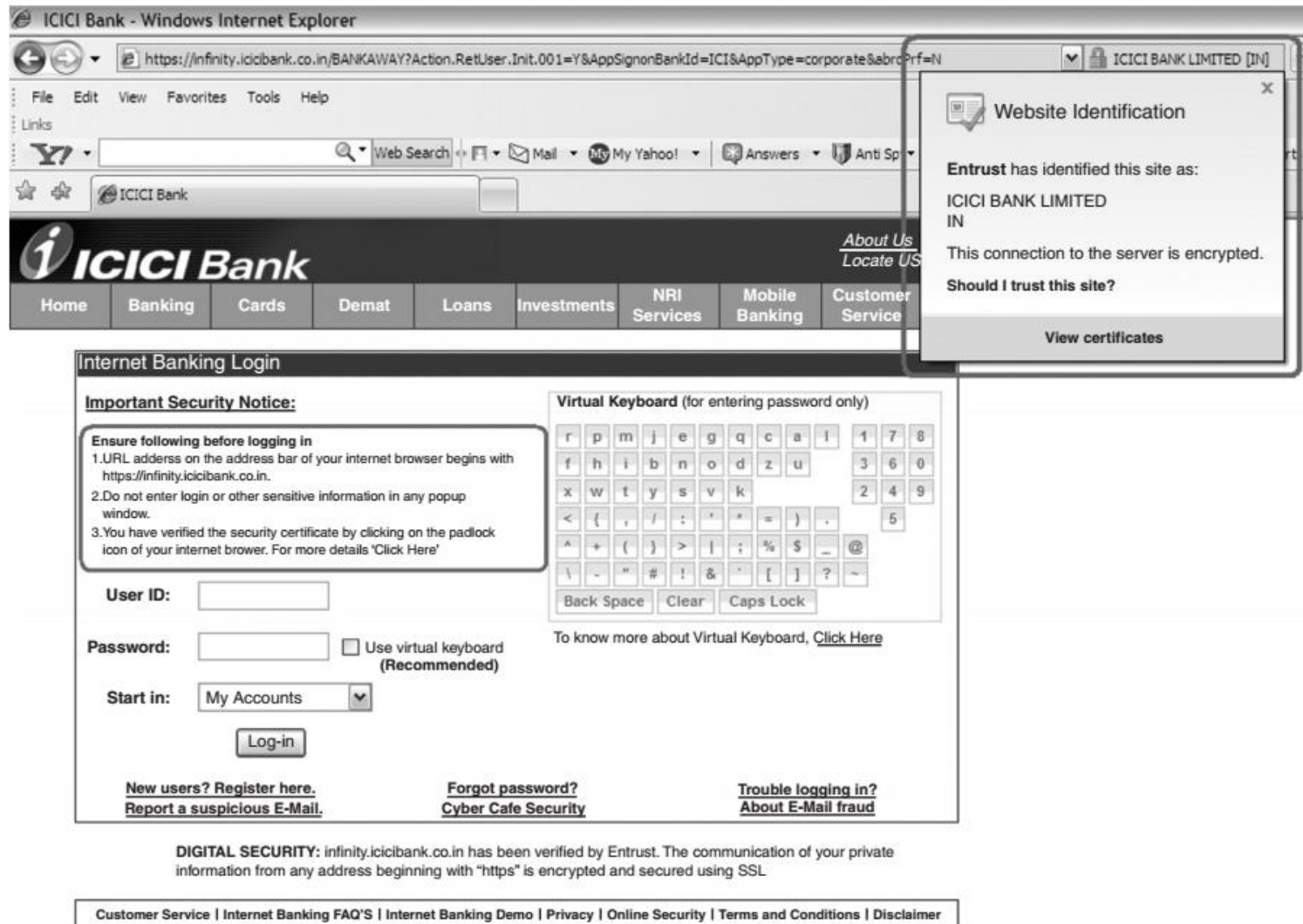


Figure 2.7 | Security warnings.

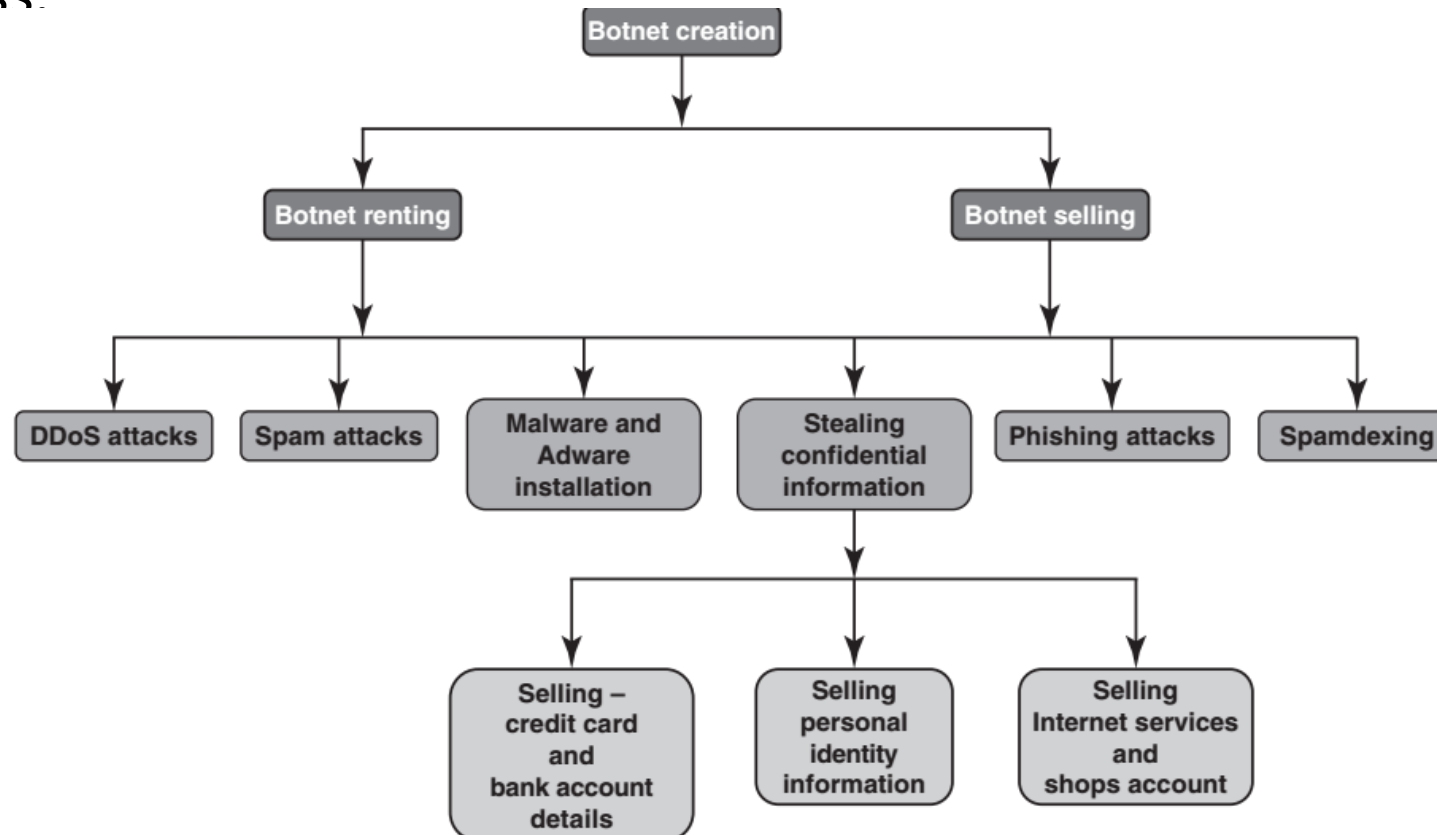
Source: <http://www.icicibank.com/pfsuser/webnews/virtualkeyboard.htm> (27 June 2009).

6) Botnets: The fuel for Cybercrime

- **Bot** is “(computing) an automated program for doing some particular task, often over a network.”
- **Botnet** is a term used for collection of software robots, or Bots, that run autonomously and automatically. The term is often associated with **malicious software** but can also refer to the network of computers using distributed computing software.
- Botnets are often used to conduct a range of activities, from distributing Spam and viruses to conducting DDoS attacks.
- **A Botnet(Zombie networks)** is a network of computers infected with a **malicious program** that allows cybercriminals to control the infected machines remotely without the users’ knowledge.

6) Botnets: The fuel for Cybercrime

- If someone wants to start a “**business**” and has no programming skills, there are plenty of “Bot for sale” offers on forums. Encryption of these programs’ code can also be ordered in the same way to protect them from detection by antivirus tools. Another option is to steal an existing Botnet. Figure 2.8 explains how Botnets create business.



6) Botnets: The fuel for Cybercrime

Box 2.9 Explanation for Technical Terms used in Fig. 2.8

Malware: It is malicious *software*, designed to damage a computer system without the owner's informed consent. Viruses and worms are the examples of malware.

Adware: It is *advertising-supported software*, which automatically plays, displays, or downloads advertisements to a computer after the software is installed on it or while the application is being used. Few Spywares are classified as Adware.

Spam: It means unsolicited or undesired E-Mail messages (this is discussed in detail in Chapter 5).

Spamdexing: It is also known as search Spam or search engine Spam. It involves a number of methods, such as repeating unrelated phrases, to manipulate the relevancy or prominence of resources indexed by a search engine in a manner inconsistent with the purpose of the indexing system.

DDoS: Distributed denial-of-service attack (DDoS) occurs when multiple systems flood the bandwidth or resources of a targeted system, usually one or more web servers. These systems are compromised by attackers using a variety of methods (this is discussed in details in Chapter 4).

6) Botnets: The fuel for Cybercrime

One can ensure following to secure the system:

- 1. Use antivirus and anti-Spyware software and keep it up-to-date.**
- 2. Set the OS to download and install security patches automatically.**
- 3. Use a firewall to protect the system** from hacking attacks while it is connected on the Internet.
- 4. Disconnect from the Internet** when you are away from your computer.
- 5. Downloading the freeware only from websites that are known and trustworthy.**
- 6. Check regularly the folders in the mail box-** “sent items” or “outgoing” – for those messages you did not send.
- 7. Take an immediate action** if your system is infected

Tools and Methods Used in Cybercrime

Topics

- **Introduction**
- **Proxy Servers and Anonymizers**
- **Phishing**
- **Password Cracking, Keyloggers and Spywares**
- **Virus and Worms**
- **Trojan-horses and Backdoors**
- **Steganography**
- **DoS and DDoS At-tacks**
- **SQL Injection**

Introduction

- There are various tools and techniques and complex methodologies used to launch attacks against the target.
- we have provided an insight toward these techniques to enable the reader to understand how the computer is an indispensable tool for almost all cybercrimes.
- As the Internet and computer networks are integral parts of information systems, attackers have in-depth knowledge about the technology and/or they gain thorough knowledge about it.

Introduction

- The **basic stages** of an attack are here described here to understand how an attacker can compromise a network here:

- 1. Initial uncovering**
- 2. Network probe**
- 3. Crossing the line toward electronic crime**
- 4. Capturing the network**
- 5. Grab the data**
- 6. Covering attacks**

Introduction

1. Initial uncovering:

Two steps are involved here.

- In the first step called as **reconnaissance**, the attacker gathers information, as much as possible, about the **target** by legitimate means-
- **searching the information** about the target on the Internet by **Googling** social networking websites and people finder websites.
- The information can also be gathered by **surfing the public websites/searching** news articles/press releases if the target is an organization/institute.

Introduction

1. Initial uncovering:

In the second step, **the attacker uncovers as much information as possible** on the company's internal network, such as, **Internet domain, machine names and the company's IP address ranges.**

From prevention perspective, at this stage, it is really not possible to **detect the attackers** because they have done nothing illegal as yet and so their information requests are considered legitimate.

Introduction

2. Network probe:

- At the network probe stage, the attacker uses more **invasive techniques** to scan the information.
- Usually, a “**ping sweep**” of the network IP addresses is performed to seek out potential targets, and then a “**port scanning**” tool is used to discover exactly which **services are running on the target system**.
- At this point, the attacker has still not done anything that would be considered as a abnormal activity on the network or anything that can be classified as an intrusion

Introduction

3. Crossing the line toward electronic crime:

- He/she does this by **exploiting possible holes** on the target system. The attacker usually goes through several stages of exploits to gain access to the system. Certain **programming errors** can be used by attackers to compromise a system and are quite common in practice.
- Exploits **usually include vulnerabilities in common gateway interface** scripts or well-known **buffer-overflow holes**, but the easiest way to gain an entry is by checking for **default login accounts** with easily **guessable(or empty) passwords**.
- Once the attackers are **able to access a guest user account** without many privileges, they will attempt further **exploits to get an administrator** or “root” access.
- The “Root” is basically an administrator or super-user access and grants them the **privileges to do anything on the system**

Introduction

4. Capturing the network:

- At this stage, the attacker **attempts to own the network**. The attacker gains a foothold in the internal network quickly and easily, by compromising **low-priority target systems**.
- The next step is to **remove any evidence of the attack**. The attacker will usually install a set of tools that **replace existing files** and services with **Trojan files** and services that have a **backdoor password**.

Introduction

4. Capturing the network:

There are a number of hacking tools which can **clean up log files and remove any trace of an intrusion.**

- Once the attacker has gained access to one system, he/she will then repeat the process by using the system as a steppingstone to **access other systems deeper within the network.**

Introduction

5. Grab the data:

- Now that the attacker has captured the network, he/she takes advantage of his/her position to **steal confidential data, customer credit information, deface webpages, alter processes and even launch attacks at other sites from your network**, causing a potentially **expensive and embarrassing** situation for an individual and/or for an organization.

Introduction

6. Covering attacks:

- This is the **last step** in any cyberattack, which refers to the **activities undertaken by the attacker to extend misuse of the system without being detected**.
- The attacker can remain undetected for long periods or use this phase either to start a **fresh reconnaissance** to a related target system or continued use of resources, **removing evidence of hacking, avoiding legal action**, etc.
- During the entire process, the **attacker takes optimum care to hide his/her identity** from the first step itself.

Proxy servers and Anonymizers

- Proxy server is a computer on a network which acts as an **intermediary for connections** with other computers on that network. The **attacker first connects to a proxy server** and establishes a connection with the target system through existing connection with proxy.
- A client connects to a proxy server and requests some services (such as a file, webpage, connection or other resource) available from a different server.
- The **proxy server evaluates the request and provides the resource by establishing the connection to the respective server and/or requests** the required service on behalf of the client.
- Using a **proxy server can allow an attacker to hide ID**

Proxy servers and Anonymizers

A proxy server has following purposes:

- Keep the **systems behind the curtain**
- Speed up access to a resource (through caching). It is usually used to **cache the webpages** from a web server.
- **Specialized proxy servers are used to filter unwanted content such as advertisements.**
- Proxy server can be used as IP address **multiplexer** to enable to connect number of computers on the Internet, whenever one has only one IP address.

Proxy servers and Anonymizers

A proxy server has following purposes (Cont...)

- One of the advantage of a proxy server is that its **cache memory can serve all users.**
- If one or more websites are requested frequently, may be by different users, it is likely to be in the proxy's cache memory, which will **improve user response time.**
- In fact there are special servers available known as cache servers.
- A proxy can also do logging.

Proxy servers and Anonymizers

- **Listed are few websites where free proxy servers can be found:**

- <http://www.proxy4free.com>
- <http://www.publicproxyservers.com>
- <http://www.proxz.com>
- <http://www.anonymitychecker.com>
- <http://www.surf24h.com>
- <http://www.hidemyass.com>

Proxy servers and Anonymizers

- ***An anonymizer*** or an anonymous proxy is a tool that attempts to make activity on the Internet untraceable.
- It accesses the Internet on the user's behalf, protecting personal information by hiding the source computer's identifying information.
- Anonymizers are services used to make Web surfing anonymous by utilizing a website that acts as a proxy server for the web client. In 1977 the first anonymizer software tool was created by Lance Cottrell, developed by Anonymizer.com.
- **Satellite Phone**

Proxy servers and Anonymizers

• Listed are few websites where more information about anonymizers can be found:

- www.anonymizer.com
- www.browzar.com
- www.anonymize.net
- www.anonymouse.ws
- www.anonymouseindex.com

Phishing

- Most people associate Phishing with E-Mail messages that spoof or mimic banks, credit card companies or other business such as Amazon and eBay.
- These messages look authentic and attempt to get users to reveal their personal information. It is believed that Phishing is an alternative spelling of “**fishing**,” as in “to fish for.

Phishing

- **Phishing work in the following way:**
 - **Planning:**
 - Criminals, usually called as phishers, decide the target and determine how to get E-Mail address of that target or customers of that business.
 - Phishers often use mass mailing and address collection techniques as **spammers**.

Phishing

- **Setup:** Once phishers know which business/business house to spoof and **who their victims are**, they will create methods for **delivering the message and to collect the data about the target**. Most often this involves E-Mail addresses and a webpage.
- **Attack:** This is the step people are most familiar with-the phisher sends a **phony message that appears to be from a reputable source**.
- **Collection:** Phishers **record the information of victims entering into webpages or pop-up windows**.
- **Identity theft and fraud:** Phishers use the information that they have gathered to make **illegal purchases or commit fraud**.

Password Cracking

- **The purpose of password cracking is as follows:**

1. To recover a forgotten password.
2. As a preventive measure by system administrators to check for easily crackable passwords.
3. To gain unauthorized access to a system.
4. Manual password cracking is to attempt to logon with different passwords.

The attacker follows the following steps:

1. Find a valid user account such as an Administrator or Guest;
2. Create a list of possible passwords;
3. Rank the passwords from high to low probability;
4. Key-in each password;
5. Try again until a successful password is found.

Password Cracking

- **Passwords can be guessed sometimes with knowledge of the user's personal information. Examples of guessable passwords include:**

1. Blank(none);
2. The words like "password", " passcode" and "admin";
3. Series of letters from the "QWERTY" keyboard, for eg., qwerty, asdf or qwertyuiop;
4. User's name or login name;
5. Name of user's friend/relative/pet;
6. User's birthplace or date of birth, or a relative's or a friend's;
7. User's vehicle number, office number, residence number or mobile number;
8. Name of a celebrity who is considered to be an idol(e.g., actors, actress, spiritual gurus) by the user;
9. Simple modification of one of the preceding, such as suffixing a digit, particularly 1, or reversing the order of letters.

Password Cracking

- An attacker can also create a **script file** (i.e., automated program) which will be executed to try each password in a list.
- This is still considered manual cracking, is time-consuming and not usually effective.
- **Passwords are stored in a database** and password verification process is established into the system when a user attempts to login or access a restricted resource.
- To ensure confidentiality of passwords, the password verification data is **usually not stored in a clear text format**.

Password Cracking

Table 4.3 | Password cracking tools

<i>Website</i>	<i>Brief Description</i>
www.defaultpassword.com	Default password(s): Network devices such as switches, hubs and routers are equipped with “default passwords” and usually these passwords are not changed after commissioning these devices into the network (i.e., into LAN). The intruders can gain the access using these default passwords by visiting the said website.
http://www.oxid.it/cain.html	Cain & Abel: This password recovery tool is typically used for Microsoft Operating Systems (OSs). It allows to crack the passwords by sniffing the network, cracking encrypted passwords using dictionary, brute force attacks, decoding scrambled passwords and recovering wireless network keys.
http://www.openwall.com/john	John the Ripper: This is a free and open-source software – fast password cracker, compatible with many OSs like different flavors of Unix, Windows, DOS, BeOS and OpenVMS. Its primary purpose is to detect weak Unix passwords.

Password Cracking

Table 4.4 | Types of password cracking attacks

<i>Type of Attack</i>	<i>Description</i>	<i>Example of a Password</i>
Dictionary attack	Attempts to match all the words from the dictionary to get the password	Administrator
Hybrid attack	Substitutes numbers and symbols to get the password	Adm1n1strator
Brute force attack	Attempts all possible permutation-combinations of letters, numbers and special characters	Adm!n@09

Password Cracking

- **Password cracking attacks can be classified under three categories as follows:**

1. Online attacks

2. Offline attacks

3. Non-electronics Attacks (E.g.: Social engineering, shoulder surfing , dumpster diving etc)

Password Cracking

1. Online attacks:

- An attacker can create a script file (i.e., automated program) that will be executed to try each password in a list and when matches, an attacker can gain access to the system.
- The most popular online attack is **man-in-the middle attack**, also termed as “**bucket-brigade attack**” or sometimes “**Janus attack**”.

Password Cracking

1. Online attacks:

- When a victim client connects to the fraudulent server, the MITM server intercepts the call, hashes the password and passes the connection to the victim server.
- This type of attack is used to obtain the passwords for E-Mail accounts on public websites such as Yahoo, Hotmail and Gmail and can also be used to get the passwords for financial websites that would like to gain the access to banking websites.

Password Cracking

2. Offline attacks:

- **These** are performed from a location other than the target (i.e., either a computer system or while on the network) where these passwords reside or are used.
- Offline attacks usually require physical access to the computer and copying the password file from the system onto removable media.

Password Cracking

Strong, Weak and Random Passwords

- A **weak password** is one, which could be easily guessed, short, common and a system default password that could be easily found by executing a brute force attack and by using a subset of all possible passwords, such as words in the dictionary, proper names and words based on the username or common variations on these themes.
- Passwords that can be easily guessed by acquaintances of the netizens (such as date of birth, pet's name and spouses' name) are considered to be very weak.

Password Cracking

Strong, Weak and Random Passwords

- **Here are some of the examples of “weak passwords”:**

1. **Susan:** Common personal name;
2. **aaaa:** repeated letters, can be guessed;
3. **rover:** common name for a pet, also a dictionary word;
4. **abc123:** can be easily guessed;
5. **admin:** can be easily guessed;
6. **1234:** can be easily guessed;

Password Cracking

Strong, Weak and Random Passwords

- **Here are some of the examples of “weak passwords”:**

7. **QWERTY:** a sequence of adjacent letters on many keyboards;
8. **12/3/75:** date, possibly of personal importance;
9. **nbusr123:** probably a username, and if so, can be very easily guessed;
10. **p@\$\$\//0rd:** simple letter substitutions are preprogrammed into password cracking tools;
11. **password:** used very often – trivially guessed;
12. **December12:** using the date of a forced password change is very common.

Password Cracking

Strong, Weak and Random Passwords

- A **strong password** is **long enough, random or otherwise difficult to guess** – producible only by the user who chooses it.
- The length of time deemed to be too long will vary with the attacker, the attacker's resources, the ease with which a password can be tried and the value of the password to the attacker.
- **E.g.:** a password controlling access to a large **bank's electronic money transfer system**

Password Cracking

Strong, Weak and Random Passwords

- Here are some examples of strong passwords:
 1. **Convert_£100 to Euros!:** Such phrases are long, memorable and contain an extended symbol to increase the strength of the password.
 2. **382465304H:** It is mix of numbers and a letter at the end, usually used on mass user accounts and such passwords can be generated randomly, for example, in schools and business.
 3. **4pRte!ai@3:** It is not a dictionary word; however it has cases of alpha along with numeric and punctuation characters.
 4. **MoOoOfIn245679:** It is long with both alphabets and numerals.
 5. **t3wahSetyeT4:** It is not a dictionary word; however, it has both alphabets and numerals.

Password Cracking

Random Passwords

- Password is stronger if it includes a mix of upper and lower case letters, numbers and other symbols, when allowed, for the same number of characters.
- The difficulty in remembering such a password increases the chance that the user will write down the password, which makes it more vulnerable to a different attack
- A password can, at first sight, be random, but if you really examine it, it is just a pattern. One of these types of passwords is 26845. It is just the four direction keys on the square number board plus a five in the middle.
- The imposition of strong random passwords may encourage the users to write down passwords, store them in personal digital assistants increasing the risk of disclosure.

Password Cracking

Random Passwords

- The general guidelines applicable to the password policies, which can be implemented organization-wide, are as follows:
 1. Passwords and user logon identities (IDs) should be **unique** to each authorized user.
 2. Passwords should consist of a minimum of **eight alphanumeric** characters (no common names or phrases).
 3. There should be computer-controlled lists of **prescribed password rules and periodic testing** (e.g., letter and number sequences, character repetition, initials, common words and standard names) to identify any password weaknesses.
 4. Passwords should be **kept private**, that is, not shared with friends, colleagues, etc. They shall not be coded into programs or noted down anywhere.
 5. Passwords shall be **changed every 30/45 days or less**. Most operating systems (OSs) can enforce a password with an automatic expiration and prevent repeated or reused passwords.
 6. User accounts should be **frozen after five failed logon attempts**. All

Password Cracking

Random Passwords

7. Sessions should be **suspended after 15 minutes** (or other specified period) of inactivity and require the passwords to be re-entered.
8. **Successful logons should display the date and time of the last logon and logoff.**
9. Logon IDs and passwords should be suspended after a **specified period of non-use.**
10. **For high-risk systems, after excessive violations, the system should generate an alarm** and be able to simulate a continuing session (with dummy data) for the failed user

Password Cracking

Similarly, netizens should practice password guidelines to avoid being victim of getting their personal E-Mail accounts hacked/attacked by the attackers.

1. Passwords used for business E-Mail accounts, personal E-Mail accounts (Yahoo/Hotmail/Gmail) and banking/financial user accounts (e.g., online banking/securities trading accounts) should be kept separate.
2. Passwords should be of minimum eight alphanumeric characters (common names or phrases should be phrased).
3. Passwords should be changed every 30/45 days.
4. Passwords should not be shared with relatives and/or friends.
5. Password used previously should not be used while renewing the password.

Password Cracking

6. Passwords of personal E-Mail accounts (Yahoo/Hotmail/Gmail) and banking/financial user accounts (e.g., online banking/securities trading accounts) should be **changed from a secured system, within couple of days**, if these E-Mail accounts has been accessed from public Internet facilities such as **cybercafes/hotels/libraries**.
7. Passwords should not be **stored under mobile phones/PDAs, as these devices are also prone to cyberattacks**
8. In the case of receipt of an E-Mail from banking/financial institutions, **instructing to change the passwords**, before clicking the weblinks displayed in the E-Mail, **legitimacy of the E-Mail should be ensured to avoid being a victim of Phishing attacks**

Password Cracking

9. Similarly, in case of receipt of **SMS** from banking/financial institutions, instructing to change the passwords, legitimacy of the E-Mail should be ensured to avoid being a victim of Smishing attacks
10. In case E-Mail accounts/user accounts have been hacked, respective **agencies/institutes should be contacted immediately.**

Keyloggers and Spywares

- Keystroke logging, often called keylogging, is the practice of **noting the keys struck on a keyboard**, typically in a covert manner so that the person using the keyboard is unaware that such actions are being monitored.
- It can be classified as
 - 1. software keylogger**
 - 2. hardware keylogger.**

Keyloggers and Spywares

Software keyloggers

- **These** are software programs installed on the computer systems which usually are located between the OS and the keyboard hardware, and **every keystroke is recorded.**
- It **is installed on a computer system by Trojans or viruses** without the knowledge of the user.
- A keylogger usually consists **of two files** that get installed in the same directory: a **dynamic link library(DLL)** file and **an Executable file** that installs the DLL file and triggers it to work. DLL does all the recording of keystrokes.

Keyloggers and Spywares

Table 4.5 | Software keyloggers

<i>Website</i>	<i>Brief Description</i>
http://www.soft-central.net	SC-KeyLog PRO: It allows to secretly record computer user activities such as E-Mails, chat conversations, visited websites, clipboard usage, etc. in a protected logfile. SC-KeyLog PRO also captures Windows user logon passwords. The captured information is completely hidden from the user and allows to remotely install the monitoring system through an E-Mail attachment without the user recognizing the installation at all.
http://www.spytech-web.com	Spytech SpyAgent Stealth: It provides a large variety of essential computer monitoring features as well as website and application filtering, chat blocking and remote delivery of logs via E-Mail or FTP.
http://www.relytec.com	All In One Keylogger: It is an invisible keystrokes recorder and a spy software tool that registers every activity on the PC to encrypted logs. This keylogger allows secretly tracking of all activities from all computer users and automatically receiving logs to a desired E-Mail/FTP accounting. With this keylogger, one can read chat conversations, look at the E-Mails as well as watch the sites that have been surfed.

Keyloggers and Spywares

Hardware keyloggers

- To install these **keyloggers**, **physical access to the computer system is required**. Hardware keyloggers are small hardware devices.
- These are **connected to the PC and/or to the keyboard** and **save every keystroke into a file** or in the memory of the hardware device.
- Cybercriminals install such devices on **ATM machines** to capture ATM cards' PINs.

Keyloggers and Spywares

Hardware keyloggers

Listed are few websites where more information about hardware keyloggers can be found:

1. <http://www.keyghost.com>
2. <http://www.keelog.com>
3. <http://www.keydevil.com>
4. <http://www.keycatcher.com>

Antikeylogger

- It is a tool that can detect the keylogger installed on the computer system and also can remove the tool.
- Advantages of using **antikeylogger** are as follows:
 1. **Firewalls cannot detect the installations** of keyloggers on the systems; hence, antikeyloggers can detect installations of keylogger.
 2. This software **does not require regular updates** of signature bases to work effectively such as other antivirus and antispy programs; if not updated, it does not serve the purpose, which makes the users at risk.
 3. **Prevents Internet banking frauds**. Passwords can be easily gained with the help of installing keyloggers.
 4. It prevents **ID theft**.
 5. It **secures E-Mail** and instant messaging/chatting.

Keyloggers and Spywares

Spywares

- Spyware is a type of malware that is installed on computers which collects information about users **without their knowledge.**
- The presence of Spyware is typically hidden from the user; it is **secretly installed on the user's personal computer.**
- Sometimes, however, Spywares such as keyloggers are installed by the owner of a shared, corporate or **public computer on purpose to secretly monitor other users.**
- **It secretly monitors the user.** The features and functions of such Spywares are beyond simple monitoring.
- **Spyware programs collect personal information about the victim, such as the Internet surfing habits/patterns and websites visited.**

Keyloggers and Spywares

Spywares

- The Spyware can also redirect Internet surfing activities by installing another stealth utility on the users' computer system.
- Spyware may also have an ability to change computer settings, which may result in slowing of the Internet connection speeds and slowing of response time.
- Various Spywares are available in the market
- Installation of anti-Spyware software has become a common element nowadays from computer security practices perspective.

Keyloggers and Spywares

Spywares

Box 4.3 Malwares

Malware, short for malicious software, is a software designed to infiltrate a computer system without the owner's informed consent (see Box 9.8, Chapter 9). The expression is a general term used by computer professionals to mean a variety of forms of hostile, intrusive or annoying software or program code.^[13] Malware can be classified as follows:

1. **Viruses and worms:** These are known as *infectious malware*. They spread from one computer system to another with a particular behavior (will discuss more on this in Section 4.6).
2. **Trojan Horses:** A Trojan Horse,^[14] Trojan for short, is a term used to describe malware that appears, to the user, to perform a desirable function but, in fact, facilitates unauthorized access to the user's computer system (will discuss more on this in Section 4.7).
3. **Rootkits:** Rootkits^[15] is a software system that consists of one or more programs designed to obscure the fact that a system has been compromised. For further details refer to Section 7.12.1, Chapter 7.
4. **Backdoors:** Backdoor^[16] in a computer system (or cryptosystem or algorithm) is a method of bypassing normal authentication, securing remote access to a computer, obtaining access to plain text and so on while attempting to remain undetected.
5. **Spyware:** For further details see Section 4.5.
6. **Botnets:** For further details see Section 2.6 in Chapter 2.
7. **Keystroke loggers:** For further details see Section 4.5.

Keyloggers and Spywares

Spywares

Table 4.6 | Spywares

<i>Website</i>	<i>Brief Description</i>
http://www.e-spy-software.com	007 Spy: It has following key features: • Capability of overriding “antispy” programs like “Ad-aware”; • record all websites URL visited in Internet; • powerful keylogger engine to capture all passwords; • view logs remotely from anywhere at anytime; • export log report in HTML format to view it in the browser; • automatically clean-up on outdated logs; • password protection.
http://www.spectorsoft.com	Spector Pro: It has following key features: • Captures and reviews all chats and instant messages; • captures E-Mails (read, sent and received); • captures websites visited; • captures activities performed on social networking sites such as MySpace and Facebook; • enables to block any particular website and/or chatting with anyone; • acts as a keylogger to capture every single keystroke (including usernames and passwords).

Viruses and Worms

- Computer virus is a program that can “**infect**” **legitimate programs** by modifying them to include a possibly “evolved” copy of itself.
- **Viruses spread themselves, without the knowledge or permission of the users**, to potentially large numbers of programs on many machines.
- A computer virus passes from computer to computer in a similar manner **as a biological virus passes from person to person.**
- Viruses may also contain malicious instructions that may **cause damage or annoyance**; the combination of possibly Malicious Code with the ability to spread is what makes viruses a considerable concern.
- Viruses can often spread **without any readily visible symptoms.**

Viruses and Worms

- A virus can start on **event-driven effects** (e.g., triggered after a specific number of executions), **time-driven effects** (e.g., triggered on a specific date, such as Friday the 13th) or can occur at random.

Viruses can take some typical actions:

1. Display a message to **prompt an action** which may set of the virus;
2. **Delete files** inside the system into which viruses enter;
3. **Scramble data** on a hard disk;
4. **Cause erratic screen behaviour**;
5. **Halt the system**;
6. Just **replicate themselves** to propagate further harm.

Viruses and Worms

- Figures 4.1–4.3 explain how viruses spread (a) through the Internet, and

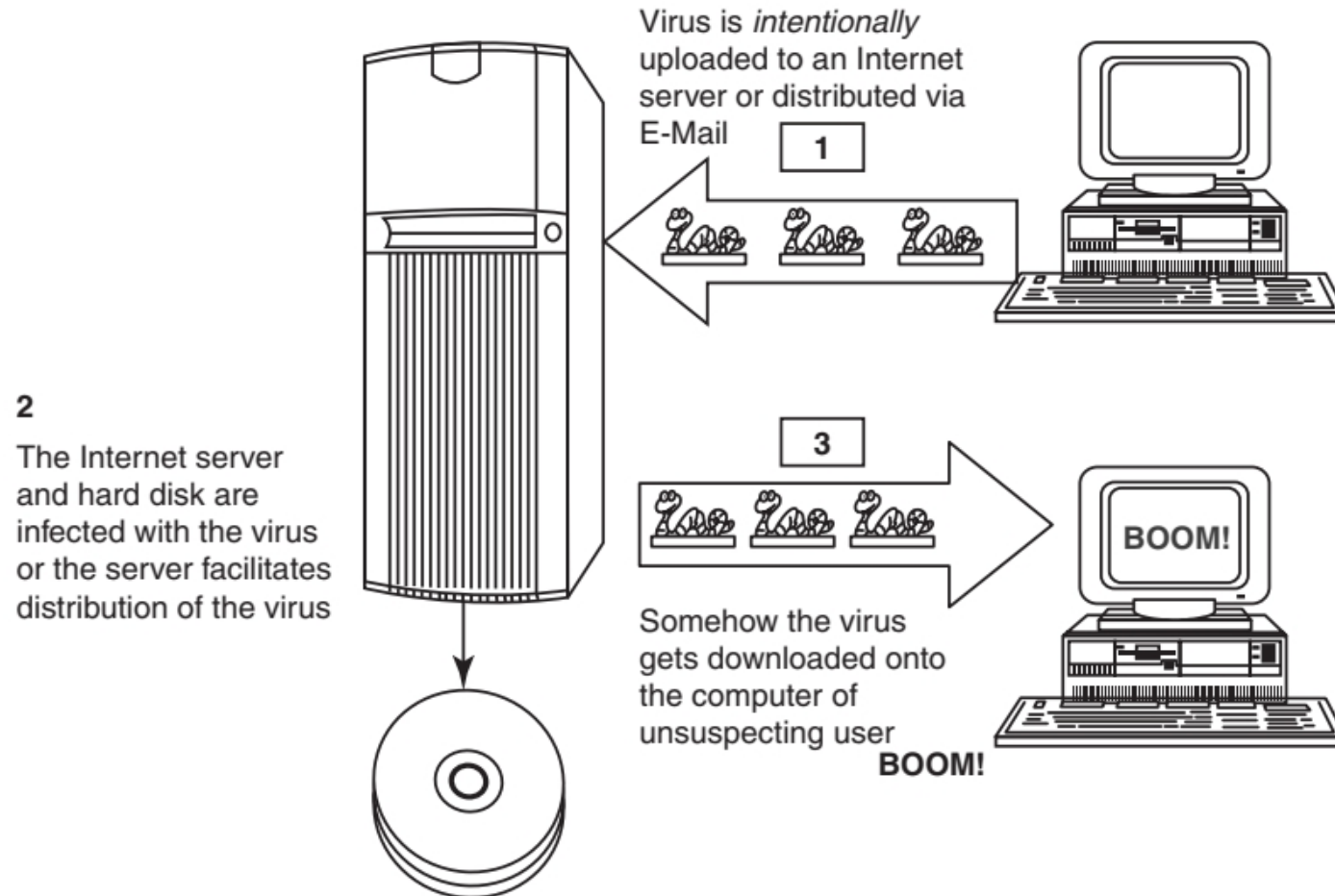


Figure 4.1 | Virus spreads through the Internet.

Viruses and Worms

- **b) through a stand-alone computer system**

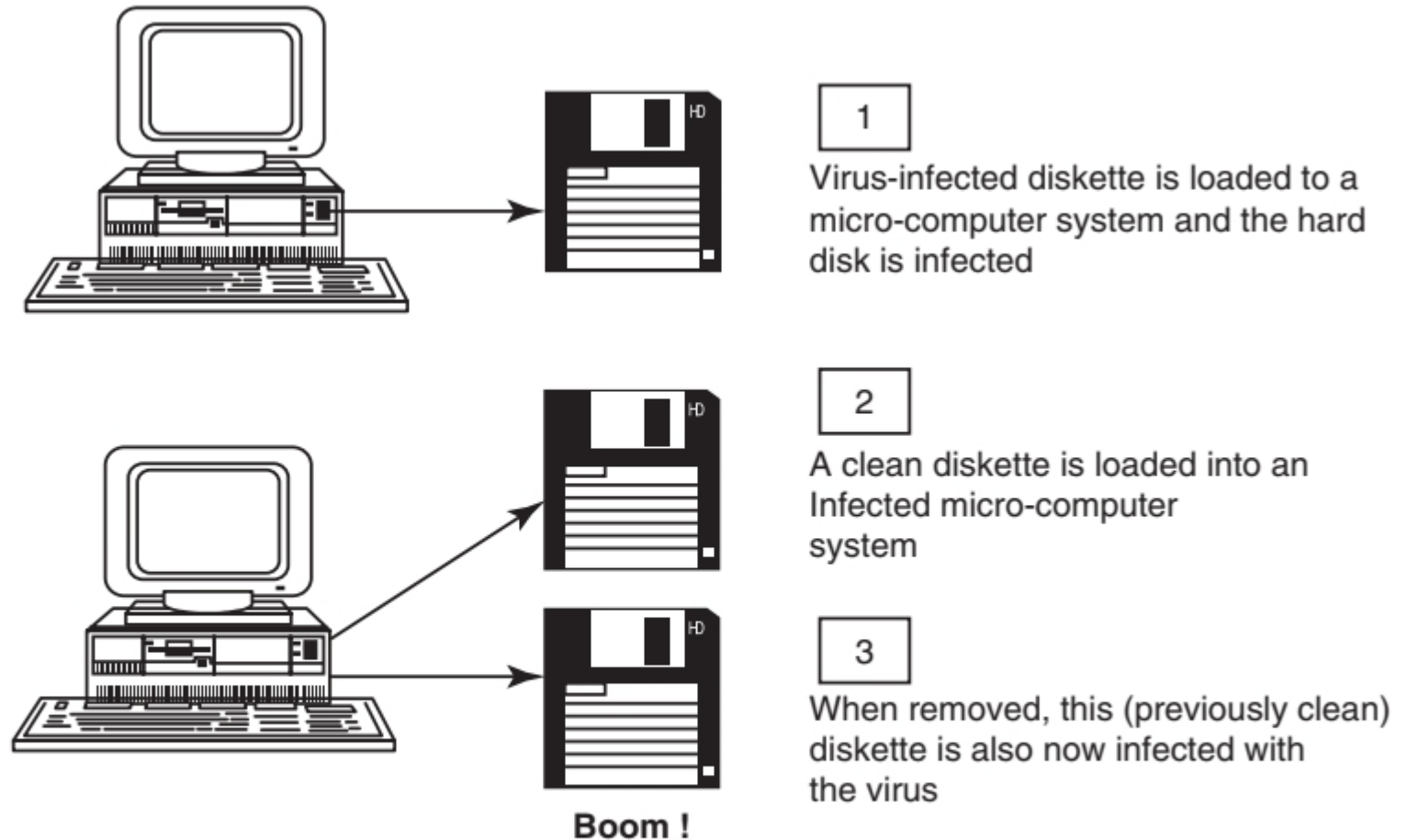


Figure 4.2 | Virus spreads through stand-alone system.

Viruses and Worms

(c) through local networks.

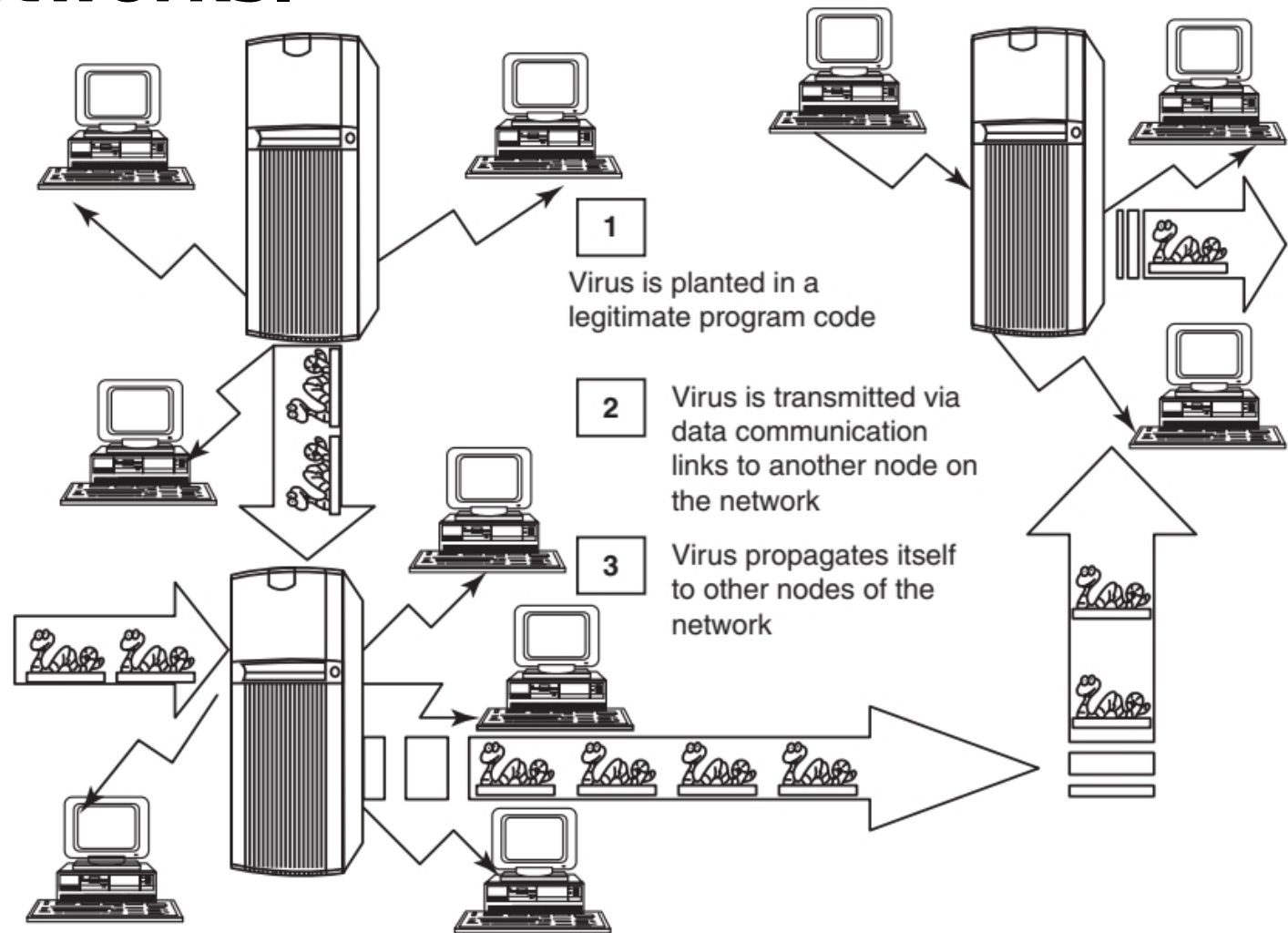


Figure 4.3 | Virus spreads through local networks.

Viruses and Worms

- Computer virus has the ability to copy itself and infect the system.
- The term virus is also commonly but erroneously used to refer to other types of malware, Adware and Spyware programs that do not have reproductive ability.
- A true virus can only spread from one system to another (in some form of executable code) when its host is taken to the target computer; for instance, when a user sent it over the Internet or a network, or carried it on a removable media such as CD, DVD or USB drives

Viruses and Worms

- Viruses can increase their chances of **spreading to other systems** by infecting files on a network file system or a file system that is accessed by another system.
- The term computer virus is sometimes used as a catch-all phrase to include all types of malware, Adware and Spyware programs that do not have **reproductive ability**.
- Viruses are sometimes confused with computer **worms and Trojan Horses**, which are technically different.

Viruses and Worms

Differences between Computers Viruses and

<i>Sr. No.</i>	<i>Facet</i>	<i>Virus</i>	<i>Worm</i>
1	Different types	Stealth virus, self-modified virus, encryption with variable key virus, polymorphic code virus, metamorphic code virus	E-Mail worms, instant messaging worms, Internet worms, IRC worms, file-sharing networks worms
2	Spread mode	Needs a host program to spread	Self, without user intervention
3	What is it?	A computer virus is a software program that can copy itself and infect the data or information, without the users' knowledge. However, to spread to another computer, it needs a host program that carries the virus	A computer worm is a software program, self-replicating in nature, which spreads through a network. It can send copies through the network with or without user intervention

Viruses and Worms

Differences between Computers Viruses and Worms

4	Inception	The creeper virus was considered as the first known virus. It was spread through ARPANET in the early 1970s. It spreads through the TENEX OS and uses connected modem to dial out to a remote computer and infect it.	The name worm originated from The Shockwave Rider, a science fiction novel published in 1975 by John Brunner. Later researchers John F Shock and Jon A Hupp at Xerox PARC published a paper in 1982, <i>The Worm Programs</i> and after that the name was adopted
5	Prevalence	Over 100,000 known computer viruses have been there though not all have attacked computers (till 2005)	Prevalence for virus is very high as against moderate prevalence for a worm.

Viruses and Worms

Types of Viruses

- Boot sector viruses
- Program viruses
- Multipartite viruses
- Stealth viruses
- Polymorphic viruses
- Macroviruses
- Active X and Java Control

Viruses and Worms

Boot sector viruses:

- It **infects the storage media** on which **OS** is stored and which is used to start the computer system.
- The entire data/programs are stored on the floppy disks and hard drives in small sections called sectors. The first sector is called the **BOOT** and it carries the master boot record(MBR).
- MBR's function is to **read and load OS**, that is, it enables computer system to start through OS.

Viruses and Worms

Boot sector viruses(Cont...)

- Once the victim's hard drive is infected all the floppy diskettes that are being used in the system will be infected.
- Boot sector viruses often spread to other systems when shared infected disks and pirated software(s) are used.

Viruses and Worms

- Program viruses:

- These viruses **become active** when the program file (usually with extensions **.bin, .com, .exe, .ovl, .drv**) is executed (i.e. opened-program is started).
- Once these program files get infected, the **virus makes copies of itself** and infects the other programs on the computer system.
- These viruses become active when the program file (usually with extensions **.bin, .com, .exe, .ovl, .drv**) is executed (i.e. opened-program is started).
- Once these program files get infected, the **virus makes copies of itself and infects the other programs** on the computer system.

Viruses and Worms

- **Multipartite viruses:**
- It is a **hybrid of a boot sector and program** viruses.
- It **infects program files along with the boot record** when the infected program is active.
- When the victim starts the computer system next time, it will **infect the local drive and other programs** on the victim's computer system.

Viruses and Worms

- **Stealth viruses:**

- It camouflages and/or masks itself and so detecting this type of virus is very difficult.
- It can disguise itself such a way that antivirus software also cannot detect it thereby preventing spreading into the computer system.
- It alters its file size and conceals itself in the computer memory to remain in the system undetected.
- The first computer virus, named as **Brain**, was a stealth virus.

Viruses and Worms

- **Polymorphic viruses:**
- It acts like a “chameleon” that **changes its virus signature** (i.e., binary patterns) every time it spreads through the system (i.e., multiplies and infects a new file).
- Hence, it is always difficult to detect polymorphic virus with the help of an antivirus program. **Polymorphic generators** are the routines (i.e., small programs) that can be linked with the existing viruses.
- These generators are not viruses but the purpose of these **generators is to hide actual viruses** under the cloak of polymorphism.
- The first all-purpose polymorphic generator was the mutation engine published in 1991.

Viruses and Worms

- Other known polymorphic generators are Dark Angel's Multiple Encryptor(DAME), Darwinian Genetic Mutation Engine(DGME), Dark Slayer Mutation Engine(DSME), MutaGen, Guns'n'Roses Polymorphic Engine(GPE) and Dark Slayer Confusion Engine(DSCE).
- **Macroviruses:**
- Many applications, such as MS Word, MS Excel, support **MACROS**. These macros are programmed as a macroembedded in a document.
 - Once a macrovirus gets onto a victim's computer then **every document he/she produces will become infected.**
 - This type of virus is relatively new and may **get slipped by the antivirus software** if the user does not have the most recent version installed on his/her system.

Viruses and Worms

- **Active X and Java Control:**
- **All the web browsers have settings about Active X and Java Controls.**
- Little awareness is needed about managing and controlling these settings of a **web browser to prohibit and allow certain functions to work**- such as **enabling or disabling pop-ups, downloading files and sound** – which invites the threats for the computer system being targeted by unwanted software(s) floating in cyberspace.

Viruses and Worms

- Almost every day new viruses/worms are created and they become new threat to netizens.
- In summary, in spite of different platforms (i.e., OS and/or applications), a typical definition of computer virus/worms might have various aspects[21] such as:
 1. A virus attacks specific file types (or files).
 2. A virus manipulates a program to execute tasks unintentionally.
 3. An infected program produces more viruses.
 4. An infected program may run without error for a long time.
 5. Viruses can modify themselves and may possibly escape detection this way.

Trojan Horses and Backdoors

- Trojan Horse is a program in which **malicious or harmful code is contained inside apparently harmless programming or data** in such a way that it can get control and cause harm, for example, **ruining the file allocation table on the hard disk.**
- A Trojan Horse may get **widely redistributed as part of a computer virus**
- The term Trojan Horse comes from Greek mythology about the Trojan War

Trojan Horses and Backdoors

- Like Spyware and Adware, Trojans can get into the system in a number of ways, **including from a web browser**, via **E-Mail** or in a bundle with other software downloaded from the Internet.
- It is also possible to **inadvertently transfer malware through a USB flash drive or other portable media**. It is possible that one could be forced to reformat USB flash drive or other portable device to eliminate infection and avoid transferring it to other machines.

Trojan Horses and Backdoors

- Unlike viruses or worms, Trojans do not replicate themselves but they can be equally destructive.
- On the surface, Trojans appear benign and harmless, but once the infected code is executed, Trojans kick in and perform malicious functions to harm the computer system without the user's knowledge.
- For example, **waterfalls.scr** is a waterfall screen saver as originally claimed by the author; however, it can be associated with malware and become a Trojan to unload hidden programs and allow unauthorized access to the user's PC.

Trojan Horses and Backdoors

- **Some typical examples of threats by Trojans are as follows:**
 1. They erase, overwrite or corrupt data on a computer.
 2. They help to spread other malware such as viruses (by a dropper Trojan).
 3. They deactivate or interfere with antivirus and firewall programs.
 4. They allow remote access to your computer (by a remote access Trojan).
 5. They upload and download files without your knowledge.
 6. They gather E-Mail addresses and use them for Spam.
 7. They log keystrokes to steal information such as passwords and credit card numbers.
 8. They copy fake links to false websites, display porno sites, play sounds/videos and display images.
 9. They slow down, restart or shutdown the system.
 10. They reinstall themselves after being disabled.
 11. They disable the task manager.
 12. They disable the control panel.

Backdoors

- A means of access to a computer program that **bypasses security** mechanisms. A programmer may sometimes install a backdoor so that the program can be accessed for troubleshooting or other purposes.
- A backdoor works in **background and hides** from the user.
- **Most backdoors are autonomic malicious programs** that must be somehow installed to a computer.
- Some parasites do not require installation, as their parts are already integrated into particular **software running on a remote host**.

Trojan Horses and Backdoors

What a Backdoor does?

- It allows an attacker to create, delete, rename, copy or edit any file, execute various commands; change any system settings; alter the Windows registry; run, control and terminate applications; install arbitrary software and parasites.
- It allows an attacker to control computer hardware devices, modify related settings, shutdown or restart a computer without asking for user permission.

Trojan Horses and Backdoors

What a Backdoor does? (Cont...)

- It **steals sensitive personal information**, valuable documents, passwords, login names, ID details; logs user activity and tracks web browsing habits.
- It **records keystrokes** that a user types on a computer's keyboard and captures screenshots.
- It **sends all gathered data to a predefined E-Mail** address, uploads it to a predetermined FTP server or transfers it through a background Internet connection to a remote host.

Trojan Horses and Backdoors

What a Backdoor does? (Cont...)

- It **infects files, corrupts installed** applications and damages the entire system.
- It **distributes infected files** to remote computers with certain security vulnerabilities and **performs attacks against hacker-defined remote hosts**.
- It installs hidden FTP server that can be used by malicious persons for **various illegal purposes**.

Trojan Horses and Backdoors

What a Backdoor does? (Cont...)

- It degrades Internet connection speed and overall system performance, decreases system security and causes software instability. Some parasites are badly programmed as they waste too many computer resources and conflict with installed applications.
- It provides no uninstall feature, and hides processes, files and other objects to complicate its removal as much as possible.

Trojan Horses and Backdoors

Two examples of backdoor Trojans

- **Back Orifice:** It is a well-known example of backdoor Trojan designed for **remote system administration**. It enables a user to control a computer running the MS **Windows OS** from a remote location. The name is a word play on MS BackOffice Server software.
- **Bifrost:** It is another backdoor Trojan that can infect **Windows95 through Vista**. It uses the typical server, server builder and client backdoor program configuration to allow a remote attacker, **who uses client, to execute arbitrary code on the compromised machine**.

Trojan Horses and Backdoors

How to protect from Trojan Horses and Backdoors

1. Stay away from suspect websites/weblinks: Avoid downloading free/pirated softwares that often get infected by Trojans, worms, viruses and other things.
- 2. Surf on the Web cautiously:** Avoid connecting with and/or downloading any information from P2P networks, which are most dangerous networks to spread Trojan Horses and other threats. P2P networks create files packed with malicious software, and then rename them to files with the criteria of common search that are used while surfing the information on the Web.
- 3. Install antivirus/Trojan remover software:** Free Trojan remover programs are also available on the Web and some of them are really good.

Steganography

- Steganography is the **art and science of writing hidden messages** in such a way that no one apart from the intended recipient knows the existence of the message;
- That is in contrast to **cryptography**, where the **existence of the message itself is not disguised, but the content is obscured.**
- The word “steganography” comes from the two Greek words: steganos meaning “covered” and graphein meaning “to write” that means **“concealed writing.”**

Steganography

- For example, in a digital image the least significant bit of each word can be used to compromise a message without causing any significant change in the image.
- Steganography can be used to make a digital watermark to detect illegal copying of digital images. Thus, it aids confidentiality and integrity of the data.

Steganography

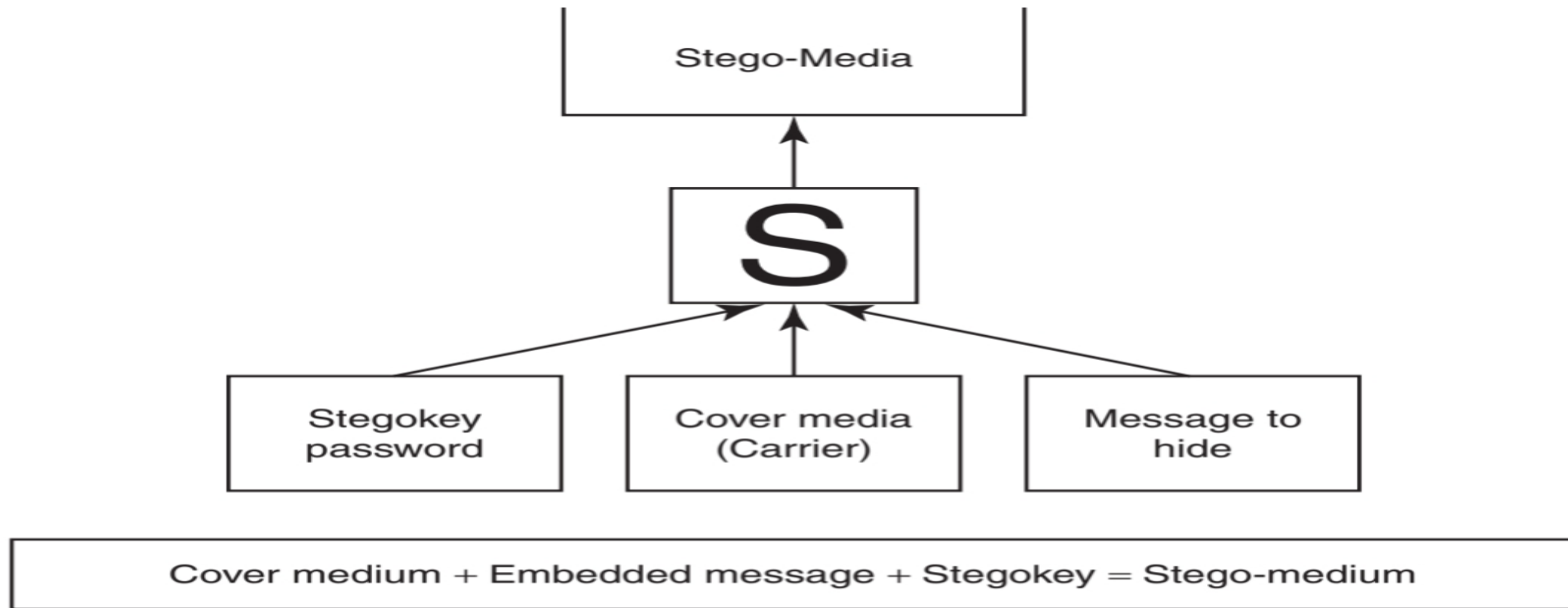
- Interestingly, steganography in digital media is very similar to “digital watermarking”. In other words, when steganography is used to place a hidden “trademark” in images, music and software, the result is a technique referred to as “watermarking”.
- The term “cover” or “cover medium” is used to describe the original, innocent message, data, audio, still, video and so on. It is the medium that hides the secret message .

Steganography

- It must have parts that can be altered or used without damaging or noticeably changing the cover media. If the cover media are digital, these alterable parts are called “redundant bits.”
- These bits or a subset can be replaced with the message that is intended to be hidden. Interestingly, steganography in digital media is very similar to “digital watermarking.”

Steganography

- In other words, when steganography is used to place a hidden “trademark” in images, music and software, the result is a technique referred to as “watermarking”



How steganography works.

Source: <http://www.cosc.iup.edu/sezekiel/Seminar/steg.ppt#452,15,Steganography%20of%20today's%20talk> (11 May 10).

Steganography

Steganalysis

- Is the art and science of detecting messages that are hidden in images, audio/video files using steganography. The goal is to identify suspected packages and to determine whether or not they have a payload encoded into them, and if possible recover it.

DoS Attacks

- In this type of criminal act, the attacker floods the bandwidth of the victim's network or fills his E-Mail box with Spam mail depriving him of the services he is entitled to access or provide.
- It generally consists of the concerted efforts of a person or people to prevent the Internet site or service from functioning efficiently or at all, temporarily or indefinitely.
- The attackers typically target sites or services hosted on high-profile web servers such as banks, credit card payment gateways, mobile phone networks and even root name servers

DoS Attacks

- **Buffer overflow** technique is employed to commit such kind of criminal attack known as **Spoofing**.
- The attacker spoofs the IP address and floods the network of the victim with **repeated requests**.
- As the **IP address is fake**, the victim machine keeps waiting for response from the **attacker's machine for each request**.
- This consumes the bandwidth of the network which then fails to serve the **legitimate requests**

DoS Attacks

- The United States Computer Emergency Response Team defines symptoms of DoS attacks to include:
 - Unusually **slow** network performance (opening files or accessing websites);
 - **Unavailability** of a particular website;
 - **Inability** to access any website;
 - Dramatic **increase in the number of Spam E-Mails** received (this type of DoS attack is termed as **E-Mail Bomb**)

DoS Attacks

- A DoS attack may do the following:
 - **Flood a network** with traffic, thereby preventing legitimate network traffic.
 - **Disrupt connections** between two systems, thereby preventing access to a service.
 - **Prevent a particular individual** from accessing a service.
 - **Disrupt service** to a specific system or person.

DoS Attacks

•Classification of DoS Attacks:

<i>Sr. No.</i>	<i>DoS Attacks</i>	<i>Brief Description</i>
1	Bandwidth attacks	Loading any website takes certain time. Loading means complete webpage (i.e., with entire content of the webpage – text along with images) appearing on the screen and system is awaiting user's input. This "loading" consumes some amount of memory. Every site is given with a particular amount of bandwidth for its hosting, say for example, 50 GB. Now if more visitors consume all 50 GB bandwidth then the hosting of the site can ban this site. The attacker does the same – he/she opens 100 pages of a site and keeps on refreshing and consuming all the bandwidth, thus, the site becomes out of service.
2	Logic attacks	These kind of attacks can exploit vulnerabilities in network software such as web server or TCP/IP stack.

DoS Attacks

•Classification of DoS Attacks (Cont...)

- | | | |
|---|--------------------------|--|
| 3 | Protocol attacks | Protocols here are rules that are to be followed to send data over network. These kind of attacks exploit a specific feature or implementation bug of some protocol installed at the victim's system to consume excess amounts of its resources. |
| 4 | Unintentional DoS attack | This is a scenario where a website ends up denied not due to a deliberate attack by a single individual or group of individuals, but simply due to a sudden enormous spike in popularity. This can happen when an extremely popular website posts a prominent link to a second, less well-prepared site, for example, as part of a news story. The result is that a significant proportion of the primary sites regular users', potentially hundreds of thousands of people, click that link within a few hours and have the same effect on the target website as a DDoS attack. |
-

Tools Used to Launch DoS Attack

Table 4.13 | Tools used to launch DoS attack

<i>Sr. No.</i>	<i>Tool</i>	<i>Brief Description</i>
1	Jolt2	A major vulnerability has been discovered in Windows' networking code. The vulnerability allows remote attackers to cause a DoS attack against Windows-based machines – the attack causes the target machine to consume 100% of the CPU time on processing of illegal packets.
2	Nemesy	This program generates random packets of spoofed source IP to enable the attacker to launch DoS attack.
3	Targa	It is a program that can be used to run eight different DoS attacks. The attacker has the option to launch either individual attacks or try all the attacks until one is successful.
4	Crazy Pinger	This tool could send large packets of ICMP to a remote target network.
5	SomeTrouble	It is a remote flooder and bomber. It is developed in Delphi.

DDoS Attacks

- It is a distributed DoS wherein a large number of zombie systems are synchronized to attack a particular system. The zombie systems are called **secondary victims** and **the main target is called primary victim**.
- Malware can carry DDoS attack mechanisms- one of the better-known examples of this is MyDoom.
- Typically, DoS mechanism triggered on a specific date and time. This type of DDoS attacks involves hardcoding the target IP address prior to release of the malware, Hence no further interaction is necessary to launch the attack.

DDoS Attacks

- A system may also be compromised with a Trojan, allowing the attacker to download a zombie agent. Nowadays, Botnet is the popular medium to launch DoS/DDoS attacks.

DDoS Attacks

How to protect from DoS/DDoS Attacks

Computer Emergency Response Team Coordination Center offers many preventive measures from being a victim of DoS Attack:

1. Implement router filters. This will lessen your exposure to certain DoS attacks.
2. If such filters are available for your system, install patches to guard against TCP SYN flooding.
3. Disable any unused or inessential network service. This can limit the ability of an attacker to take advantage of these services to execute a DoS attack.
4. Enable quota systems on your OS if they are available.
5. Observe your system's performance and establish baselines for ordinary activity. Use the baseline to gauge unusual levels of disk activity, CPU usage or network traffic.
6. Routinely examine your physical security with regard to your current needs.

DDoS Attacks

How to protect from DoS/DDoS Attacks

7. Use **Tripwire** or a similar tool to detect changes in configuration information or other files.
8. Invest in redundant and fault-tolerant network configurations.
9. Invest in and maintain “hot spares” – machine that can be placed into service quickly if a similar machine is disabled.
10. Establish and maintain regular backup schedules and policies, particularly for important configuration information.
11. Establish and maintain appropriate password policies, especially access to highly privileged accounts such as Unix root or MS Windows NT Administrator.

SQL Injection(SQL Insertion)

- **Structured Query Language (SQL)** is a database computer language designed for managing data in RDBMS.
- SQL injection is a code injection technique that exploits a security vulnerability occurring in the database layer of an application.
- The vulnerability is present when user input is either filtered incorrectly for string literal escape characters embedded in SQL statements or user input is not strongly typed and thereby unexpectedly executed.
- It is an instance of a more general class of vulnerabilities that can occur whenever one programming or scripting language is embedded inside another.

SQL Injection(SQL Insertion)

- The prime objective behind SQL injection attack is to obtain the information while accessing a database table that may contain personal information such as credit card numbers, social security numbers or passwords.
- Just as a legitimate user enters queries and additions to the SQL database via a web form, the attacker can insert commands to the SQL server through the same web form field.
- The attacker determines whether a database and the tables residing into it are vulnerable, before launching an attack. Many webpages take parameters from web user and make SQL query to the database. With SQL injection, it is possible for an attacker to send crafted username and/or password field that will change the SQL query.

SQL Injection(SQL Insertion)

Steps for SQL Injection attack

1. The attacker looks for the webpages that allow submitting data, that is, login page, search page, feedback, etc. The attacker also looks for the webpages that display the HTML commands such as POST or GET by checking the site's source code.
2. To check the source code of any website, right click on the webpage and click on "view source"(if you are using IE) - source code is displayed in the notepad. The attacker checks the source code of the HTML, and look for "FORM" tag in the HTML code. Everything between the <FORM> and </FORM> have potential parameters that might be useful to find the vulnerabilities.

```
<FORM action=search/search.asp method=post>
```

```
<input type=hidden name=A value=C>
```

```
</FORM>
```

SQL Injection(SQL Insertion)

Steps for SQL Injection attack

3. The attacker inputs a single quote under the text box provided on the webpage to accept the username and password. This checks whether the user-input variable is sanitized or interpreted literally by the server. If the response is an error message such as use "a"="a"(or something similar) then the website is found to be susceptible to an SQL injection attack.
4. The attacker uses SQL commands such as SELECT statement command to retrieve data from the database or INSERT statement to add information to

SQL Injection(SQL Insertion)

In summary, using SQL injections, attackers can:

1. Obtain some basic information if the purpose of the attack is reconnaissance
2. May gain access to the database by obtaining username and their password
3. Add new data to the database
4. Modify data currently in the database

SQL Injection(SQL Insertion)

How to prevent SQL Injection Attacks

SQL injection attacks occur due to poor website administration and coding. The following steps can be taken to prevent SQL injection:

1. Input validation

- Replace all single quotes to two single quotes.
- **Sanitize the input:** User input needs to be checked and cleaned of any characters or strings that could possibly be used maliciously. For eg., character sequences such as ;,--,select, insert and xp_ can be used to perform an SQL injection attack.
- **Numeric values** should be checked while accepting a query string value. Function – **IsNumeric()** for Active Server Pages should be used to check these numeric values.

- Keep all text boxes and form fields as short as possible

SQL Injection(SQL Insertion)

How to prevent SQL Injection Attacks

2. Modify error reports: SQL errors should not be displayed to outside users and to avoid this, the developer should handle or configure the error reports very carefully. These errors some time display full query pointing to the syntax error involved and the attacker can use it for further attacks.

3. Other preventions:

1. The default system accounts for SQL server should never be used.
2. Isolate database server and web server. Both should reside on different machines.
3. Most often attackers may make use of several extended stored procedures such as xp_cmdshell and xp_grantlogin in SQL injection attacks. In case such extended stored procedures are not used or have

Phishing and Identity Theft

Topics

1. Phishing

a. Introduction

b. Phishing Definition and types

c. Methods of Phishing

d. Phishing Techniques

e. Spear Phishing

f. Types of Phishing Scams

g. Phishing Toolkits and Spy phishing

**h. Phishing Counter Measures - Phishing
attack flowchart**

Topics

2. ID Theft

a.PII

b.Types of Identity Theft

c.Techniques of ID Theft

d.ID Theft - Countermeasures

**e.How to efface your online
Identity**

Phishing

- “Phishing” is the **use of social engineering tactics** to trick users into revealing confidential information.
- Phishing is equal parts of **technology and psychology** – resorted to a systematic way to exploit netizens, not only by individual attackers but also by organized criminal groups.
- **Prime objective** behind these **Phishing attacks** is **ID theft**.

Phishing

- This chapter aims **to lay the foundation** to understand Phishing and different techniques and methods of Phishing attacks.

Phishing

- **According to Wikipedia** It is the criminally fraudulent process of attempting to **acquire sensitive information such as usernames, passwords and credit card details** by masquerading as a trustworthy entity in an electronic communication.
- In summary, Phishing is a **type of deception** designed to steal your identity.

Phishing

How Phishing works?

1.Planning: Criminals, usually called as phishers, decide the target (i.e., specific business/business house/an individual) and determine how to get E-Mail address of that target or customers of that business.

Phishers often **use mass mailing and address collection techniques** as spammers.

Phishing

How Phishing works?

2. Setup: Once phishers know which business/business house to spoof and **who their victims are**, they will create methods for **delivering the message and to collect the data about the target**. Most often this involves E-Mail addresses and a webpage.

3. Attack: This is the step people are most familiar with-the phisher sends a **phony message** that appears to be from a reputable source.

Phishing

How Phishing works?

4.Collection: Phishers record the information of victims entering into webpages or pop-up windows.

5.Identity theft and fraud: Phishers use the information that they have gathered to make illegal purchases or commit fraud.

Phishing

- Mail is the popular medium used in the Phishing attacks and such E-Mails are also called as **Spams**; however, not all E-Mails are spam E-Mails.
- So It is important to understand these types of E-Mails with which we deal everyday.
- We will discuss two such E-Mails:
 - **(A) Spam E-Mails**
 - **(B) hoax E-Mails.**

Phishing

A. Spam E-Mails

- Also known as “**junk E-Mails**” they involve nearly identical messages sent to numerous recipients.
- Botnets networks of virus-infected computers, are used to send about 80% of Spam.
- **Types of Spam E-Mails are as follows:**
 - 1. Unsolicited bulk E-Mail (UBE):** It is synonym for SPAM
 - unsolicited E-Mail sent in large quantities
 - 2. Unsolicited commercial E-Mail (UCE):** Unsolicited E-Mails are sent in large quantities from commercial perspective.

Phishing

A. Spam E-Mails (Cont...)

- **Spam E-Mails** proved to be a popular medium for phishers to scam users to **enter personal information on fake websites** using E-Mail forged to look like as if it is from a bank or other organizations such as eBay, Amazon, Facebook
- Here are a few examples of phrases used to entice the user to take the action.
 - **“Verify your account”:**
 - **“You have won the lottery”:**
 - **“If you don’t respond within 48 hours, your account will be closed”:**

Phishing

- **Note that the purpose of a phished E-Mail is to obtain sensitive personal information about a netizen/Internet user and to do so E-Mail needs to deceive the intended recipient into believing that it is from a legitimate organization/institute.**

Phishing

A. Spam E-Mails (Cont...)

The ways to reduce the amount of Spam E-Mails we receive.

1. Share personal E-Mail address **with limited people and/or on public websites** – the more it is exposed to the public, the more Spam E-Mails will be received.
2. **Never reply or open any Spam E-Mails.** Any spam E-Mails that are opened or replied to inform the phishers not only about your existence but also about **validity of your E-Mail address.**

Phishing

A. Spam E-Mails (Cont...)

The ways to reduce the amount of Spam E-Mails we receive.

1. Disguise the E-Mail address on public website or groups by spelling out the sign “@” and the DOT (.); for example, **RajeevATgmailDOTcom**. This usually prohibits phishers to catch valid E-Mail addresses while gathering E-Mail addresses through programs.

Phishing

The ways to reduce the amount of Spam E-Mails we receive.

5. Use **alternate E-Mail** addresses to register for any personal or shopping website. Never ever use business E-Mail addresses for these sites but rather use E-Mail addresses that are free from Yahoo, Hotmail or Gmail.
6. Do not **forward** any E-Mails from unknown recipients.
7. Make a habit to **preview an E-Mail** (an option available in an E-Mail program) before opening it.
8. Never use **E-Mail address as the screen name** in chat groups or rooms.
9. **Never respond to a Spam E-Mail asking to remove your E-Mail address from the mailing distribution list.** More often it confirms to the phishers that your E-Mail address is active.

Phishing

B. Hoax E-Mails

- These are deliberate attempt to deceive or trick a user into **believing or accepting that something is real (BOMB)**, when the hoaxter (the person or group creating the hoax) knows it is false.
- Hoax E-Mails may or may not be Spam E-Mails. It is difficult sometimes to recognize whether an E-Mail is a "Spam" or a "hoax."
- The websites mentioned below can be used to check the **validity of such "hoax" E-Mails**
 - www.breakthechain.org:
 - www.hoaxbusters.org

Methods of Phishing

1) Dragnet :

- This method involves the use of spammed E-Mails, **bearing falsified corporate identification** (e.g., corporate names, logos and trademarks), which are addressed to a large group of people to websites or **pop-up windows with similarly falsified identification**.
- Dragnet phishers **do not identify specific prospective victims** in advance.
- Instead, they rely on **false information included in an E-Mail to trigger an immediate response by victims** taking victims to the websites or pop-up windows where they are requested to enter bank or credit card account data or other personal data.

Methods of Phishing (Cont..)

2) Rod-and-reel:

In this method, phishers identify specific prospective victims in advance, and convey false information to them to prompt their disclosure of personal and financial data.

- **For example:** on the phony webpage, availability of similar item for a better price is displayed which the victims may be searching for and upon visiting the webpage, victims were asked for personal information such as name, bank account numbers and passwords, before confirming that the "sale" and the information is available to the phisher easily.

Methods of Phishing

3) Lobsterpot:

- This method focuses upon use of **spoofed websites**. It consists of creating of **bogus/ phony websites**, similar to legitimate corporate ones, targeting a **narrowly defined class of victims**,
- These attacks are also known as “content injection Phishing.”
- The phisher **places a weblink into an E-Mail message** to make it look more legitimate and actually takes the victim to a phony scam site,
- These fake sites are also **called "spoofed" websites**. Once the netizen is into one of these spoofed sites, he/she might **unwittingly send personal** information to the con artists.
- Then they often use your information **to purchase goods, apply for a new credit card or otherwise steal your identity**.

Methods of Phishing

4) Gillnet:

- This technique relies far less on social engineering techniques and phishers **introduce malicious code into E-Mails and websites.**
- They can, for example, **misuse browser functionality by injecting hostile content into another site's pop-up window.**
- In some cases, the Malicious Code will change settings in user's systems so that **users who want to visit legitimate banking websites will be redirected to a look alike Phishing site.**
- In other cases, the Malicious Code will **record user's keystrokes and passwords when they visit legitimate banking sites,** and then transmit those data to phishers for later illegal access to users' financial accounts.

Phishing Techniques

- **URL (weblink) manipulation:**
 - In Phishing attack, these **URLs are usually supplied as misspelled**, for example, instead of **www.abcbank.com**, URL is provided as **www.abcbankl.com**.
 - Phishers use Lobsterpot method of Phishing and make the **difference of one or two letters in the URLs**, which is ignored by netizens.
 - This makes a big difference and it **directs users to a fake/bogus website** or a webpage.

Phishing Techniques

- **Filter evasion:**

- This technique **use graphics instead of text** to obviate from netting such E-Mails by anti-Phishing filters. Normally, these **filters are inbuilt into the web browsers.**

- **For example,**

- **Internet Explorer version 7 has inbuilt "Microsoft phishing filter."** One can enable it during the installation or it can be enabled post-installation. It is important to note that it is **not enabled by default.**

- Firefox 2.0 and above has inbuilt "**Google Phishing filter,**" duly licensed from Google. It is enabled by default.

- The Opera Phishing filter is dubbed **Opera Fraud Protection** and is included in version 9.5+.

Phishing Techniques

- **Flash Phishing:**

- **Anti-Phishing toolbars are installed/enabled** (see Table 5.2) to help checking the webpage content for signs of Phishing, but have limitations that they do not analyze flash objects at all.
- Phishers use it to emulate the legitimate website.
- Netizens believe that the website is "clean" and is a real website because anti-Phishing toolbar is unable to detect it.

Phishing Techniques

• Social Phishing:

- Phishers entice the netizens to reveal sensitive data by other means and it works in a systematic manner.
 - Phisher sends a mail as if it is sent by a bank asking to call them back because there was a security breach.
 - The victim calls the bank on the phone numbers displayed in the mail.
 - The phone number provided in the mail is a false number and the victim gets redirected to the phisher.
 - Phisher speaks with the victim in the similar fashion/style as a bank employee, asking to verify that the victim is the customer of the bank.
 - Phisher gets the required details swimmingly **ATM**

Phishing Techniques

- **Phone Phishing:**

- Phisher can use a **fake caller ID** data to make it appear that the call is received from a trusted organization to **entice the users to reveal their personal information such as account numbers and passwords.**

Phishing

Types of Phishing Scams

We have seen how phishers use numerous methods and techniques to launch Phishing attacks. The prevalent types of Phishing scams are discussed in this section.

- 1. Deceptive Phishing**
- 2. Malware-based Phishing**
- 3. Keyloggers**
- 4. Session hijacking**
- 5. In-session Phishing**
- 6. In-session Phishing**
- 7. Pharming**
- 8. System reconfiguration attacks**
- 9. Data theft**
- 10. Content-injection Phishing**
- 11. Search engine Phishing**
- 12. Man-in-the-middle Phishing**
- 13. SSL certificate Phishing::**

Types of Phishing Scams

1. Deceptive Phishing:

- Phishing scams started by broadcasting deceptive E-Mail messages with the objective of ID theft.
- E-Mails are broadcasted to a wide group of netizens asking about the need to verify banking account information/system failure requiring users to re-enter their personal information.
- The netizens easily get enticed and reveal their information by responding to these E-Mails and/or clicking on weblinks or signing onto a fake website designed by the phisher.

Phishing

Types of Phishing Scams

2. Malware-based Phishing:

- It refers to scams that involve running Malicious Code on the netizens system.
- Malware can be launched as an E-Mail attachment or as a downloadable file from a website or by exploiting known security vulnerabilities.

Phishing

Types of Phishing Scams

3. Keyloggers:

- Malware can embed a keylogger to track keyboard input and send relevant information to the phisher through the Internet.
- The keyloggers can also be embedded into netizen's browser as a small utility program which can start automatically when the browser is opened or can be embedded into system files as device drivers.

Phishing

Types of Phishing Scams

4. Session hijacking:

- It is an attack in which netizens' activities are monitored until they establish their bonafide credentials by signing into their account or begin the transaction and at that point the Malicious Code takes over and comport unauthorized actions such as transferring funds without netizen's

Phishing

Types of Phishing Scams

5. In-session Phishing:

- **It** is a Phishing attack based upon one web browsing session being able to detect the presence of another session (such as visit to an online banking website) on the same web browser and then a pop-up window is launched that pretends to be opened from the targeted session.

Phishing

Types of Phishing Scams

5. In-session Phishing (Cont...):

- Netizen believes this pop-up window is being a part of the targeted session and is used to steal netizen's personal information/data in the same way as with other Phishing attacks.
- The advantage of in-session Phishing attack is the phisher does not need the targeted website to be compromised but to rely on modern web browsers to

Phishing

Types of Phishing Scams

6. Web Trojans:

- It pops up to collect netizen's credentials and transmit them to the phisher while netizens are attempting to log in. Such pop-ups are usually invisible.

Phishing

Types of Phishing Scams

7. Pharming:

- It is a new threat evolved with a goal to steal online identity of the netizens and Pharming is known as one of the "P" in cybercrime
- **In Pharming, following two techniques are used:**
 1. Hosts poisoning
 2. DNS-based Phishing:

Phishing

Types of Phishing Scams

7. Pharming:

1. Hosts poisoning

- The most popular operating system (OS) in the world is Windows and it has “host names” in their host file. A simple text file was used in web address during early days of the Internet (i.e., before undertaking a DNS (Domain Name Server) lookup)].
- Phisher used to “**poison**” the host file to redirect the netizen to a fake/bogus website, designed and developed by the phisher, which will “look alike” the original website, to steal the netizen's personal information easily.

Phishing

Types of Phishing Scams

7. Pharming:

2. DNS-based Phishing:

- Phisher tampers with a DNS so that requests for URLs or name service return a fake address and subsequently netizens are directed to a fake site.
- Netizens usually are unaware that they are entering their personal confidential information in a website controlled by phishers and probably not even in the same country as the legitimate website.
- DNS-based Phishing is also known as **DNS hijacking**.

Phishing

Types of Phishing Scams

7. Pharming:

2. DNS-based Phishing:

- Phisher tampers with a DNS so that requests for URLs or name service return a fake address and subsequently netizens are directed to a fake site.
- Netizens usually are unaware that they are entering their personal confidential information in a website controlled by phishers and probably not even in the same country as the legitimate website.
- DNS-based Phishing is also known as **DNS hijacking**.

Phishing

Types of Phishing Scams

8. System reconfiguration attacks:

- Phisher can intrude into the netizens' system (i.e., computer) to modify the settings for malicious purposes.
- For example, URLs saved under favorites in the browser might be modified to redirect the netizen to a fake/bogus “look alike” websites (i.e., URL for a website of a bank can be changed from “www.xyzbank.com” to www.xyzbanc.com.).

Phishing

Types of Phishing Scams

9. Data theft:

- Critical and confidential data getting stolen is one of the biggest concerns in the modern times.
- As more and more information resides on the corporate servers and the Web (including what happens with “cloud computing”), attackers have a boom time because taking away/copying information in electronic form is so easy!
- Unsecured systems (e.g., computers enabled with the Internet facility and with inappropriate security settings) are often found to be inappropriately maintained, from cyber security perspective.

Phishing

Types of Phishing Scams

9. Data theft (Cont...):

- When such systems are connected, the web servers can launch an attack with numerous methods and techniques.
- Data theft is a widely used approach to business espionage. Phishers can easily make profit from selling the stealth confidential communications, design documents, legal opinions and employee-related records to those who may want to embarrass or cause economic damage to competitors.

Phishing

Types of Phishing Scams

10.Content-injection Phishing:

- In this type of scam, phisher replaces part of the content of a legitimate website with false content to mislead the netizen to reveal the confidential personal information.
- For example, Phisher may insert Malicious Code to capture netizen's credentials that can secretly collect information and send it to phisher.

Phishing

Types of Phishing Scams

11.Man-in-the-middle Phishing:

- In this type of attack, phisher positions himself between the netizen and the legitimate website or system.
- Phisher records the input being provided by the netizen but continues to pass it on to the web server so that netizens' transactions are not affected.
- Later on phisher can either sell or use the information or credentials collected when the user is not active on the system.
- 'This attack is very difficult to detect compared to

Phishing

Types of Phishing Scams

12.Search engine Phishing:

- It occurs when phishers create websites with attractive sounding offers (often found too good to be true) and have them indexed legitimately with search engines.
- Netizens find websites during their normal course of search for products or services and are trapped to reveal their personal information.
- For example, phishers set up fake/bogus banking websites displaying an offer of lower credit costs or better interest rates than other banks.
- Netizens who use these websites to save or make more from interest charges are encouraged to transfer existing accounts and enticed to giving up their details.

Phishing

Types of Phishing Scams

13.SSL certificate Phishing

- Phishers target web servers with SSL certificates to create a duplicitous website with fraudulent webpages displaying familiar "lock" icon.
- It is important to note that, in such types of scams, SSL certificates are always found to be legitimate as they match the URL of the fake pages that are mimicking the target brands but in reality had no connection to these brands displayed.
- It is difficult to recognize such websites; however, smart netizens can detect such deception after reviewing the certificate and/or whether the website has been secured

Phishing

Phishing Countermeasures

The countermeasures explained in Table 5.1 will prevent malicious attacks that phisher may target to gain the unauthorized access to the system to steal the relevant personal information about the victim, from the system.

Phishing

Phishing Countermeasures

Table 5.1 | How to avoid being victim of Phishing attack

<i>Sr. No.</i>	<i>Security Measures</i>	<i>Brief Description</i>
1	Keep antivirus up to date	Important aspect is to keep antivirus software up to date because most antivirus vendors have signatures that protect against some common technology exploits. This can prevent things such as a Trojan disguising the web address bar or mimicking the secure link (i.e., HTTPS)
2	Do not click on hyperlinks in E-Mails	It should always be practiced that, in case an E-Mail has been received from unknown source, clicking on any hyperlinks displayed in an E-Mail should be avoided. This may lead to either the link taking the victim to the website created by the phisher or triggering a Malicious Code installation on the system. Instead, to check out the link, manually retyping it into a web browser is highly recommended.
3	Take advantage of anti-Spam software	Anti-Spam software can help keep Phishing attacks at a minimum. A lot of attacks come in the form of Spam and by using anti-Spam software, many types of Phishing attacks are reduced because the messages will never end up in the mailboxes of end-users.

Phishing - Phishing Countermeasures

Phishing Countermeasures

<i>Sr. No.</i>	<i>Security Measures</i>	<i>Brief Description</i>
4	Verify https (SSL)	Ensure the address bar displays “https://” rather than just “http://” along with a secure lock icon than has been displayed at the bottom right-hand corner of the web browser while passing any sensitive information such as credit cards or bank information. One may like to check by double-clicking the lock to guarantee the third-party SSL certificate that provides the https service. Always ensure that the webpage is truly encrypted.
5	Use anti-Spyware software	Keep Spyware down to a minimum by installing an active Spyware solution such as Microsoft anti-Spyware and also scanning with a passive solution such as Spybot. If for some reason your browser is hijacked, anti-Spyware software can often detect the problem and provide a fix.
6	Get educated	Always update the knowledge to know new tools and techniques used by phishers to entice the netizens and to understand how to prevent these types of attacks. Report any suspicious activity observed to nearest cyber-security cell.

Phishing - Phishing Countermeasures

Phishing Countermeasures

- | | | |
|---|---|--|
| 7 | Use the Microsoft Baseline Security Analyzer (MBSA) | The netizens on the Microsoft platform should use MBSA to ensure the system is up to date by applying all the security patches. MBSA is a free tool available on Microsoft's website. This protects the IT systems against known exploits in Internet Explorer and Outlook (and Outlook Express) that can be used in Phishing attacks. |
| 8 | Firewall | Firewall can prevent Malicious Code from entering into the system and hijacking the browser. Hence, a desktop (software) such as Microsoft's built-in software firewall in Windows-XP and/or network (hardware) firewall should be used. It should be up to date in case any cybersecurity patches have been released by the vendor. |
| 9 | Use backup system images | Always keep a backup copy or image of all systems to enable to revert to a original system state in case of any foul play. |

Phishing-Phishing Countermeasures

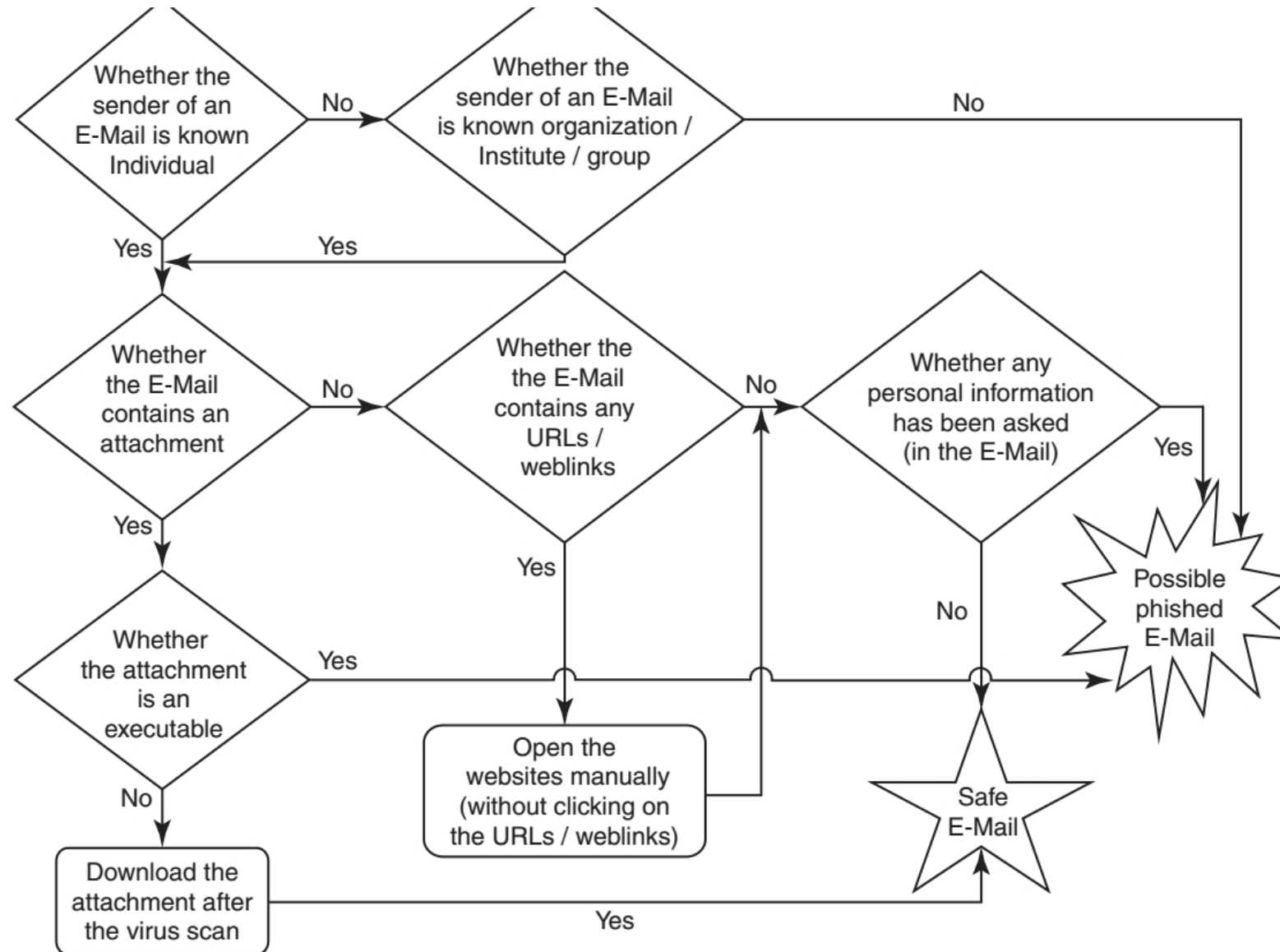
Phishing Countermeasures

- | | | |
|----|---|--|
| 10 | Do not enter sensitive or financial information into pop-up windows | A common Phishing technique is to launch a bogus pop-up window when someone clicks on a link in a Phishing E-Mail message. This window may even be positioned directly over a legitimate window a netizen trusts. Even if the pop-up window looks official or claims to be secure, entering sensitive information should be avoided because there is no way to check the security certificate. |
| 11 | Secure the hosts file | The attacker can compromise the hosts file on desktop system and send a netizen to a fraudulent site. Configuring the host file to read-only may alleviate the problem, but complete protection will depend on having a good desktop firewall such as Zone Alarm that protects against tampering by outside attackers and keeps browsing safe. |
| 12 | Protect against DNS Pharming attacks | This is a new type of Phishing attack that does not Spam you with E-Mails but poisons your local DNS server to redirect your web requests to a different website that looks similar to a company website (e.g., eBay or PayPal). This is explained in Box 5.11. |

Phishing- Sanitizing Proxy System (SPS) Algorithm

- The proposal of system based on a simple filtering algorithm, Sanitizing Proxy System (SPS), has been suggested under the white paper by the authors Daisuke Miyamoto, Hiroaki Hazeyama and Youki Kadobayashi from Nara Institute of Science and Technology, Japan.
- The key idea behind SPS is that web Phishing attack can be immunized by removing part of the content that entices the netizens into entering their personal information.
- SPS sanitizes all HTTP responses from suspicious URLs with warning messages; however, netizens will realize that they are browsing Phishing sites.

Phishing - Sanitizing Proxy System (SPS) Algorithm



Identity Theft (ID Theft)

Identity Theft

- ID theft involves unauthorized **access to personal data**.
- This term is used to refer to fraud that involves someone pretending to be someone else to steal money or get other.
- The person whose identity is used can suffer various consequences when he/she is held responsible for the perpetrator's actions.
- ID theft is a punishable offense under the Indian IT Act (Section 66C and Section 66D).

Identity Theft

- **Section 66C** of the Indian IT Act states that "***whosoever fraudulently dishonestly make use of the electronic signature, password or any other unique identification feature of any other person, shall be punished with imprisonment of either description for a term which may extend to three years and shall also be liable to fine which may extend to rupees one lakh.***"
- **Section 66D** of the Indian IT Act states that "***whoever, by means for any communication device or computer resource cheats by personation, shall be punished with imprisonment of either description for a term which may extend to three years and shall also be***

Identity Theft

- **Federal Trade Commission (FTC) has provided the statistics about each one of the identity fraud mentioning prime frauds presented below.**
 - 1. Credit card fraud (26%):** The highest rated fraud that can occur is when someone acquires the victim's credit card number and uses it to make a purchase.
 - 2. Bank fraud (17%):** cheque theft and Automatic Teller Machines (ATM) pass code theft have been reported that are possible with ID theft.
 - 3. Employment fraud (12%):** In this fraud, the attacker borrows the victim's valid SSN to obtain a job.
 - 4. Government fraud (9%):** This type of fraud includes SSN, driver license and income tax fraud.
 - 5. Loan fraud (5%):** It occurs when the attacker applies for a loan on the victim's name

Identity Theft

Personally Identifiable Information (PII)

- The fraudster always has an eye on the information which can be used to uniquely identify, contact or locate a single person or can be used with other sources to uniquely identify a single individual.
- PII has four common variants based on personal, personally, identifiable and identifying.

Identity Theft

Personally Identifiable Information (PII)

- The fraudsters attempt to steal the elements mentioned below, which can express the purpose of distinguishing individual identity:
 1. Full name;
 2. National identification number (e.g., SSN);
 3. Telephone number and mobile phone number;
 4. Driver's license number;
 5. Credit card numbers;
 6. Digital identity (e.g., E-Mail address, online account ID and password);
 7. Birth date/birth day;
 8. Birthplace;
 9. Face and fingerprints

Identity Theft

Personally Identifiable Information (PII)

- The fraudster may search for following about an individual, which is less often used to distinguish individual identity; however these can be categorized as **potentially PII** because they can be combined with other personal information to identify an individual.
 1. First or last name;
 2. age;
 3. country, state or city of residence;
 4. gender;
 5. name of the school/college/workplace;
 6. job position, grades and/or salary;
 7. criminal record.

Identity Theft

Personally Identifiable Information (PII)

- The information can be further classified as
 - **(a) non-classified**
 - **b) classified.**

Identity Theft

Personally Identifiable Information (PII)

- **Non-classified information**

- **Public information:** Information that is a matter of public record or knowledge.
- **Personal information:** Information belongs to a private individual but the individual commonly may share this information with others for personal or business reasons (e.g., addresses, tele- phone numbers and E-Mail addresses).
- **Routine business information:** Business information that do not require any special protection and may be routinely shared with anyone inside or outside of the business.

Identity Theft

Personally Identifiable Information (PII)

- **Non-classified information**

- **Private information:** Information that can be private if associated with an individual and individual can object in case of disclosure (e.g., SSN, credit card numbers and other financial information).
- **Confidential business information:** Information which, if disclosed, may harm the business (e.g., sales and marketing plans, new product plans and notes associated

Identity Theft

Personally Identifiable Information (PII)

- **Classified information**

- **Confidential:** Information that requires protection and unauthorized disclosure could damage national security (e.g., information about strength of armed forces and technical information about weapons).
- **Secret:** Information that requires substantial protection and unauthorized disclosure could seriously damage national security (e.g., national security policy, military plans or intelligence operations)

Identity Theft

Personally Identifiable Information (PII)

- **Classified information**

- **Top secret:** Information that requires the highest degree of protection and unauthorized disclosure could severely damage national security (e.g., vital defense plans and cryptologic intelligence systems).

Identity Theft

Personally Identifiable Information (PII)

- **Classified information** : Identity is stolen in order for someone to commit the crime in many area
 1. Financial identity theft;
 2. criminal identity theft;
 3. identity cloning;
 4. business identity theft;
 5. medical identity theft;
 6. synthetic identity theft;
 7. child identity theft.

Identity Theft

Types of Identity Theft

- Financial Identity Theft
- Criminal Identity Theft
- Identity Cloning
- Business Identity Theft
- Medical Identity Theft
- Synthetic Identity Theft
- Child Identity Theft

Identity Theft

Types of Identity Theft

- **Financial Identity Theft**

- Financial ID theft includes bank fraud, credit card fraud, tax refund fraud, mail fraud and several more.
- Financial identity occurs when a fraudster makes a use of someone else's identifying details, such as name, SSN and bank account details, to commit fraud that is detrimental to a victim's finances.
- For example, the fraudster fraudulently can open a new credit card account in the victim's name and the card charges up, payment is neglected, leaving the victim with bad credit history (and a world of debt).

Identity Theft

Types of Identity Theft

- **Financial Identity Theft (Cont...)**

- In some cases, the fraudster will completely take over a victim's identity, which enables the fraudster to easily open bank accounts, multiple credit cards, purchase a vehicle, receive a home mortgage or even find employment in the victim's name.
- The process of recovering from the crime is often expensive, time-consuming and psychologically painful.
- Many a times, before a crime is detected, the fraudster is capable of running up hundreds to thousands of dollars worth of debt in the victim's name.

Identity Theft

Types of Identity Theft

- **Financial Identity Theft (Cont...)**

- This type of fraud often destroys a victim's credit and it may take weeks, months or even years to repair.
- As technology moves along and fraudsters become more advanced, financial ID theft will continue to pose a great threat to many individuals

Identity Theft

Types of Identity Theft

Criminal Identity Theft

- It involves taking over someone else's identity to commit a crime such as enter into a country, get special permits, hide one's own identity or commit acts of terrorism. These criminal activities can include:
 1. Computer and cybercrimes;
 2. organized crime;
 3. drug trafficking;
 4. alien smuggling;
 5. money laundering.

Identity Theft

Types of Identity Theft

Criminal Identity Theft (Cont...)

- This type of fraud/theft occurs when a fraudster uses the victim's name upon an arrest or during a criminal investigation.
- The personal information given by a fraudster to a law enforcement officer may include counterfeited/faked document such as driver's license, birth certificate, etc.
- Unfortunately, the victim of criminal ID theft may not know what warrant has been issued under his/her name for quite some time.

Identity Theft

Types of Identity Theft

Criminal Identity Theft (Cont...)

- The victim will only come to know in case of being detained on a routine traffic stop and arrested due to outstanding and overdue debts.
- In some cases, the fraudster will appear in court for the violation and enter a guilty plea without the victim's knowledge.
- This may place the victim's name into countywide or state-wide criminal database with a huge blemish language on the record.

Identity Theft

Types of Identity Theft

Criminal Identity Theft (Cont..)

- The victims of this crime are left with the burden to clear their own name in the eyes of the criminal justice system.
- It is very important to act quickly in order to minimize the damage and get your life back in order.
- What makes the process so difficult is the fact that officials working within the criminal justice system are the only ones capable of correcting the data. It is very crucial and important to contact local police department immediately in case of becoming a victim of criminal ID theft.
- This should be the first step in building a case and clearing

Identity Theft

Types of Identity Theft

Identity Cloning

- Instead of stealing the personal information for financial gain or committing crimes in the victim's name, identity clones compromise the victim's life by actually living and working as the victim.
- ID clones may even pay bills regularly, get engaged and married, and start a family.
- In summary, identity cloning is the act of a fraudster living a natural and usual life similar to a victim's life, may be at a different location.

Identity Theft

Types of Identity Theft

Identity Cloning (Cont...)

- An identity clone will obtain as much information about the victim as possible.
- They will look to find out what city and state the victim (he/she) was born in, what street he/she grew up on, where he/she attended school and what relationships he/she may have been involved in.
- They will also want to know information concerning the victim's parents and other family members. In a nutshell, identity clones want as much personal information about the victim as they can attain.
- This enables them to answer questions in an informative manner when they are on the move or asked about the

Identity Theft

Types of Identity Theft

Business Identity Theft

- It is extremely important to protect **business sensitive information (BSI)** to avoid any further scams.
- BSI is the information about the business/organization, privileged in nature and/or proprietary information which, if it is compromised through alteration, corruption, loss, misuse or unauthorized disclosure, could cause serious damage to the organization. ("**sensitive asset**")
- Identity theft in the business context occurs most often when someone knocks off the victim's product and masquerades their shoddy goods as victim's.
- It is a kind of intellectual property theft.

Identity Theft

Types of Identity Theft

Business Identity Theft (Cont...)

- Nowadays, technology has made it easier for the trademarks and security devices such as holograms to be knocked off swimmingly.

- **Example**

A fraudster rents a space in the same building as victim's office. Then he applies for corporate credit cards using victim's firm name. The application passes a credit check because the company name and address match, but the cards are delivered to the fraudster's mailbox. He sells them on the street and vanishes before the victim discovers the firm's credit is

Identity Theft

Types of Identity Theft

Business Identity Theft (Cont...)

- The consequences of business ID theft may call for a disaster to the business, such as call out from market and damage to the reputation, and hence it is extremely important to employ countermeasures for such type of attacks

Identity Theft

Types of Identity Theft

Medical Identity Theft

- There are greater opportunities for protected health information (PHI) changing hands when multiple agencies are connected over the Internet (medical representatives, health officers, doctors, medical insurance organizations, hospitals)
- Because of electronic records, stolen information can be used by the fraudster or sold in the black market to

Identity Theft

Types of Identity Theft

Medical Identity Theft (Cont...)

- **This could lead to many more cases.** For example, invoice of thousands of dollars of emergency medical services was received by a man situated in Houston (Texas), who had never had any health issues, **as reported in the New York Times.** Because a fraudster had used this man's identity for the fraudster's emergency medical needs
- Also, If the fraudster has successfully stolen the victim's identity and received treatment, the record can become part of a victim's permanent medical record

Identity Theft

Types of Identity Theft

Medical Identity Theft (Cont...)

- **This could lead to many more cases.** For example, invoice of thousands of dollars of emergency medical services was received by a man situated in Houston (Texas), who had never had any health issues, **as reported in the New York Times.** Because a fraudster had used this man's identity for the fraudster's emergency medical needs
- Also, If the fraudster has successfully stolen the victim's identity and received treatment, the record can become part of a victim's permanent medical record

Identity Theft

Types of Identity Theft

Medical Identity Theft (Cont...)

- **Example :** A patient could be unconscious after an accident. The emergency room reads that during a previous admission the "patient indicated he/she is not allergic to the medication the doctor believes will be most beneficial for the unconscious patient. Relying on the prior medical record, the doctor administers that drug which, in reality, the patient is severely allergic to.

Identity Theft

Types of Identity Theft

Medical Identity Theft (Cont...)

- **According to a 2008 Identity Theft Resource Center survey, some of the reasons why medical ID theft is particularly damaging the victims include:**

1. Approximately one-third of victims of medical ID theft surveyed had someone else's medical information or medical history on their medical record, increasing the possibility of patients being treated incorrectly because of incorrect medical records.
2. More than 10% of victims of medical ID theft surveyed were denied health or life insurance for unexplained reasons.

Identity Theft

Types of Identity Theft

Medical Identity Theft (Cont...)

- ModernHealthcare.com **reported a noticeable spike in attempted medical ID theft.**
- The World Privacy Forum estimates that there are more than 250,000 cases of medical ID theft each year and acknowledges that medical ID theft is a crime that can cause great harm to the victims.

Identity Theft

Types of Identity Theft

Synthetic Identity Theft

- This is an advanced form of ID theft in the ID theft world.
- The fraudster will take parts of personal information from many victims and combine them.
- The new identity is not any specific person, but all the victims can be affected when it is used.

Identity Theft

Types of Identity Theft

Child Identity Theft

- Parents might sometimes steal their children's identity to open credit card accounts, utility accounts, bank accounts and even to take out loans or secure leases because their own credit history is insufficient or too damaged to open such accounts.

Identity Theft

Techniques of ID Theft

The attackers use both traditional, that is human-based, methods as well as computer-based techniques.

1. Human-based methods
2. Computer-based technique

Identity Theft - Techniques of ID Theft

Human-based methods: These methods are techniques used by an attacker without and/or minimal use of technology

- 1. Direct access to information:** People who have earned a certain degree of trust (house cleaners, babysitters, nurses, friends or roommates) can obtain legitimate access to a business or to a residence to steal the required personal information.
- 2. Dumpster diving:** Retrieving documents from trash bins is very common and explained in Chapter 2.
- 3. Theft of a purse or wallet:** Wallet often contains bank credit cards, debit cards, driving license, medical insurance identity card and what not. Pickpockets work on the street as well as in public transport and exercise rooms to steal the wallets and in turn sell the personal information.

Identity Theft - Techniques of ID Theft

4. Mail theft and rerouting:

- It is easy to steal the postal mails from mailboxes, which has poor security mechanism and all the documents available to the fraudster are free of charge, for example, Bank Mail (credit cards and account statements), administrative forms or partially completed credit offers.
- The fraudster can use your name and other information that may prove to be harmful for an individual in the near future.
- Therefore, return items to the sender or request a of address.

Identity Theft - Techniques of ID Theft

- 5. Shoulder surfing:** People who loiter around in the public facilities such as in the cybercafes, near ATMs and telephone booths can keep an eye to grab the personal details.
- 6. False or disguised ATMs ("skimming"):** Just as it is possible to imitate a bank ATM, it is also possible to install miniaturized equipment on a valid ATM. This equipment (a copier) captures the card information, using which, duplicate card can be made and personal identification number (PIN) can be obtained by stealing the camera films.
- 7. Dishonest or mistreated employees:** An employee or partner with access to the personal files, salary information, insurance files or bank information can gather all sorts of confidential information and can use it to provide sufficient

Identity Theft - Techniques of ID Theft

8. Telemarketing and fake telephone calls:

This is an effective method for collecting information from unsuspecting people. The caller who makes a "cold call" (supposedly from a bank) asks the victim to verify account information immediately on the phone, often without much verification

Identity Theft - Techniques of ID Theft

Computer-based technique: These techniques are attempts made by the attacker to exploit the vulnerabilities within existing processes and/or systems.

1.Backup theft: In addition to stealing equipment from private buildings, attackers also strike public facilities such as transport areas, hotels and recreation centers. They carefully analyze stolen equipment or backups to recover the data.

2.Hacking, unauthorized access to systems and database theft: Besides stealing the equipment and/or hardware, criminals attempt to compromise information systems with various tools, techniques

Identity Theft - Techniques of ID Theft

3. Phishing: Phishing is explained in Section 5.2.

4. Pharming:

- The attackers setup typo or matching domain names of the target (usually of popular banks and financial institutions) and install websites with similar look and feel.
- Hence, even if the user types-in incorrect URL (e.g., instead of `www.xyzbank.com`, URL is punched as `www.xyzbanc.com`), the user gets the website with the same look and feel.
- This website is not real and is hosted with the sole purpose to extract personal information from the netizen.

Identity Theft - Techniques of ID Theft

5. Redirectors:

- These are malicious programs that redirect users' network traffic to locations they did not intend to visit.
- The highest volume in traffic occurs with Malicious Code that simply modifies the victim's DNS server settings or the hosts file to redirect either some specific DNS lookups or all DNS lookups to a fraudulent DNS server.
- The fraudulent DNS server replies with "good" answers for most domains.
- However, when attackers want to direct the victim to a fraudulent site, they simply modify their name server responses.

Identity Theft - Techniques of ID Theft

5. Redirectors (Cont...):

- These are malicious programs that redirect users' network traffic to locations they did not intend to visit.
- The highest volume in traffic occurs with Malicious Code that simply modifies the victim's DNS server settings or the hosts file to redirect either some specific DNS lookups or all DNS lookups to a fraudulent DNS server.
- The fraudulent DNS server replies with "good" answers for most domains.
- However, when attackers want to direct the victim to a fraudulent site, they simply modify their name server responses.

Identity Theft - Techniques of ID Theft

6. Hardware:

- During March 2005, police discovered that the London office of the Japanese bank Sumitomo had been the target of a group of hackers for several months. The investigators initially believed that the attackers had used a Trojan. However, after several days of exploration, they found a tiny keystroke-recording device inserted where the keyboard cable connects to the back of the computer. A quick search on the Internet yields a list of a half-dozen companies that sell this type of product.

Identity Theft - Countermeasures

1. Monitor your credit closely
2. Keep records of your financial data and transactions
3. Install security software
4. Use an updated Web browser
5. Be wary of E-Mail attachments and links in both E-Mail and instant messages.
6. Store sensitive data securely
7. Shred documents
8. Protect your PII
9. Stay alert to the latest scams

Identity Theft - Countermeasures

<i>Sr. No.</i>	<i>Security Measures</i>	<i>Brief Description</i>
1	Monitor your credit closely	The credit report contains information about your credit accounts and bill paying history so that you can be tipped off when someone is impersonating you. Watch for suspicious signs such as accounts you did not open. You can also consider identity protection services, which range from credit monitoring to database scanning, for extra security.
2	Keep records of your financial data and transactions	Review your statements regularly for any activity or charges you did not make.
3	Install security software	Install security software (firewall, antivirus and anti-Spyware software) and keep it up to date as a safety measure against online intrusions.

Identity Theft - Countermeasures

- | | | |
|---|--|---|
| 4 | Use an updated Web browser | Use an updated web browser to make sure you're taking advantage of its current safety features. |
| 5 | Be wary of E-Mail attachments and links in both E-Mail and instant messages. | Use caution even when the message appears to come from a safe sender, as identity information in messages can easily be spoofed (see Appendix C to learn E-Mail security and etiquettes). |
| 6 | Store sensitive data securely | Just as you keep sensitive paper documents under lock and key, secure sensitive online information. This can be done through file encryption software. |

Identity Theft - Countermeasures

- 7 Shred documents
It is important to shred the documents that contain personal or financial information (both paper and electronic) before discarding them. This prevents dumpster diving and, in the online world, the ability for hackers to bypass information that has not been permanently deleted from your system.
- 8 Protect your PII
Be cautious about giving out your personally identifiable information (PII) to anyone. Find out why the information is needed, and if it's absolutely necessary to give out. Be careful about the details you provide about yourself online, such as on social networking sites.

Identity Theft - Countermeasures

- 7 Shred documents

It is important to shred the documents that contain personal or financial information (both paper and electronic) before discarding them. This prevents dumpster diving and, in the online world, the ability for hackers to bypass information that has not been permanently deleted from your system.
- 8 Protect your PII

Be cautious about giving out your personally identifiable information (PII) to anyone. Find out why the information is needed, and if it's absolutely necessary to give out. Be careful about the details you provide about yourself online, such as on social networking sites.

Identity Theft - Countermeasures

- 9 Stay alert to the latest scams Awareness and caution are effective methods to counter fraud. Create awareness among your friends and family members by sharing security tips you learn with them.

Identity Theft

How to efface your online Identity

- Every time details about your identity and/or about your personal information are revealed on the Internet, you are prone to be a victim for ID theft/fraud.
- Hence, netizens may think to either protect their identity and/or would like to erase their identity, that is, every footprint available on the Internet.
- However, it is highly impossible to get one single tool that can completely eradicate each of your footprint from the Internet.

Identity Theft

How to efface your online Identity

<i>Sr. No.</i>	<i>Websites</i>	<i>Brief Description</i>
1	www.giantmatrix.com	Anti Tracks: These are set of tools that appear to be a complete solution to protect your online identity, sensitive data and maintaining the integrity of your system by hiding system's IP address, securely locking and hiding important files and folders and maintaining a healthy system performance, which keeps the system in top-notch condition.

Identity Theft

How to efface your online Identity

2

www.privacyeraser.com

Privacy Eraser Pro: It protects Internet privacy by cleaning up all the tracks of Internet and computer activities and supports almost all popular web browsers. The main features of this utility are as follows:

- Erase Browser Cache Files, Browser History, Cookies, Browser Address Bar History and Browser AutoComplete Memory.
- File Shredder: Securely shred files and folders.
- Cleaning Free Disk Space (Windows FAT/FAT32/NTFS).
- Speed up the system.

Identity Theft

How to efface your online Identity

- 3 www.reputationdefender.com **MyPrivacy:** It removes your personal information such as name, address, age, phone, past address and any other related information. It also helps by continuously monitoring the Internet to remove the footprint available on the Internet.